République du Cameroun

Université de Yaoundé I

École Nationale Supérieure Polytechnique de Yaoundé

Département de Génie Informatique · Niveau 4

Analyse des Risques et Gestion de Crise

Analyser, auditer, continuer, décider :
du registre des risques à la cellule de crise

ARGC - UE GES4062



MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | LIMSI | ENSPY

École Nationale Supérieure Polytechnique de Yaoundé · Université de Yaoundé I

maletyon@proton.me

Année académique 2026–2027

Version 1.0 | Document pédagogique de l'UE GES4062

AVANT-PROPOS

> « Le risque se gère avant, la crise pendant,
> et l'apprentissage après. »
>
> Principe du cours

Ce cours s'adresse aux élèves ingénieurs de quatrième année du Département de Génie Informatique de l'École Nationale Supérieure Polytechnique de Yaoundé. Il suppose acquis le cours de sécurité informatique (SEC3266) et prolonge l'audit des systèmes d'information (INF3226) : il ne réexplique pas les mesures techniques, il apprend à décider à leur sujet, à vérifier qu'elles tiennent, et à diriger l'organisation quand elles ont cédé.

Il repose sur deux convictions. La première : un risque n'est pas une couleur dans une matrice, mais une incertitude sur des pertes, que l'on peut estimer, discuter et réduire. La seconde : une crise ne se gère pas avec un plan, mais avec une organisation entraînée, qui sait qui décide, qui informe et qui consigne. Entre les deux, l'audit vérifie que ce que l'on croit en place l'est vraiment, et la continuité garantit que l'essentiel reprend dans les délais convenus.

Ce que ce cours n'est pas. Il n'est pas une préparation à une certification, ni un recueil de modèles à remplir, ni un cours de communication institutionnelle. Les méthodes y sont présentées avec leurs limites, et les chiffres avec leur marge.

Ce que ce cours est. Un traité de vingt-six chapitres, en six parties précédées d'un prologue. La Partie I pose les fondements : risque et incertitude, perception et biais, gouvernance, cadres de référence, obligations juridiques. La Partie II apprend à analyser : identifier, coter, conduire EBIOS Risk Manager, quantifier avec FAIR, simuler par Monte-Carlo, traiter et rendre compte. La Partie III apprend à auditer le dispositif selon l'ISO 19011. La Partie IV traite des incidents et de la continuité. La Partie V est consacrée à la gestion de crise : cellule, décision, communication, exercices. La Partie VI apprend à tirer les leçons et à mesurer la résilience, y compris ce que l'on en ignore.

Un fil rouge. Le cours suit l'entreprise fictive LiZbiZ, société de logistique aux quatre centres de données, frappée par un rançongiciel une nuit de mars (Opération GAROUA) : le cours de sécurité en a étudié les causes techniques ; celui-ci étudie la décision, avant, pendant et après. L'Opération LIZBIZ suit le programme de gestion des risques et l'audit qui ont suivi ; l'Opération WOURI, la continuité de la BANQUE SANAGA ; l'Opération MOUNGO, l'inondation d'un entrepôt de Douala. Les noms, les

dates et les montants sont fictifs ; les méthodes sont exactes, et les textes de loi sont cités d'après leur version officielle.

Comment travailler. Lisez chaque chapitre avec sa fiche d'auto-évaluation ; faites les exercices avant de lire leurs corrigés ; pratiquez dans les labs de NDAP SUKULU. Prenez l'habitude que le cours cherche à transmettre : séparer ce que l'on a constaté de ce que l'on en pense, donner une marge avec chaque chiffre, et dire ce que l'on ne sait pas.

MINKA MI NGUIDJOÏ Thierry Emmanuel
Yaoundé, novembre 2026

MODE D'EMPLOI DU COURS

Structure générale

Le cours compte un prologue et six parties, soit 26 chapitres, pour 60 heures en présentiel réparties en trente séances de deux heures. Les fiches d'auto-évaluation et les dix laboratoires de NDAP SUKULU sont des travaux à faire hors de ces 60 heures.

Partie	Thème	Compétences visées	Niveau
Prologue	Le matin du 6 mars	Lire une crise, séparer constatation et opinion	★☆☆
I	Fondements du risque	Incertitude, biais, gouvernance, cadres, droit	★☆☆
II	Analyser les risques	Identifier, coter, EBIOS RM, FAIR, Monte-Carlo, traiter	★★☆
III	Auditer le dispositif	Programme, preuves, échantillons, rapport	★★☆
IV	Incidents et continuité	Incidents, analyse d'impact, plans, reprise, exercices	★★☆
V	Gestion de crise	Cellule, décision, communication, exercices	★★☆ à ★★★
VI	Apprendre et mesurer	Retour d'expérience, OUI / NON / NEK	★★★

Les trente séances

© *MaletYon*

Séance	Contenu	Partie
1	Prologue : le matin du 6 mars	Prologue
2	Risque, incertitude et décision (Ch. 1)	I
3	Percevoir le risque (Ch. 2)	I
4	Gouvernance des risques (Ch. 3)	I
5	Les cadres de management des risques (Ch. 4)	I
6	Obligations juridiques (Ch. 5)	I
7	Identifier les risques (Ch. 6)	II
8	Échelles et matrices (Ch. 7)	II
9–10	ISO/IEC 27005 et EBIOS Risk Manager (Ch. 8)	II
11–12	Analyse quantitative, FAIR (Ch. 9)	II
13	Simuler : Monte-Carlo (Ch. 10)	II
14	Traiter, suivre, rendre compte (Ch. 11)	II
15	L'audit selon l'ISO 19011 (Ch. 12)	III
16	Conduire l'audit (Ch. 13)	III
17	Auditer la gestion des risques et le SMSI (Ch. 14)	III
18	Le rapport et le suivi (Ch. 15)	III
19	Gérer les incidents (Ch. 16)	IV
20	L'analyse d'impact sur l'activité (Ch. 17)	IV
21	Stratégies et plans de continuité (Ch. 18)	IV
22	Reprise informatique et résilience (Ch. 19)	IV
23	Exercer et tester les plans (Ch. 20)	IV
24	Qu'est-ce qu'une crise ? (Ch. 21)	V
25–26	La cellule de crise (Ch. 22)	V
27	Décider en crise (Ch. 23)	V
28	Communiquer en crise (Ch. 24)	V
29	Les exercices de crise (Ch. 25)	V
30	Retour d'expérience et mesure ; synthèse (Ch. 26)	VI

Les encadrés

Définition

Définition. Introduit un terme avec sa définition ; les termes définis sont indexés et repris dans le glossaire (Annexe A).

Scénario Opérationnel · Titre du scénario

Scénario opérationnel. Un épisode d'une des opérations du cours : GAROUA et LIZBIZ (LiZbiZ), WOURI (BANQUE SANAGA), MOUNGO (entrepôt de Bonabéri).

Fiche de risque · R-xx · Intitulé

Fiche de risque. Présente un risque sous une forme constante : scénario, cotation, traitement, propriétaire, indicateur de suivi.

Procédure de crise

Procédure de crise. Dit, pas à pas, ce qu'il faut faire.

Application Gestionnaire de risques

Application métier. Traduit le chapitre en gestes concrets pour l'un des métiers visés : gestionnaire de risques, auditeur des systèmes d'information, responsable de la continuité, directeur de crise, chargé de communication de crise.

Jurisprudence & Droit applicable

Cite un texte de loi d'après sa version officielle, puis en tire la portée pour la gestion des risques et des crises.

★ Attention

Violation typique et **règle** : une erreur fréquente, et ce qu'il faut faire à la place.

✍ Exercice

Exercice. Dix par chapitre, gradués en trois niveaux : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert. Les corrigés figurent dans le livret de correction.

Conventions

- Chaque analyse indique un niveau de confiance : faible, moyenne ou élevée, et reste séparée de la constatation.
- Chaque estimation chiffrée est donnée avec son intervalle ou ses hypothèses ; un chiffre seul n'est pas une estimation.
- Les **termes clés** apparaissent en gras ; les normes s'écrivent **[ISO 31000]**, les lois camerounaises **Loi n° 2010/012**.
- Les échelles, les seuils et les grilles proposés sont des conventions pédagogiques, à adapter par chaque organisation.

Matériel d'accompagnement

- **Annexes** : glossaire, outils, modèles et procédures, textes juridiques et normatifs, bibliographie commentée, contacts (Annexes A à F).
- **Livret de correction** : corrigés des exercices et des fiches, réservé au formateur.
- **NDAP SUKULU** : fiches d'auto-évaluation et laboratoires, présentés dans la section qui suit.

NDAP SUKULU, LA SALLE DE CLASSE COMPAGNON



Un nom venu du pays bassa

> *Le soir tombe sur Éséka. Un enfant revient des champs avec son grand-père et lui demande pourquoi il doit marcher si loin, chaque matin, pour aller à l'école. Le vieil homme s'arrête au bord du chemin et répond, en bassa : «* Ndap sukulu*, la salle de classe, ce ne sont pas les murs. Ce sont les murs qui viennent après. La salle de classe, c'est l'endroit où quelqu'un t'attend pour t'apprendre ce qu'il sait. » L'enfant insiste : « Et qui m'attend ? » Le grand-père sourit : «* Malet yon*. Ton enseignant. »*

En bassa, la langue paternelle de l'auteur, ***ndap sukulu*** désigne la salle de classe et ***malet yon*** signifie « ton enseignant ». L'environnement compagnon de ce cours porte ce nom parce qu'il prolonge la salle de classe au-delà des heures de cours : il attend l'étudiant le soir, le week-end, à distance, avec des questions, des pièces à examiner et une correction immédiate. Il est édité par **MaletYon**, « ton enseignant », et mis à la disposition des étudiants et des praticiens qui souhaitent se perfectionner (maletyon@proton.me).

Ce que l'on y trouve

- **Une fiche d'auto-évaluation par chapitre.** Chaque fiche puise vingt questions dans une banque de quarante (QCM, vrai ou faux, textes à trous). Elle dure trente minutes ; la copie validée est verrouillée et notée aussitôt. Le seuil de réussite est de 60 %.
- **Des laboratoires pratiques.** Chaque lab place l'étudiant devant les pièces d'une affaire du fil rouge (tableurs, journaux, contrats, procès-verbaux) dans un bureau d'analyste virtuel, ouvert dans le navigateur. Il dure soixante minutes, se termine par des points de contrôle notés automatiquement et renvoie aux sections du livre qu'il mobilise.

© MaletYon

➢ **Un suivi pour l'enseignant** : rapport de classe, notes par fiche et par lab, journal d'activité.

Les fiches et les labs sont des travaux à faire hors des heures de cours. Ils ne remplacent ni le livre ni les exercices de fin de chapitre : ils en vérifient la maîtrise.

Comment y travailler

1. Se connecter au portail NDAP SUKULU avec ses identifiants et le code de cours **GES4062**.
2. Pour un lab, commencer par vérifier l'empreinte SHA-256 des pièces (`sha256sum -c MANIFESTE_SHA256.txt`), puis travailler sur la copie du dossier `travail` : les pièces originales sont en lecture seule et l'activité est journalisée, comme dans une vraie mission.
3. Lire le rappel de cours affiché par le lab et relire les sections citées avant de répondre.

Note

Si le portail n'est pas encore ouvert. En attendant le déploiement de NDAP SUKULU, les fiches de questions sont fournies au format texte dans le dossier `fiches` du cours, prêtes à être distribuées. Les corrections des fiches figurent dans le livret de correction, à la suite des corrigés des exercices de chaque chapitre.

Les laboratoires du cours

Le cours compte dix laboratoires, disponibles sous le code GES4062. Les cinq premiers portent sur l'analyse des risques, les cinq suivants sur l'audit, les incidents, la continuité et la crise.

Lab	Sujet	Chapitre	Opération
ARGC-LAB-01	Matrice et registre des risques	7	LIZBIZ
ARGC-LAB-02	EBIOS RM : menace des parties prenantes	8	LIZBIZ
ARGC-LAB-03	FAIR : estimer la perte annuelle	9	GAROUA
ARGC-LAB-04	Monte-Carlo : lire une distribution de pertes	10	GAROUA
ARGC-LAB-05	Indicateurs de risque et tableau de bord	11	LIZBIZ
ARGC-LAB-06	Échantillonnage et constats d'audit	13	LIZBIZ
ARGC-LAB-07	Registre des incidents : classer et mesurer	16	GAROUA
ARGC-LAB-08	Analyse d'impact : RTO, RPO, dépendances	17	WOURI
ARGC-LAB-09	Main courante de la cellule de crise	22	GAROUA
ARGC-LAB-10	Communication de crise et retour d'expérience	24	MOUNGO

Les laboratoires du cours dans NDAP SUKULU

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi du cours v

NDAP SUKULU, la salle de classe compagnon ix

Prologue Opérationnel 3

0 Prologue : le Matin du 6 Mars 3

0.1 LiZbiZ avant la Crise . . . 4
0.2 La Journée du 6 Mars . . . 4
0.3 Les Jours Suivants . . . 6
0.4 Constatations, Suppositions, Opinions . . . 6
0.5 Les Questions du Cours . . . 7

I Fondements du Risque 11

1 Risque, Incertitude et Décision 13

1.1 Risque et Incertitude . . . 14
1.2 Probabilité et Conséquences . . . 14
1.3 La Perte Annuelle Attendue . . . 15
1.4 Juger une Décision . . . 15
1.5 Les Événements Rares . . . 16

2 Percevoir le Risque : Biais et Culture 21

2.1 Deux Manières de Penser . . . 22
2.2 Les Heuristiques . . . 22
2.3 La Perception du Risque . . . 23
2.4 Les Biais Collectifs . . . 23
2.5 La Culture du Risque . . . 24
2.6 Se Calibrer . . . 24

3 Gouvernance des Risques 27

3.1 Les Rôles . . . 28
3.2 Le Modèle des Trois Lignes . . . 28
3.3 Appétence et Tolérance . . . 29

© *MaletYon*

3.4 Le Comité des Risques . . . 30
3.5 Les Risques Externalisés . . . 30

4 Les Cadres de Management des Risques 33

4.1 L'ISO 31000 . . . 34
4.2 Le Processus de Management du Risque . . . 34
4.3 Le COSO ERM . . . 35
4.4 Les Techniques de l'IEC 31010 . . . 35
4.5 Les Cadres Propres à la Sécurité de l'Information . . . 36
4.6 Un Cadre pour LiZbiZ . . . 36

5 Obligations Juridiques et Responsabilités 41

5.1 Gérer les Risques : une Obligation Légale . . . 42
5.2 Conserver et Surveiller . . . 42
5.3 L'Audit de Sécurité . . . 43
5.4 Les Responsabilités en Jeu . . . 44
5.5 Les Décisions Juridiques d'une Crise . . . 44

II Analyser les Risques 49

6 Identifier les Risques 51

6.1 Formuler un Risque . . . 52
6.2 Partir des Objectifs et des Processus . . . 52
6.3 Les Techniques d'Identification . . . 53
6.4 Classer : les Taxonomies . . . 54
6.5 Les Signaux Faibles . . . 54

7 Estimer : Échelles et Matrices 59

7.1 Les Échelles . . . 60
7.2 Coter et Placer . . . 60
7.3 Matrice et Appétence . . . 61
7.4 Les Limites des Matrices . . . 61
7.5 Bien Utiliser une Matrice . . . 62

8 ISO/IEC 27005 et EBIOS Risk Manager 67

8.1 L'ISO/IEC 27005 . . . 68
8.2 EBIOS Risk Manager : Principes . . . 68
8.3 Ateliers 1 et 2 : Socle et Sources de Risque . . . 69
8.4 Atelier 3 : l'Écosystème . . . 69
8.5 Atelier 4 : les Scénarios Opérationnels . . . 70
8.6 Atelier 5 : le Traitement . . . 71

9 L'Analyse Quantitative : FAIR et Pertes Annuelles 75

9.1 La Taxonomie FAIR . . . 76
9.2 Estimer par Trois Points . . . 77
9.3 La Fréquence des Pertes . . . 77
9.4 L'Ampleur des Pertes . . . 77
9.5 La Perte Annuelle Attendue . . . 78
9.6 Comparer des Options . . . 78

10 Simuler : Monte-Carlo et Sensibilité 83

10.1 Le Principe . . . 84
10.2 Choisir les Lois . . . 84
10.3 Lire les Résultats . . . 85
10.4 La Courbe de Dépassement . . . 85
10.5 L'Analyse de Sensibilité . . . 86

11 Traiter, Suivre et Rendre Compte 89

11.1 Les Options de Traitement . . . 90
11.2 Le Plan de Traitement . . . 90
11.3 Arbitrer le Budget . . . 91
11.4 Les Indicateurs Clés de Risque . . . 92
11.5 Rendre Compte . . . 92

III Auditer le Dispositif 97

12 L'Audit selon l'ISO 19011 99

12.1 Les Types d'Audit . . . 100
12.2 Les Principes de l'Audit . . . 100
12.3 Le Programme d'Audit . . . 101
12.4 Les Rôles et les Compétences . . . 102
12.5 L'Audit d'un Système de Management de la Sécurité . . . 102

13 Conduire l'Audit : Preuves, Échantillons, Constats 105

13.1 Les Étapes d'un Audit . . . 106
13.2 Les Preuves . . . 106
13.3 Échantillonner . . . 107
13.4 Conclure sur la Population . . . 107
13.5 Rédiger un Constat . . . 108

14 Auditer la Gestion des Risques et le SMSI 111

14.1 Trois Niveaux d'Examen . . . 112
14.2 Rapprocher Incidents et Registre . . . 112

14.3 Tester Cotations et Mesures . . . 113
14.4 Auditer un Indicateur . . . 113
14.5 Les Clauses de l'ISO/IEC 27001 . . . 114

15 Le Rapport et le Suivi des Actions 117

15.1 La Structure du Rapport . . . 118
15.2 Hiérarchiser et Recommander . . . 118
15.3 La Réponse de l'Audité . . . 119
15.4 L'Action Corrective . . . 119
15.5 Suivre et Clore . . . 120

IV Incidents et Continuité 123

16 Gérer les Incidents de Sécurité 125

16.1 Événement, Incident, Crise . . . 126
16.2 Les Phases de l'ISO/IEC 27035 . . . 126
16.3 Classer et Escalader . . . 127
16.4 L'Équipe de Réponse . . . 127
16.5 Mesurer et Apprendre . . . 128

17 L'Analyse d'Impact sur l'Activité 131

17.1 L'Objet de l'Analyse d'Impact . . . 132
17.2 Mesurer l'Impact dans le Temps . . . 132
17.3 Les Objectifs de Reprise . . . 133
17.4 Les Dépendances . . . 133
17.5 L'Ordre de Reprise . . . 134

18 Stratégies et Plans de Continuité 137

18.1 Le Système de Management de la Continuité . . . 138
18.2 Les Stratégies par Ressource . . . 138
18.3 Le Mode Dégradé . . . 139
18.4 Le Plan de Continuité . . . 139
18.5 Les Trois Plans . . . 140

19 Reprise Informatique et Résilience 143

19.1 Protéger les Données selon les Objectifs . . . 144
19.2 Le Plan de Reprise Informatique . . . 144
19.3 Reprendre après un Rançongiciel . . . 145
19.4 La Résilience Opérationnelle . . . 145
19.5 Mesurer la Capacité Réelle . . . 146

20 Exercer et Tester les Plans **149**

20.1 Revue, Exercice, Test . . . 150
20.2 Le Programme d'Exercices . . . 150
20.3 Concevoir un Exercice . . . 151
20.4 Évaluer . . . 151
20.5 Tester sans Nuire . . . 152

V Gestion de Crise **155**

21 Qu'est-ce qu'une Crise ? **157**

21.1 Définir la Crise . . . 158
21.2 Les Caractéristiques d'une Crise . . . 158
21.3 Crises Soudaines, Crises Rampantes . . . 159
21.4 Les Phases d'une Crise . . . 159
21.5 Perdre le Sens de la Situation . . . 160

22 La Cellule de Crise **163**

22.1 Deux Niveaux . . . 164
22.2 Les Rôles . . . 165
22.3 La Main Courante . . . 165
22.4 Le Rythme de la Crise . . . 166
22.5 La Première Heure . . . 166
22.6 Salle, Annuaire, Relèves, Fin . . . 167

23 Décider en Situation de Crise **171**

23.1 Comment Décident les Experts . . . 172
23.2 Les Biais de la Crise . . . 172
23.3 Réversible ou Irréversible . . . 173
23.4 Structurer une Décision . . . 173
23.5 Décider à Froid ce qui se Décidera à Chaud . . . 174

24 Communiquer en Crise **177**

24.1 Les Principes . . . 178
24.2 Les Parties Prenantes . . . 178
24.3 La Théorie de Coombs . . . 179
24.4 Les Messages . . . 179
24.5 Porte-Parole et Réseaux Sociaux . . . 180

25 Les Exercices de Crise **185**

25.1 Ce qu'Entraîne un Exercice de Crise . . . 186
25.2 Le Scénario et les Injections . . . 186

25.3 Animer et Observer 187
25.4 Débriefer 187
25.5 Mesurer la Progression 188

VI Apprendre et Mesurer 191

26 Retour d'Expérience, Résilience et Mesure 193

26.1 Le Retour d'Expérience 194
26.2 Remonter aux Causes 194
26.3 Suivre jusqu'à l'Effet 195
26.4 Mesurer la Résilience 195
26.5 La Précision de la Mesure 196
26.6 Synthèse du Cours 197

A Glossaire 201

B Référentiel des Outils 205

C Modèles et Procédures 207

D Textes Juridiques et Normatifs 209

E Bibliographie Commentée 211

F Contacts et Ressources 213

Références bibliographiques 215

TABLE DES FIGURES

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

Prologue Opérationnel

© *MaletYon*

0

PROLOGUE : LE MATIN DU 6 MARS

« Le plan n'est rien ; la planification est tout. »

Formule attribuée à Dwight D. Eisenhower

Niveau : *Fondamental* • Aucun ; le cours SEC3266 (Sécurité informatique) éclaire les causes techniques.

✦ Objectifs du chapitre

- ➢ Lire le déroulement d'une crise réelle du point de vue de la direction.
- ➢ Séparer ce qui a été constaté de ce qui a été supposé, et des opinions exprimées.
- ➢ Repérer, dans une crise, ce qui relevait du risque, de l'audit, de la continuité et de la décision.
- ➢ Formuler les questions auxquelles le cours répond.

Question directrice : qui décide, quand rien n'a été prévu ?

Le vendredi 6 mars 2026, à 7 h 30, le responsable informatique de LiZbiZ découvre que les serveurs de Douala et de Garoua sont chiffrés. Trois heures plus tard, une cellule de crise improvisée se réunit dans le bureau du directeur général. Personne n'a de liste des clients à prévenir, ni de numéro de l'assureur, ni d'idée du temps qu'il faudra pour facturer à nouveau. Ce prologue raconte cette journée et les suivantes, sans les juger ; les chapitres qui suivent donnent les outils pour les juger.

Plan du chapitre.

1. LiZbiZ avant la crise (section 0.1).
2. La journée du 6 mars (section 0.2).
3. Les jours suivants (section 0.3).
4. Constatations, suppositions, opinions (section 0.4).
5. Les questions du cours (section 0.5).

© *MaletYon*

0.1 LiZbiZ avant la Crise

LiZbiZ[1] est une société anonyme de logistique dont le siège est à Douala. Elle emploie 150 salariés et réalise un chiffre d'affaires d'environ 24 milliards de FCFA par an, soit quelque 80 millions de FCFA par jour ouvré. Elle exploite quatre centres de données, à Douala, Yaoundé, Garoua et Bafoussam, et a confié en septembre 2025 l'exploitation de Garoua et de Douala au prestataire SAHEL INFOGÉRANCE.

Acteur	Rôle pendant la crise
M. ETEME	Directeur général ; préside la cellule de crise
Mme MBALLA	Directrice administrative et financière ; trésorerie, assurance, clients
M. KOUNOU	Responsable informatique ; découvre l'attaque, pilote la reprise
Mme NKENG	Contrôleuse interne ; tient la main courante à partir du 7 mars
M. NGUELE	Directeur des opérations ; expéditions, agences, mode dégradé
Mme ABOMO	Chargée de communication ; clients, presse, personnel
M. NANGA	Chef d'agence de Garoua
Me TSALA	Avocat de la société ; plainte, rançon, données personnelles

Tableau 0.1. Les acteurs de l'Opération GAROUA

Constatation. En février 2026, LiZbiZ n'a ni registre des risques, ni plan de continuité, ni plan de gestion de crise. Le dernier audit de sécurité date de 2023 et ne couvrait pas le prestataire. Le contrat avec SAHEL INFOGÉRANCE ne mentionne ni délai de notification d'un incident, ni obligation de second facteur.

0.2 La Journée du 6 Mars

La chronologie ci-dessous a été reconstituée par Mme NKENG à partir des messages, des appels et des souvenirs des participants ; aucune main courante n'a été tenue avant le 7 mars.

[1] LiZbiZ, ses dirigeants, ses clients et ses prestataires sont fictifs, comme les dates, les montants et les adresses du cours ; les méthodes et les normes citées sont réelles.

Heure	Événement
07 h 30	M. KOUNOU constate que les serveurs de Douala et de Garoua sont chiffrés ; un message de rançon réclame 85 000 dollars en cryptoactifs.
07 h 45	Il appelle M. ETEME, qui est en route pour Yaoundé.
08 h 40	M. NGUELE apprend par un client que le portail de suivi ne répond plus.
09 h 05	Les liaisons entre les sites sont toujours ouvertes ; personne n'a autorité pour les couper sans le directeur général.
10 h 30	Réunion dans le bureau du DG, par téléphone pour M. ETEME : huit personnes, aucun ordre du jour, aucun compte rendu.
11 h 10	Décision de couper les liaisons entre les sites. Yaoundé et Bafoussam sont épargnés.
13 h 00	Mme MBALLA cherche le contrat d'assurance : la police ne couvre pas les cyberattaques.
15 h 30	Les agents des agences reçoivent la consigne orale de noter les expéditions sur papier.
18 h 30	Une photographie du message de rançon, prise par un salarié, circule sur les réseaux sociaux.
20 h 00	Un journaliste appelle le standard ; personne n'est désigné pour répondre.

Tableau 0.2. La journée du 6 mars, reconstituée

Scénario Opérationnel · Opération GAROUA. Trois heures et quarante minutes

Constatation. Entre la découverte (7 h 30) et la coupure des liaisons (11 h 10), 3 h 40 se sont écoulées. Pendant ce temps, aucune action de confinement n'a été prise, faute de personne autorisée à la décider.

Analyse (confiance moyenne). Les serveurs de Yaoundé et de Bafoussam n'ont pas été touchés ; il n'est donc pas établi que le délai ait aggravé les dommages. Il est établi, en revanche, que l'organisation ne savait pas qui pouvait décider : c'est le premier défaut de gestion de crise (Chapitre 22).

0.3 Les Jours Suivants

Date	Événement
7 mars	Première réunion avec main courante ; communiqué aux clients à 9 h ; plainte déposée auprès de la police judiciaire à Douala.
8 mars	Après avis de Me TSALA, M. ETEME décide de ne pas payer la rançon.
9 mars	Les mots de passe d'administration sont changés.
12 mars	Premier comité de sécurité : registre des risques établi après coup.
16 mars	Reprise de la facturation, onze jours après l'attaque.
19 mars	L'attaquant publie sur son site un échantillon de 2 Go de données clients ; seconde vague d'appels.
2 avril	Réunion de retour d'expérience, avec la direction et SAHEL INFOGÉRANCE.

Tableau 0.3. Les jours suivants

Le 2 avril, Mme MBALLA présente une première estimation des coûts de la crise.

Poste	Millions de FCFA
Remise en état (prestataires, matériel, licences)	96
Ressaisie de six semaines de factures	18
Pénalités contractuelles versées aux clients	74
Clients perdus (marge annuelle estimée)	110
Conseil juridique et communication	14
Total	**312**

Tableau 0.4. Les coûts de l'Opération GAROUA (estimation du 2 avril)

★ Attention

Violation typique. Présenter « 312 millions » comme un fait.

Règle : trois postes sont constatés (remise en état, ressaisie, pénalités, soit 188 millions) ; deux sont estimés (clients perdus, conseil). Une estimation se présente avec ses hypothèses et sa marge (Chapitre 9).

0.4 Constatations, Suppositions, Opinions

Au retour d'expérience du 2 avril, chacun a sa lecture de la crise. Le cours demande de séparer trois registres.

Registre	Exemples entendus le 2 avril
Constatation	« Les liaisons ont été coupées à 11 h 10 » ; « la police d'assurance exclut les cyberattaques »
Supposition	« Si l'on avait coupé à 8 h, rien n'aurait changé » ; « les clients perdus le sont à cause de la photo »
Opinion	« Le prestataire est incompétent » ; « on a bien géré, vu les circonstances »

Tableau 0.5. Trois registres

Application Directeur de crise

Faire tenir la main courante dès la première minute. Le directeur de crise désigne, avant toute décision, une personne qui consigne l'heure, le fait, la source et la décision. Sans elle, la crise se raconte après coup, de mémoire.

Application Chargé de communication de crise

Parler avant les réseaux sociaux. Un message bref et exact, publié tôt, vaut mieux qu'un communiqué complet publié après la rumeur. À 18 h 30, la rumeur a parlé la première.

0.5 Les Questions du Cours

Partie	Question posée par la crise	Chapitres
I. Fondements	Pourquoi personne n'avait-il jugé ce risque prioritaire ?	1 à 5
II. Analyser	Quelle perte fallait-il craindre, et avec quelle probabilité ?	6 à 11
III. Auditer	Un audit aurait-il vu le compte sans second facteur ?	12 à 15
IV. Continuer	Pourquoi onze jours pour facturer ?	16 à 20
V. Crise	Qui devait décider à 7 h 45, et que fallait-il dire ?	21 à 25
VI. Apprendre	Qu'a-t-on appris, et comment le mesurer ?	26

Tableau 0.6. Les questions du cours

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **La crise de LiZbiZ** n'a pas commencé le 6 mars : elle tenait à l'absence de registre, de plan et d'audit.
- **Le premier défaut** du 6 mars fut de ne pas savoir qui décidait : 3 h 40 sans confinement.
- **Sans main courante**, une crise se reconstitue de mémoire.
- **Les coûts** mêlent constatations et estimations ; il faut les distinguer.
- **Constatation, supposition, opinion** : trois registres à ne jamais confondre.

● Note

Points de contrôle de l'élève. Je sais : retracer la chronologie du 6 mars ; nommer les acteurs et leur rôle ; distinguer les coûts constatés des coûts estimés ; classer une affirmation en constatation, supposition ou opinion ; relier chaque défaut à une partie du cours.

✍ **Exercice 0.1. Le délai** ★☆☆

Calculez le délai entre la découverte de l'attaque et la décision de couper les liaisons, puis entre la découverte et le premier communiqué aux clients.

✍ **Exercice 0.2. Les registres** ★☆☆

Classez en constatation, supposition ou opinion : « la rançon aurait été payée sans Me TSALA » ; « la facturation a repris le 16 mars » ; « SAHEL INFOGÉRANCE aurait dû prévenir » ; « le portail ne répondait plus à 8 h 40 ».

✍ **Exercice 0.3. Les coûts** ★☆☆

Dans le Tableau 0.4, quelle part du total est constatée, et quelle part est estimée ? Donnez les montants et les pourcentages.

✍ **Exercice 0.4. Les absents** ★★☆

Quelles fonctions manquaient à la réunion de 10 h 30 pour décider vite ? Quelles informations auraient dû être disponibles à l'ouverture de la réunion ?

✍ **Exercice 0.5. Le message** ★★☆

Rédigez le message de trois phrases que LiZbiZ aurait pu publier à 19 h le 6 mars, après la diffusion de la photographie.

✍ Exercice 0.6. L'assurance ★★☆

La police d'assurance excluait les cyberattaques. Quelle étape de la gestion des risques aurait dû le révéler, et à quel moment ?

✍ Exercice 0.7. La rançon ★★☆

Listez les éléments que la cellule de crise devait réunir avant de décider de payer ou non la rançon.

✍ Exercice 0.8. La seconde vague ★★☆

Le 19 mars, un échantillon de données est publié. Quelles parties prenantes faut-il informer, et dans quel ordre ?

✍ Exercice 0.9. La chronologie idéale ★★★

Réécrivez la journée du 6 mars, de 7 h 30 à 20 h, telle qu'elle aurait dû se dérouler avec une cellule de crise préparée.

✍ Exercice 0.10. Le programme ★★★

À partir du Tableau 0.6, proposez à M. ETEME un programme de six mois pour que la prochaine crise soit mieux gérée : actions, responsables, échéances.

● Note

Pour aller plus loin.

- P. Lagadec, *La gestion des crises* [28].
- ISO 22361, lignes directrices pour la gestion de crise [15].

● Note

Transition. Avant de gérer une crise, il faut savoir ce qu'est un risque. Le Chapitre 1 distingue risque et incertitude, et montre ce qu'est une bonne décision sous incertitude.

partie I

Fondements du Risque

© *MaletYon*

1

RISQUE, INCERTITUDE ET DÉCISION

« Une bonne décision peut mal tourner,
et une mauvaise décision peut bien tourner. »

Principe du cours

Niveau : *Fondamental* • Prologue ; notions de probabilité.

✦ Objectifs du chapitre

- ➢ Définir le risque selon l'ISO 31000 et le distinguer de l'incertitude au sens de Knight.
- ➢ Décrire un risque par une distribution de conséquences, et non par un seul chiffre.
- ➢ Calculer et interpréter une perte annuelle attendue.
- ➢ Juger une décision sur l'information disponible, et non sur son résultat.
- ➢ Reconnaître les limites de la prévision face aux événements rares.

Question directrice : le risque de rançongiciel était-il connu en février ?

En février 2026, M. KOUNOU avait proposé d'exiger un second facteur sur la passerelle d'accès distant, pour 6 millions de FCFA par an. La dépense avait été reportée : « nous n'avons jamais été attaqués ». Le risque était-il connu ? Pouvait-on le chiffrer ? Et la décision de reporter était-elle mauvaise, ou seulement malchanceuse ?

Plan du chapitre.

1. Risque et incertitude (section 1.1).
2. Probabilité et conséquences (section 1.2).
3. La perte annuelle attendue (section 1.3).
4. Juger une décision (section 1.4).
5. Les événements rares (section 1.5).

© *MaletYon*

1.1 Risque et Incertitude

Définition

Risque (ISO 31000) : effet de l'incertitude sur les objectifs. Un effet est un écart par rapport à ce qui est attendu ; il peut être positif ou négatif. Le risque s'exprime souvent par des sources de risque, des événements, leurs conséquences et leur vraisemblance.

La définition de l'[ISO 31000] et du [Guide ISO 73] rattache le risque aux *objectifs* : sans objectif, pas de risque. Pour LiZbiZ, l'objectif « facturer chaque jour ouvré » donne son sens au risque « arrêt de la facturation » [8], [16].

En 1921, l'économiste Frank Knight distingue le **risque**, dont on connaît la distribution des issues, et l'**incertitude**, dont on ne la connaît pas [27]. Le lancer d'un dé relève du risque ; la date de la prochaine attaque contre LiZbiZ relève, en grande partie, de l'incertitude. Le travail du gestionnaire de risques consiste à faire passer ce qui peut l'être de l'incertitude au risque, par l'observation, les données et le jugement d'experts, et à reconnaître ce qui n'y passera pas.

Situation	Ce que l'on sait	Exemple chez LiZbiZ
Risque	Les issues et leurs probabilités	Pannes de disques, connues par les statistiques du fabricant
Incertitude mesurable	Les issues, et une estimation des probabilités	Hameçonnage, estimé par les signalements et les études publiées
Incertitude profonde	Ni la liste des issues, ni leurs probabilités	Une rupture technologique, une crise politique régionale

Tableau 1.1. Du risque à l'incertitude profonde

1.2 Probabilité et Conséquences

Un risque ne se résume pas à un nombre. Il se décrit par la **distribution des conséquences** : pour chaque perte possible, la probabilité qu'elle survienne sur une période. Deux risques de même perte moyenne peuvent être très différents.

	Risque A : pannes fréquentes	Risque B : rançongiciel
Fréquence annuelle	10 pannes	0,25 événement
Perte par événement	3 millions de FCFA	120 millions de FCFA
Perte annuelle moyenne	30 millions	30 millions
Pire année plausible	45 millions	300 millions ou plus

Tableau 1.2. Même moyenne, deux risques différents

Analyse. Les deux risques coûtent 30 millions par an en moyenne, mais le risque B peut, une année donnée, menacer la trésorerie. Une entreprise peut absorber A dans son budget ; elle doit transférer ou réduire B. C'est la *queue* de la distribution, et non sa moyenne, qui décide.

1.3 La Perte Annuelle Attendue

Définition

Perte annuelle attendue : espérance de la perte sur un an, égale, pour un scénario simple, au produit de la fréquence annuelle et de la perte moyenne par événement. Elle sert à comparer des options, non à prévoir une année particulière.

Scénario Opérationnel · Opération GAROUA. La décision de février

Hypothèses (établies après coup, confiance faible à moyenne) : fréquence annuelle d'un rançongiciel réussi sans second facteur, 0,25 ; avec second facteur, 0,05 ; perte par événement, 300 millions de FCFA (Tableau 0.4) ; coût du second facteur, 6 millions par an.

Calcul. Sans second facteur : $0{,}25 \times 300 = 75$ millions par an. Avec : $0{,}05 \times 300 + 6 = 21$ millions par an.

Analyse (confiance moyenne). Même si les fréquences sont incertaines, l'écart est si grand que la décision ne change pas tant que la fréquence sans second facteur dépasse $6/300 + 0{,}05 = 0{,}07$ par an. Reporter la dépense n'était pas justifié par les chiffres ; il était justifié par l'absence de chiffres.

Ce raisonnement est un **seuil de rentabilité** : au lieu de chercher la « vraie » fréquence, on cherche la fréquence à partir de laquelle la décision bascule, puis on se demande si l'on y croit. C'est souvent plus facile que d'estimer la fréquence elle-même.

1.4 Juger une Décision

Une décision se juge sur l'information disponible au moment de la prendre, et non sur son résultat. Si LiZbiZ avait installé le second facteur et avait été attaqué par une autre

voie, la décision aurait été bonne et le résultat mauvais. À l'inverse, reporter la dépense et ne pas être attaqué aurait été une mauvaise décision au résultat favorable.

	Résultat favorable	Résultat défavorable
Bonne décision	Mérité	Malchance
Mauvaise décision	Chance	Conséquence prévisible

Tableau 1.3. Décision et résultat

★ Attention

Violation typique. Juger une décision à son résultat (« on n'a jamais été attaqués, donc on avait raison »).

Règle : documenter, au moment de décider, les options, les hypothèses et l'information disponible. Le retour d'expérience juge ensuite la qualité de ce dossier, et non la chance (Chapitre 26).

Trois critères éclairent une décision sous incertitude : la perte attendue (ce que l'on perd en moyenne), la perte dans un scénario sévère (ce que l'on ne peut pas se permettre) et la **valeur de l'information** (ce que coûterait d'en savoir plus avant de décider). Un dirigeant averse au risque peut préférer une option plus chère en moyenne si elle supprime le scénario qui le ruinerait.

1.5 Les Événements Rares

Certains événements sont si rares qu'aucune statistique ne permet de les estimer, et leurs conséquences si grandes qu'ils dominent toutes les autres. Nassim Taleb les appelle des « cygnes noirs » : rares, d'impact extrême, et expliqués après coup comme s'ils avaient été prévisibles [38]. Charles Perrow avait montré, dès 1984, que dans les systèmes complexes et étroitement couplés, des défaillances mineures peuvent se combiner en accident majeur : il les nommait « accidents normaux » [34].

● Note

Ce que l'on peut faire face à l'imprévisible. On ne prévoit pas l'événement, mais on réduit la fragilité : couplages moins étroits (segmentation, liaisons coupables entre sites), marges (trésorerie, stocks), capacité de réaction (cellule de crise entraînée). C'est l'objet des Parties IV et V.

Fiche de risque · R-01 · Arrêt de la facturation

Scénario : un incident informatique arrête la facturation plus de deux jours ouvrés. **Cotation :** fréquence estimée de 0,3 par an, perte par événement de 40 à 300 millions de FCFA. **Traitement :** réduire (second facteur, sauvegardes hors ligne) et transférer (assurance cyber). **Propriétaire :** Mme MBALLA. **Indicateur :**

durée du dernier test de restauration de la facturation.

Application Gestionnaire de risques

Chiffrer le seuil, pas seulement le risque. Quand la fréquence est incertaine, le gestionnaire présente à la direction la fréquence à partir de laquelle l'investissement se justifie, et les raisons de croire qu'elle est dépassée.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le risque** est l'effet de l'incertitude sur les objectifs (ISO 31000) ; Knight distingue risque et incertitude.
- **Un risque** se décrit par une distribution ; la queue compte autant que la moyenne.
- **La perte annuelle attendue** compare des options ; le seuil de rentabilité évite d'estimer ce qu'on ne sait pas.
- **Une décision** se juge sur l'information disponible, pas sur son résultat.
- **Face aux événements rares**, on réduit la fragilité.

● Note

Points de contrôle de l'élève. Je sais : définir le risque selon l'ISO 31000 ; distinguer risque et incertitude ; comparer deux risques de même moyenne ; calculer une perte annuelle attendue et un seuil de rentabilité ; distinguer bonne décision et bon résultat.

✍ Exercice 1.1. Définir ★☆☆

Donnez, pour LiZbiZ, un objectif, un risque qui s'y rattache, sa source, l'événement redouté et sa conséquence.

✍ Exercice 1.2. Knight ★☆☆

Classez en risque, incertitude mesurable ou incertitude profonde : la panne d'un onduleur ; une fraude au virement ; une nouvelle loi sur les données ; une inondation à Bonabéri.

✍ Exercice 1.3. Calculer ★☆☆

Une fraude au virement survient en moyenne une fois tous les quatre ans pour une perte de 60 millions de FCFA. Quelle est la perte annuelle attendue ?

✍ Exercice 1.4. Le seuil ★★☆

Une double validation des virements coûte 4 millions par an et divise la fréquence par quatre. À partir de quelle fréquence initiale est-elle rentable, pour une perte de 60 millions par événement ?

✍ Exercice 1.5. La queue ★★☆

Expliquez à Mme MBALLA pourquoi le risque B du Tableau 1.2 justifie une assurance, alors que le risque A n'en justifie pas.

✍ Exercice 1.6. Décision ou chance ★★☆

Classez dans le Tableau 1.3 : LiZbiZ installe le second facteur et n'est pas attaquée ; elle reporte la dépense et est attaquée ; elle reporte et n'est pas attaquée.

✍ Exercice 1.7. Le dossier ★★☆

Rédigez la note de décision que M. KOUNOU aurait dû remettre en février : options, hypothèses, chiffres, recommandation.

✍ Exercice 1.8. Couplage ★★☆

En quoi les liaisons ouvertes entre les sites de LiZbiZ illustrent-elles le couplage étroit au sens de Perrow ?

✍ Exercice 1.9. Sensibilité ★★★

Refaites le calcul de la décision de février avec une perte par événement de 120 millions au lieu de 300. La conclusion change-t-elle ? Pour quelle perte bascule-t-elle ?

✍ Exercice 1.10. Fragilité ★★★

Proposez cinq mesures qui réduisent la fragilité de LiZbiZ face à un événement que l'on ne sait pas prévoir. Pour chacune, dites quel couplage ou quelle marge elle crée.

● Note

Pour aller plus loin.

- ISO 31000 [16] ; Guide ISO 73 [8].
- F. Knight, *Risk, Uncertainty and Profit* [27].
- C. Perrow, *Normal Accidents* [34].

Note

Transition. Les chiffres ne suffisent pas : les personnes perçoivent les risques à travers des biais. Le Chapitre 2 les présente.

2

PERCEVOIR LE RISQUE : BIAIS ET CULTURE

« Ce qui nous attire des ennuis, ce n'est pas ce que nous ignorons, c'est ce que nous tenons pour certain et qui ne l'est pas. »

Formule d'usage dans la gestion des risques

Niveau : *Fondamental* • Chapitre 1.

✦ Objectifs du chapitre

- ➢ Reconnaître les heuristiques de disponibilité, de représentativité et d'ancrage dans un jugement sur le risque.
- ➢ Expliquer pourquoi le public et les experts ne hiérarchisent pas les risques de la même manière.
- ➢ Identifier les biais collectifs : pensée de groupe, normalisation de la déviance.
- ➢ Décrire une culture juste et son rôle dans la remontée des signaux.
- ➢ Calibrer ses propres estimations par des intervalles.

Question directrice : pourquoi « nous n'avons jamais été attaqués » a-t-il convaincu ?

En février, l'argument a suffi à reporter le second facteur. En avril, après l'attaque, le comité de direction a voté sans débat un budget de sécurité quatre fois supérieur à celui de l'année précédente. Dans les deux cas, la décision a suivi la mémoire récente plus que l'analyse. Ce chapitre explique pourquoi, et comment s'en protéger.

Plan du chapitre.

1. Deux manières de penser (section 2.1).
2. Les heuristiques (section 2.2).
3. La perception du risque (section 2.3).
4. Les biais collectifs (section 2.4).

© MaletYon

5. La culture du risque (section 2.5).
6. Se calibrer (section 2.6).

2.1 Deux Manières de Penser

Daniel Kahneman décrit deux modes de pensée : un mode rapide, intuitif, automatique, et un mode lent, délibéré, coûteux en effort [25]. Le premier nous permet de réagir vite ; il répond souvent à une question plus facile que celle qui est posée. À la question « quelle est la probabilité d'une attaque cette année ? », il répond « me souviens-je d'une attaque récente ? ».

Définition

Heuristique : règle de jugement simple, le plus souvent inconsciente, qui donne vite une réponse acceptable, mais produit des erreurs systématiques, les **biais**.

2.2 Les Heuristiques

Amos Tversky et Daniel Kahneman ont décrit en 1974 trois heuristiques du jugement sous incertitude [40].

Heuristique	Principe	Chez LiZbiZ
Disponibilité	On juge probable ce dont on se souvient facilement	« Jamais attaqués » en février ; « tout est menacé » en avril
Représentativité	On juge sur la ressemblance avec un stéréotype, en négligeant la fréquence de base	« Un rançongiciel vise les banques, pas la logistique »
Ancrage	Une valeur initiale, même arbitraire, tire l'estimation	Le budget de l'an passé sert de point de départ au suivant

Tableau 2.1. Les trois heuristiques de Tversky et Kahneman

Attention

Violation typique. Estimer une fréquence d'attaque par sa propre expérience (« jamais vu ici »).

Règle : partir d'une *fréquence de base* externe (études publiées, données du secteur, signalements du centre de réponse national), puis l'ajuster par ce qui distingue l'organisation. L'absence d'attaque constatée peut aussi signifier une absence de détection.

S'y ajoutent l'**excès d'optimisme** (croire que les malheurs arrivent aux autres), le **biais de normalité** (penser qu'une situation inhabituelle va revenir d'elle-même à la normale, comme le technicien qui redémarre les serveurs le 5 mars au soir) et le **biais rétrospectif** (juger après coup qu'un événement était évident).

2.3 La Perception du Risque

Paul Slovic a montré que le public ne classe pas les risques selon leur fréquence de décès, mais selon deux dimensions : le caractère *redouté* (catastrophique, involontaire, incontrôlable) et le caractère *inconnu* (nouveau, invisible, aux effets différés) [36]. Un risque rare mais redouté et inconnu (une cyberattaque massive) mobilise plus qu'un risque fréquent et familier (les pannes).

Scénario Opérationnel · Opération GAROUA. Deux budgets

Constatation. Budget de sécurité de 2025 : 45 millions de FCFA ; budget voté en avril 2026 : 180 millions, sans analyse des risques préalable.

Analyse (confiance moyenne). Le premier budget était ancré sur l'historique et l'absence d'incident ; le second, sur l'effroi d'une crise récente. Ni l'un ni l'autre n'a été dérivé d'une analyse. Le risque est que les 180 millions financent des mesures visibles plutôt que les plus efficaces : le registre du Chapitre 11 doit les réaffecter.

2.4 Les Biais Collectifs

Les groupes ne corrigent pas toujours les biais individuels ; ils peuvent les amplifier.

Biais	Description et parade
Pensée de groupe	Un groupe soudé recherche l'unanimité au détriment de l'examen des options (Janis). Parade : désigner un contradicteur, recueillir les avis par écrit avant la discussion [23]
Normalisation de la déviance	Un écart toléré sans conséquence devient la norme (Vaughan, à propos de Challenger). Parade : tracer les dérogations et les revoir [41]
Effet d'autorité	L'avis du plus haut placé clôt le débat. Parade : faire parler le plus haut placé en dernier

Tableau 2.2. Trois biais collectifs

Exemple. Le compte partagé du prestataire sans second facteur était connu depuis septembre ; il avait été accepté « provisoirement », puis plus personne n'en parlait. C'est une normalisation de la déviance : une exception devenue habitude.

2.5 La Culture du Risque

James Reason décrit une **culture juste** : une organisation où l'on signale les erreurs et les quasi-accidents sans crainte de sanction injuste, tout en sanctionnant les comportements délibérément dangereux ; elle conditionne la remontée des signaux faibles [35].

Application Gestionnaire de risques

Rendre le signalement facile et utile. Le gestionnaire ouvre un canal simple pour signaler un quasi-incident, répond à chaque signalement, et publie ce qui a changé grâce aux signalements. Un salarié qui ne voit jamais d'effet cesse de signaler.

2.6 Se Calibrer

Douglas Hubbard et Richard Seiersen montrent qu'un expert peut apprendre à donner des estimations **calibrées** : des intervalles à 90 % qui contiennent la vraie valeur environ neuf fois sur dix [9]. Sans entraînement, la plupart des personnes donnent des intervalles trop étroits : elles sont trop sûres d'elles.

Procédure de crise

Estimer par un intervalle calibré

1. Donner une borne basse et une borne haute telles que l'on soit sûr à 90 % que la valeur est entre les deux.
2. Se demander : « parierais-je autant sur mon intervalle que sur une roue qui gagne neuf fois sur dix ? » Élargir si la roue semble préférable.
3. Chercher une raison pour laquelle la valeur serait hors de l'intervalle, de chaque côté.
4. Après coup, compter combien d'intervalles contenaient la valeur, et corriger sa largeur.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le jugement rapide** substitue une question facile à la question posée.
- **Disponibilité, représentativité, ancrage** faussent l'estimation ; on part d'une fréquence de base.
- **Le public** juge sur l'effroi et l'inconnu ; l'expert doit le savoir pour communiquer.
- **Les groupes** amplifient les biais ; contradicteur et avis écrits les limitent.
- **Une culture juste** fait remonter les signaux ; **l'intervalle calibré** rend l'estimation honnête.

Note

Points de contrôle de l'élève. Je sais : nommer et reconnaître trois heuristiques ; expliquer les dimensions de Slovic ; décrire la pensée de groupe et la normalisation de la déviance ; définir une culture juste ; donner un intervalle calibré.

✍ Exercice 2.1. Quelle heuristique ? ★☆☆

Nommez l'heuristique : « depuis l'attaque d'une banque voisine, je trouve les rançongiciels très probables » ; « le budget de cette année sera celui de l'an dernier plus 10 % ».

✍ Exercice 2.2. Fréquence de base ★☆☆

Pourquoi l'absence d'attaque constatée chez LiZbiZ avant mars ne prouve-t-elle pas l'absence d'attaque ?

✍ Exercice 2.3. Biais de normalité ★☆☆

En quoi le redémarrage des serveurs le 5 mars à 22 h 05 illustre-t-il le biais de normalité ?

✍ Exercice 2.4. Slovic ★★☆

Placez sur les deux axes de Slovic : une panne d'électricité ; une fuite de données personnelles ; une inondation d'entrepôt ; une fraude interne.

✍ Exercice 2.5. Le comité ★★☆

Proposez trois règles de fonctionnement du comité des risques de LiZbiZ pour limiter la pensée de groupe et l'effet d'autorité.

✍ Exercice 2.6. Dérogations ★★☆

Concevez un registre des dérogations qui empêche la normalisation de la déviance : colonnes, propriétaire, durée, revue.

✍ Exercice 2.7. Culture juste ★★☆

Un agent a cliqué sur un lien d'hameçonnage et l'a signalé aussitôt. Comment la direction doit-elle réagir dans une culture juste ? Et s'il l'avait caché ?

✍ Exercice 2.8. Calibrer ★★☆

Donnez un intervalle à 90 % pour : la population de Douala ; l'année de publication de l'ISO 31000 (première édition) ; la distance Douala-Garoua par la route. Vérifiez ensuite.

✍ Exercice 2.9. Le budget d'avril ★★★

Proposez à M. ETEME une méthode en quatre étapes pour affecter les 180 millions de FCFA sans céder à l'effroi.

✍ Exercice 2.10. Un atelier ★★★

Concevez un atelier d'une heure pour calibrer les dix experts qui estimeront les risques de LiZbiZ : questions, déroulé, mesure du résultat.

Note

Pour aller plus loin.

- A. Tversky et D. Kahneman [40] ; D. Kahneman [25].
- P. Slovic [36] ; J. Reason [35].
- D. Hubbard et R. Seiersen [9].

Note

Transition. Pour que les décisions sur les risques ne dépendent pas de l'humeur du moment, il faut des rôles et des règles. Le Chapitre 3 présente la gouvernance des risques.

3

GOUVERNANCE DES RISQUES

« Un risque sans propriétaire
est un risque que personne ne traite. »

Principe du cours

Niveau : *Fondamental* • Chapitres 1 et 2.

✦ Objectifs du chapitre

- ➢ Répartir les responsabilités entre conseil, direction, propriétaires de risques, fonction risques et audit interne.
- ➢ Appliquer le modèle des trois lignes de l'IIA.
- ➢ Formuler une appétence et des tolérances au risque.
- ➢ Définir le rôle et la composition d'un comité des risques.
- ➢ Maîtriser les risques d'une activité externalisée.

Question directrice : qui, chez LiZbiZ, répondait du risque du prestataire ?

Le contrat avec SAHEL INFOGÉRANCE avait été signé par la direction des opérations, négocié par la direction financière, et suivi par l'informatique. Chacun pensait que l'un des deux autres veillait à la sécurité. Personne n'en était chargé par écrit. Ce chapitre montre comment attribuer chaque risque à quelqu'un, et vérifier qu'il s'en occupe.

Plan du chapitre.

1. Les rôles (section 3.1).
2. Le modèle des trois lignes (section 3.2).
3. Appétence et tolérance (section 3.3).
4. Le comité des risques (section 3.4).
5. Les risques externalisés (section 3.5).

© *MaletYon*

3.1 Les Rôles

Définition

Gouvernance des risques : ensemble des rôles, des règles et des instances par lesquels une organisation fixe le niveau de risque qu'elle accepte, attribue chaque risque à un responsable et vérifie que les risques sont traités.

Acteur	Rôle
Conseil d'administration	Fixe l'appétence au risque, approuve la politique, reçoit le compte rendu des risques majeurs
Direction générale	Met en œuvre la politique, arbitre les ressources, répond devant le conseil
Propriétaire de risque	Responsable de l'activité exposée ; décide du traitement de son risque et en rend compte
Fonction risques	Fournit la méthode, consolide le registre, alerte, conseille ; ne possède pas les risques
Audit interne	Donne au conseil une assurance indépendante sur le dispositif

Tableau 3.1. Les rôles de la gouvernance des risques

Attention

Violation typique. Faire de la fonction risques (ou du service informatique) le propriétaire de tous les risques.

Règle : le propriétaire d'un risque est celui qui a l'autorité et le budget pour le traiter, c'est-à-dire le responsable de l'activité exposée. La fonction risques l'aide, elle ne le remplace pas.

3.2 Le Modèle des Trois Lignes

L'Institut des auditeurs internes (IIA) a publié en 2020 une mise à jour du modèle des « trois lignes » [39]. Il décrit les rôles plutôt que des barrières : la première ligne gère les risques dans les opérations, la deuxième apporte expertise, méthode et surveillance, la troisième, l'audit interne, donne une assurance indépendante à l'organe de gouvernance.

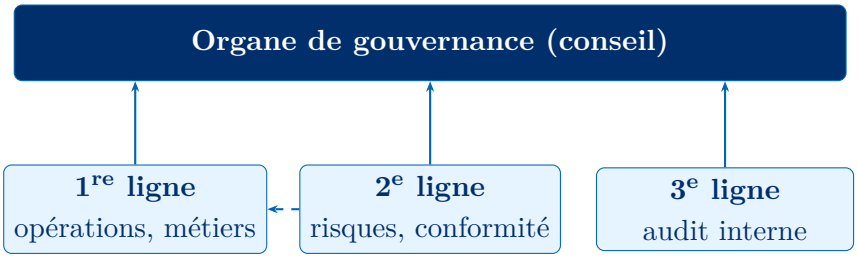


Figure 3.1. Le modèle des trois lignes (d'après l'IIA, 2020)

Scénario Opérationnel · Opération LIZBIZ. La nouvelle organisation

Constatation (avril 2026). LiZbiZ recrute une gestionnaire des risques, Mme MOUAFO, rattachée au directeur général (deuxième ligne). Mme NKENG, contrôleuse interne, voit son rôle d'audit confirmé et rattaché au comité d'audit du conseil (troisième ligne). Chaque directeur devient propriétaire des risques de son activité (première ligne).

Analyse (confiance élevée). La séparation entre la fonction qui conseille (Mme MOUAFO) et celle qui contrôle (Mme NKENG) garantit que l'audit ne juge pas un dispositif qu'il a lui-même conçu.

3.3 Appétence et Tolérance

Définition

Appétence au risque (COSO ERM) : types et niveau de risque qu'une organisation est disposée à accepter pour atteindre sa mission [3]. La **tolérance** précise, pour un objectif donné, l'écart acceptable autour de la cible, sous forme mesurable.

Domaine	Énoncé adopté par le conseil de LiZbiZ (mai 2026)
Continuité	Aucun arrêt de la facturation de plus de deux jours ouvrés
Données clients	Aucune fuite de données personnelles acceptée ; tout traitement de ces données est chiffré
Pertes financières	Perte annuelle liée aux incidents informatiques inférieure à 100 millions de FCFA dans neuf ans sur dix
Prestataires	Aucun accès distant d'un tiers sans second facteur ni journalisation

Tableau 3.2. L'appétence au risque de LiZbiZ

Une bonne appétence est *mesurable* : on doit pouvoir dire, à la fin de l'année, si elle a été respectée. « Nous avons une faible appétence au risque cyber » ne se vérifie pas ; « aucun arrêt de plus de deux jours » se vérifie.

3.4 Le Comité des Risques

Procédure de crise

Le comité des risques de LiZbiZ

1. **Composition** : directeur général (président), directeurs propriétaires de risques, gestionnaire des risques (secrétaire), contrôleuse interne (invitée, sans voix délibérative).
2. **Fréquence** : trimestrielle, et extraordinaire après tout incident majeur.
3. **Ordre du jour** : évolution des risques majeurs, état des plans de traitement, indicateurs, dérogations, risques émergents.
4. **Décisions** : consignées avec le propriétaire, l'échéance et le budget.
5. **Compte rendu** au conseil une fois par semestre.

3.5 Les Risques Externalisés

Externaliser une activité ne transfère pas la responsabilité de ses risques. LiZbiZ reste exploitant de ses systèmes au sens de la loi (Chapitre 5), même si SAHEL INFOGÉRANCE les administre.

Étape	Exigence
Avant le contrat	Évaluer le prestataire ; préciser ses accès et ses obligations de sécurité
Contrat	Délai de notification d'un incident, second facteur, droit d'audit, réversibilité, assurance
Pendant	Revue périodique des accès, indicateurs, audit
Fin	Retrait des accès, restitution et effacement des données

Tableau 3.3. Maîtriser un prestataire

Fiche de risque · R-02 · Accès distant d'un prestataire

Scénario : un compte du prestataire est usurpé et donne accès au domaine. **Cotation :** vraisemblance 3, impact 4 (score 12, intolérable). **Traitement :** réduire (second facteur, bastion, plages horaires) et contractualiser (notification sous 24 heures, droit d'audit). **Propriétaire :** M. NGUELE, signataire du contrat. **Indicateur :** part des accès du prestataire passés par le bastion.

Application Auditeur des systèmes d'information

Vérifier que chaque risque a un nom. L'auditeur prend le registre et, pour chaque risque majeur, vérifie que le propriétaire désigné sait qu'il l'est, connaît son plan de traitement et peut montrer où il en est.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le conseil** fixe l'appétence ; **la direction** met en œuvre ; **le propriétaire** traite son risque.
- **Trois lignes** : les opérations gèrent, la fonction risques aide et surveille, l'audit donne une assurance indépendante.
- **L'appétence** se formule de manière mesurable.
- **Le comité des risques** décide, consigne, rend compte.
- **Externaliser** ne transfère pas la responsabilité.

● Note

Points de contrôle de l'élève. Je sais : attribuer un risque à un propriétaire ; placer un acteur dans les trois lignes ; rédiger un énoncé d'appétence mesurable ; décrire un comité des risques ; énumérer les clauses de sécurité d'un contrat d'externalisation.

✍ **Exercice 3.1. Quelle ligne ?** ★☆☆

Placez dans les trois lignes : le chef d'agence de Garoua ; Mme MOUAFO ; Mme NKENG ; le RSSI ; un auditeur externe mandaté par le conseil.

✍ **Exercice 3.2. Le propriétaire** ★☆☆

Qui doit être propriétaire du risque « fraude au virement » : la DAF, le RSSI ou la gestionnaire des risques ? Justifiez.

✍ **Exercice 3.3. Mesurable** ★☆☆

Réécrivez de manière mesurable : « LiZbiZ a une faible tolérance aux interruptions de service ».

✍ **Exercice 3.4. Indépendance** ★★☆

Pourquoi Mme NKENG ne doit-elle pas rédiger elle-même la méthode d'analyse des risques qu'elle auditera ?

✍ **Exercice 3.5. Le contrat** ★★☆

Rédigez cinq clauses de sécurité à ajouter au contrat de SAHEL INFOGÉRANCE.

✍ Exercice 3.6. Appétence et décision ★★☆

Une option coûte 30 millions et ramène la perte dans neuf ans sur dix à 80 millions ; une autre coûte 10 millions et la ramène à 120 millions. Laquelle respecte l'appétence du Tableau 3.2 ?

✍ Exercice 3.7. L'ordre du jour ★★☆

Rédigez l'ordre du jour du comité des risques extraordinaire du 12 mars.

✍ Exercice 3.8. RACI ★★☆

Établissez une matrice RACI (réalise, approuve, consulté, informé) pour la mise en place du second facteur sur la passerelle.

✍ Exercice 3.9. Charte ★★★

Rédigez la charte de la fonction risques de LiZbiZ : mission, rattachement, droits d'accès à l'information, relations avec l'audit.

✍ Exercice 3.10. Une banque ★★★

Comment la gouvernance des risques de la BANQUE SANAGA doit-elle différer de celle de LiZbiZ ? Considérez la taille, la supervision et la nature des risques.

Note

Pour aller plus loin.

- IIA, *The IIA's Three Lines Model* [39].
- COSO, *Enterprise Risk Management* [3].

Note

Transition. Les rôles posés, il faut une méthode commune. Le Chapitre 4 présente l'ISO 31000 et le COSO ERM.

4

LES CADRES DE MANAGEMENT DES RISQUES

> « Une méthode commune ne garantit pas de bons jugements, mais elle permet de les comparer. »
>
> Principe du cours

Niveau : *Intermédiaire* • Chapitres 1 et 3.

✦ Objectifs du chapitre

- ➢ Énoncer les principes, le cadre organisationnel et le processus de l'ISO 31000.
- ➢ Situer le COSO ERM, ses composantes et son usage.
- ➢ Choisir une technique d'appréciation dans l'IEC 31010.
- ➢ Articuler un cadre général et un cadre propre à la sécurité de l'information (ISO/IEC 27005, NIST SP 800-30).
- ➢ Proposer un cadre adapté à une entreprise de taille moyenne.

Question directrice : quelle méthode adopter pour que les risques de LiZbiZ soient comparables ?

En avril, chaque direction de LiZbiZ présente « ses » risques au comité : la DAF les cote de 1 à 5, l'informatique en rouge, orange et vert, les opérations en jours d'arrêt. Aucun classement global n'est possible. Mme MOUAFO doit proposer un cadre commun, sans imposer une usine à gaz à une entreprise de 150 personnes.

Plan du chapitre.

1. L'ISO 31000 (section 4.1).
2. Le processus de management du risque (section 4.2).
3. Le COSO ERM (section 4.3).
4. Les techniques de l'IEC 31010 (section 4.4).

© MaletYon

5. Les cadres propres à la sécurité de l'information (section 4.5).
6. Un cadre pour LiZbiZ (section 4.6).

4.1 L'ISO 31000

L'[ISO 31000:2018] donne des lignes directrices applicables à toute organisation et à tout type de risque [16]. Elle ne se certifie pas. Elle s'organise en trois blocs : des *principes*, un *cadre organisationnel* et un *processus*.

Principe	Ce qu'il signifie
Intégré	Le risque se gère dans les décisions et les activités, pas à côté
Structuré et global	Une approche cohérente donne des résultats comparables
Adapté	Le dispositif est proportionné au contexte
Inclusif	Les parties prenantes sont associées
Dynamique	Le dispositif suit les changements
Meilleure information disponible	On utilise les données historiques, actuelles et prévisionnelles, avec leurs limites
Facteurs humains et culturels	Le comportement et la culture influencent chaque étape
Amélioration continue	On apprend et on progresse

Tableau 4.1. Les huit principes de l'ISO 31000:2018

Le *cadre organisationnel* décrit l'engagement de la direction, l'intégration, la conception, la mise en œuvre, l'évaluation et l'amélioration du dispositif : c'est la gouvernance du Chapitre 3.

4.2 Le Processus de Management du Risque

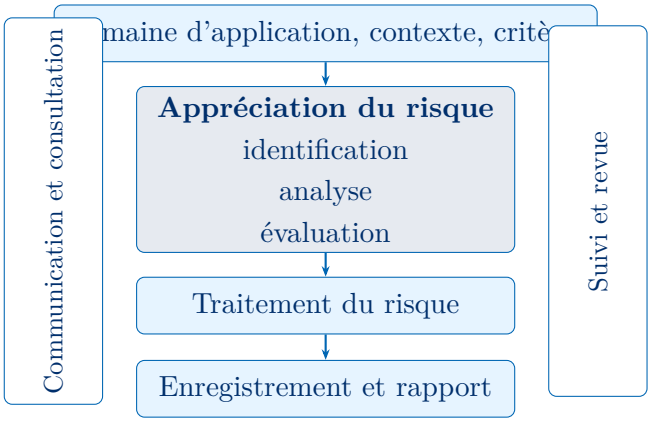


Figure 4.1. Le processus de l'ISO 31000:2018 (simplifié)

Définition

Appréciation du risque : processus global d'identification, d'analyse et d'évaluation du risque. L'*analyse* détermine la nature et le niveau du risque ; l'*évaluation* compare le résultat aux critères pour décider s'il faut le traiter.

La distinction entre *analyse* et *évaluation* est essentielle : la première est un travail d'expert (combien ?), la seconde une décision de direction (est-ce acceptable ?). Les **critères de risque**, fixés au départ, rendent la seconde reproductible.

4.3 Le COSO ERM

Le référentiel du COSO, *Enterprise Risk Management, Integrating with Strategy and Performance* (2017), relie la gestion des risques à la stratégie et à la performance [3]. Il compte cinq composantes et vingt principes.

Composante	Contenu
Gouvernance et culture	Surveillance par le conseil, structures, culture, valeurs, compétences
Stratégie et objectifs	Contexte, appétence, choix de la stratégie, objectifs
Performance	Identification, gravité, priorisation, réponses, vue d'ensemble des risques
Revue et révision	Changements importants, revue de la performance, amélioration
Information, communication et reporting	Systèmes d'information, communication, rapports

Tableau 4.2. Les cinq composantes du COSO ERM (2017)

Analyse. L'ISO 31000 est plus courte et plus générale ; le COSO ERM est plus détaillé et parle davantage aux conseils et aux auditeurs financiers. Les deux sont compatibles : on peut appliquer le processus de l'ISO 31000 en rendant compte selon les composantes du COSO.

4.4 Les Techniques de l'IEC 31010

L'[**IEC 31010:2019**] décrit plusieurs dizaines de techniques d'appréciation, avec leurs usages et leurs limites [10].

Technique	Étape	Usage chez LiZbiZ
Entretiens, ateliers	Identification	Recueillir les scénarios auprès des directeurs
Analyse d'impact sur l'activité	Analyse	Fixer RTO et RPO (Chapitre 17)
Arbre de défaillances	Analyse	Décomposer l'arrêt de la facturation
Nœud papillon	Analyse, traitement	Relier causes, événement, conséquences et barrières
Matrice de cotation	Évaluation	Classer les risques (Chapitre 7)
Simulation de Monte-Carlo	Analyse	Distribution des pertes (Chapitre 10)

Tableau 4.3. Quelques techniques de l'IEC 31010

4.5 Les Cadres Propres à la Sécurité de l'Information

Pour les risques liés à l'information, l'**[ISO/IEC 27005:2022]** décline le processus de l'ISO 31000 et le relie au système de management de l'**[ISO/IEC 27001]** [19], [20]. Le NIST SP 800-30 décrit, pour les systèmes fédéraux américains, une appréciation fondée sur les sources de menace, les vulnérabilités, la vraisemblance et l'impact [24]. EBIOS Risk Manager, de l'ANSSI, propose une démarche par scénarios en cinq ateliers (Chapitre 8).

★ Attention

Violation typique. Tenir deux registres séparés, l'un « risques de l'entreprise », l'autre « risques informatiques ».

Règle : un seul registre, des critères communs. Les risques de sécurité de l'information sont des risques de l'entreprise : ils se comparent aux autres sur les mêmes échelles d'impact.

4.6 Un Cadre pour LiZbiZ

Scénario Opérationnel · Opération LIZBIZ. Le cadre adopté en mai

Décision du comité des risques (mai 2026) :

- processus de l'ISO 31000, critères communs à toutes les directions (échelles du Chapitre 7) ;
- EBIOS Risk Manager pour les risques numériques majeurs, une fois par an ;
- estimation quantitative (FAIR) pour les cinq risques les plus élevés ;
- un registre unique tenu par Mme MOUAFO, revu chaque trimestre.

Analyse (confiance moyenne). Le cadre est proportionné : la méthode lourde (EBIOS, FAIR) est réservée aux risques qui la justifient.

Application Gestionnaire de risques

Écrire la méthode sur deux pages. Une méthode que les directeurs ne lisent pas ne sera pas appliquée. Mme MOUAFO rédige un guide de deux pages : critères, échelles, rôles, calendrier, modèle de fiche de risque.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'ISO 31000** : huit principes, un cadre organisationnel, un processus.
- **Analyse et évaluation** se distinguent : l'une mesure, l'autre décide, selon des critères fixés à l'avance.
- **Le COSO ERM** relie le risque à la stratégie ; il est compatible avec l'ISO 31000.
- **L'IEC 31010** donne les techniques ; **l'ISO/IEC 27005** décline le processus pour la sécurité de l'information.
- **Un registre unique**, des critères communs, une méthode proportionnée.

● Note

Points de contrôle de l'élève. Je sais : citer les principes et le processus de l'ISO 31000 ; distinguer analyse et évaluation ; nommer les composantes du COSO ERM ; choisir une technique de l'IEC 31010 ; situer l'ISO/IEC 27005 et le NIST SP 800-30.

✍ Exercice 4.1. Le processus ★☆☆

Rangez dans les étapes du processus de l'ISO 31000 : fixer les échelles d'impact ; lister les scénarios ; décider d'assurer un risque ; présenter le registre au conseil.

✍ Exercice 4.2. Analyser ou évaluer ★☆☆

« Le risque S1 a un score de 12 » et « le risque S1 est intolérable » : laquelle de ces phrases relève de l'analyse, laquelle de l'évaluation ?

✍ Exercice 4.3. Principes ★☆☆

Quel principe de l'ISO 31000 la pratique de LiZbiZ en avril (trois cotations différentes) viole-t-elle ?

✍ Exercice 4.4. COSO ★★☆

Dans quelle composante du COSO ERM se rangent : la définition de l'appétence ; la revue après l'attaque ; le tableau de bord du conseil ?

✍ Exercice 4.5. Choisir une technique ★★☆

Choisissez dans l'IEC 31010 une technique pour : identifier les risques d'un nouveau contrat ; comprendre pourquoi la facturation s'est arrêtée ; estimer la perte d'une année sévère.

✍ Exercice 4.6. Nœud papillon ★★☆

Dessinez le nœud papillon de l'événement « chiffrement des serveurs » : trois causes, trois conséquences, deux barrières de chaque côté.

✍ Exercice 4.7. Un registre ★★☆

Pourquoi LiZbiZ ne doit-elle pas tenir un registre séparé des risques informatiques ?

✍ Exercice 4.8. Proportionner ★★☆

Pourquoi le comité réserve-t-il FAIR aux cinq risques les plus élevés ? Que perdrait-on à l'appliquer à tous ?

✍ Exercice 4.9. Le guide ★★★

Rédigez le guide de deux pages de Mme MOUAFO : critères, échelles, rôles, calendrier, modèle de fiche.

✍ Exercice 4.10. Comparer ★★★

Comparez, en un tableau, l'ISO 31000, le COSO ERM, l'ISO/IEC 27005 et le NIST SP 800-30 : portée, public, certification, apports.

● Note

Pour aller plus loin.

- ISO 31000 [16] ; IEC 31010 [10].
- COSO ERM [3] ; NIST SP 800-30 [24].

Note

Transition. Le cadre doit aussi répondre à la loi. Le Chapitre 5 présente les obligations juridiques des exploitants et des dirigeants.

5

OBLIGATIONS JURIDIQUES ET RESPONSABILITÉS

« La loi ne demande pas d'éviter tout incident ;
elle demande d'avoir fait ce qu'il fallait. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 3 et 4 ; cours SEC3266, chapitre sur le droit.

✦ Objectifs du chapitre

- ➢ Citer les obligations de gestion des risques, de conservation et d'audit que la loi n° 2010/012 impose aux exploitants.
- ➢ Distinguer obligation de moyens et obligation de résultat.
- ➢ Identifier les responsabilités contractuelle, civile et pénale en jeu après un incident.
- ➢ Préparer les décisions juridiques d'une crise : plainte, rançon, données personnelles, assurance.
- ➢ Constituer la preuve qu'on a fait ce qu'il fallait.

Question directrice : LiZbiZ avait-elle respecté la loi avant l'attaque ?

Le 7 mars, Me TSALA pose trois questions à M. ETEME : « Aviez-vous un dispositif normalisé de gestion des risques ? Avez-vous conservé vos journaux ? Quand a eu lieu votre dernier audit ? » Aux trois, la réponse est embarrassée. Ce chapitre présente ce que la loi exige, et comment le prouver.

Plan du chapitre.

1. Gérer les risques : une obligation légale (section 5.1).
2. Conserver et surveiller (section 5.2).
3. L'audit de sécurité (section 5.3).

© MaletYon

4. Les responsabilités en jeu (section 5.4).
5. Les décisions juridiques d'une crise (section 5.5).

5.1 Gérer les Risques : une Obligation Légale

Jurisprudence & Droit applicable

Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité au Cameroun (texte officiel)

Article 26, alinéa 1 : *« Les exploitants des systèmes d'information prennent toutes les mesures techniques et administratives afin de garantir la sécurité des services offerts. A cet effet, ils se dotent de systèmes normalisés leur permettant d'identifier, d'évaluer, de traiter et de gérer continûment les risques liés à la sécurité des systèmes d'information dans le cadre des services offerts directement ou indirectement. »*

Article 30, alinéa 1 : *« Les exploitants des systèmes d'information évaluent, révisent leurs systèmes de sécurité et introduisent en cas de nécessité les modifications appropriées dans leurs pratiques, mesures et techniques de sécurité en fonction de l'évolution des technologies. »*

Portée. La loi n'impose pas une méthode, mais un *système normalisé* qui couvre les quatre temps du processus de l'ISO 31000 : identifier, évaluer, traiter, gérer continûment. Un registre établi après l'attaque ne prouve pas qu'on gérait les risques avant.

Définition

Obligation de moyens : obligation de mettre en œuvre tous les moyens raisonnables pour atteindre un but, sans garantir le résultat. **Obligation de résultat** : obligation d'atteindre le résultat promis. La sécurité des systèmes relève, en règle générale, de la première : on ne reproche pas l'attaque, mais l'absence de mesures.

5.2 Conserver et Surveiller

Jurisprudence & Droit applicable

Loi n° 2010/012, article 29 (texte officiel)

Alinéa 1 : *« Les exploitants des systèmes d'information ont l'obligation de conserver les données de connexion et de trafic de leurs systèmes d'information pendant une période de dix (10) ans. »*

Alinéa 2 : *« Les exploitants des systèmes d'information sont tenus d'installer des mécanismes de surveillance de contrôle d'accès aux données de leurs systèmes d'information. Les données conservées peuvent être accessibles lors des investigations*

judiciaires. »

Portée. Les journaux sont à la fois une obligation légale, une condition de la détection et la matière de l'enquête. La messagerie de LiZbiZ ne conservait que sept jours de journaux : l'obligation n'était pas tenue, et l'enquête en a été privée.

5.3 L'Audit de Sécurité

⚖ Jurisprudence & Droit applicable

Loi n° 2010/012 (texte officiel)

Article 4, point 9 : *« Audit de sécurité : examen méthodique des composantes et des acteurs de la sécurité, de la politique, des mesures, des solutions, des procédures et des moyens mis en oeuvre par une organisation, pour sécuriser son environnement, effectuer des contrôles de conformité, des contrôles d'évaluation de l'adéquation des moyens (organisationnels, techniques, humains, financiers) investis au regard des risques encourus, d'optimisation, de rationalité et de performance. »*

Article 13, alinéa 1 : *« Sont soumis à un audit de sécurité obligatoire, les réseaux de communications électroniques et les systèmes d'information, des opérateurs, des autorités de certification et des fournisseurs de services de communications électroniques. »*

Article 32, alinéas 1 et 2 : *« Les réseaux de communications électroniques et les systèmes d'information sont soumis à un régime d'audit de sécurité obligatoire et périodique de leurs systèmes de sécurité par l'Agence. » « L'audit de sécurité et les mesures d'impact de gravité sont effectués chaque année ou lorsque les circonstances l'exigent. »*

Portée. La définition légale rattache l'audit aux *risques encourus* : auditer, c'est vérifier que les moyens sont adéquats au regard des risques. Les conditions et les modalités de l'audit obligatoire sont fixées par voie réglementaire (article 13, alinéa 2) ; elles se vérifient dans les textes d'application et auprès de l'ANTIC.

5.4 Les Responsabilités en Jeu

Responsabilité	Fondement	Chez LiZbiZ
Contractuelle	Inexécution d'un contrat	Pénalités versées aux clients (74 millions) ; recours contre le prestataire
Civile	Dommage causé à un tiers par une faute	Clients dont les données ont été publiées le 19 mars
Pénale de l'attaquant	Infractions de la loi n° 2010/012	Plainte du 7 mars
Des dirigeants	Faute de gestion, devant la société et les tiers selon le droit des sociétés	Question posée par les actionnaires
Administrative	Contrôle de l'autorité de régulation	Conformité à l'article 26

Tableau 5.1. Les responsabilités après un incident

★ Attention

Violation typique. Croire que la qualité de victime protège de toute responsabilité.

Règle : l'entreprise attaquée est victime au pénal, mais peut être responsable au civil et au contrat si elle n'avait pas pris les mesures raisonnables. Sa meilleure défense est un dossier qui montre ce qu'elle avait fait, avant l'incident.

● Note

Les données personnelles. La loi n° 2024/017 relative à la protection des données à caractère personnel fixe le cadre camerounais (obligations des responsables de traitement, droits des personnes, autorité de protection). Le cours n'en cite pas les articles : ils doivent être lus dans le texte publié au Journal officiel, avec le conseil juridique, avant toute décision, notamment sur l'information des personnes concernées après une fuite.

5.5 Les Décisions Juridiques d'une Crise

☑ Procédure de crise

Les décisions juridiques des premières 72 heures

1. **Désigner le conseil juridique** dès l'ouverture de la cellule de crise.
2. **Préserver les preuves** (journaux, images, message de rançon) avant toute remise en état.
3. **Déposer plainte** auprès de la police judiciaire, de la gendarmerie ou du procureur.
4. **Déclarer le sinistre** à l'assureur dans le délai de la police.

5. **Examiner la rançon** avec le conseil : aucune garantie de restitution, risque de financer une activité criminelle, et de sanctions si le destinataire est visé par des mesures internationales.
6. **Évaluer les obligations envers les personnes** dont les données sont touchées (loi n° 2024/017) et envers les clients (contrats).
7. **Notifier le prestataire** et activer les clauses du contrat.

Scénario Opérationnel · Opération GAROUA. Le dossier de Me TSALA

Constatations. Pas de registre des risques avant mars ; journaux de la messagerie conservés sept jours ; dernier audit en 2023, hors prestataire ; contrat sans clause de sécurité ; police d'assurance excluant les cyberattaques.

Analyse (confiance moyenne). LiZbiZ peut difficilement démontrer qu'elle disposait du « système normalisé » de l'article 26. Son recours contre le prestataire est affaibli par l'absence de clause. Les actions engagées depuis avril (registre, audit, contrat révisé) ne réparent pas le passé, mais constituent le dossier de la prochaine fois.

Application Auditeur des systèmes d'information

Relier chaque constat à son fondement. Dans un rapport, l'auditeur cite pour chaque écart l'obligation qu'il méconnaît (article de loi, clause de contrat, politique interne). Un constat sans fondement est une opinion.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'article 26** impose un système normalisé de gestion continue des risques ; **l'article 30**, la révision.
- **L'article 29** impose dix ans de conservation des données de connexion et une surveillance des accès.
- **L'audit de sécurité** est défini par la loi au regard des risques encourus (articles 4, 13, 32).
- **La victime** peut être responsable au contrat et au civil ; on se défend par un dossier constitué avant.
- **En crise** : conseil, preuves, plainte, assureur, rançon, personnes concernées, prestataire.

Note

Points de contrôle de l'élève. Je sais : citer les articles 26, 29, 30 et 32 et en tirer la portée ; distinguer obligation de moyens et de résultat ; nommer les responsabilités en jeu ; dérouler les décisions juridiques des 72 premières heures.

✍ Exercice 5.1. L'article 26 ★☆☆

Quels sont les quatre verbes de l'article 26 qui décrivent la gestion des risques ? À quelles étapes de l'ISO 31000 correspondent-ils ?

✍ Exercice 5.2. Dix ans ★☆☆

Pendant combien de temps LiZbiZ doit-elle conserver les données de connexion de sa passerelle ? Quel article le prévoit ?

✍ Exercice 5.3. Moyens ou résultat ★☆☆

L'obligation de sécurité d'un exploitant est-elle de moyens ou de résultat ? Quelle conséquence pour sa défense après une attaque ?

✍ Exercice 5.4. La définition ★★☆

Selon l'article 4, point 9, au regard de quoi l'audit évalue-t-il l'adéquation des moyens ? Qu'en déduisez-vous pour le programme d'audit ?

✍ Exercice 5.5. Responsabilités ★★☆

Pour chaque responsabilité du Tableau 5.1, donnez la preuve que LiZbiZ aurait dû pouvoir produire.

✍ Exercice 5.6. La rançon ★★☆

Rédigez la note de Me TSALA à M. ETEME sur la rançon : faits, risques, options, recommandation.

✍ Exercice 5.7. Le contrat ★★☆

Quelles clauses auraient permis à LiZbiZ de se retourner contre SAHEL INFOGÉRANCE ?

✍ Exercice 5.8. Données personnelles ★★☆

Le 19 mars, des données de clients sont publiées. Quelles questions faut-il poser au conseil juridique, au regard de la loi n° 2024/017 ?

✍ Exercice 5.9. Le dossier ★★★

Établissez la liste des pièces que LiZbiZ doit tenir à jour pour prouver, à tout moment, qu'elle respecte les articles 26, 29 et 30.

✍ Exercice 5.10. L'assurance ★★★

Rédigez le cahier des charges d'une assurance cyber pour LiZbiZ : garanties, exclusions à refuser, obligations de l'assuré, plafonds.

● Note

Pour aller plus loin.

- Loi n° 2010/012 relative à la cybersécurité et la cybercriminalité au Cameroun [29].
- Loi n° 2024/017 relative à la protection des données à caractère personnel [30].

● Note

Transition. Les fondements sont posés. La Partie II apprend à analyser les risques, en commençant par les identifier (Chapitre 6).

partie II

Analyser les Risques

© *MaletYon*

6

IDENTIFIER LES RISQUES

« Le risque le plus dangereux
est celui qui ne figure pas dans le registre. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 1 à 4.

✦ Objectifs du chapitre

- ➢ Formuler un risque sous la forme cause, événement, conséquence.
- ➢ Choisir et combiner des techniques d'identification.
- ➢ Classer les risques selon une taxonomie utile.
- ➢ Partir des objectifs et des processus pour ne rien oublier.
- ➢ Repérer les signaux faibles et les risques émergents.

Question directrice : pourquoi le prestataire ne figurait-il dans aucune liste ?

Lors de l'atelier de mai, chaque directeur de LiZbiZ cite les risques de son activité. Personne ne cite SAHEL INFOGÉRANCE : pour la DAF, c'est un fournisseur ; pour l'informatique, un sous-traitant ; pour les opérations, un contrat. Un risque qui traverse les frontières des directions échappe aux listes établies direction par direction. Ce chapitre montre comment identifier sans laisser de trou.

Plan du chapitre.

1. Formuler un risque (section 6.1).
2. Partir des objectifs et des processus (section 6.2).
3. Les techniques d'identification (section 6.3).
4. Classer : les taxonomies (section 6.4).
5. Les signaux faibles (section 6.5).

© *MaletYon*

6.1 Formuler un Risque

Définition

Énoncé de risque : phrase qui relie une *cause* (source ou vulnérabilité), un *événement* incertain et ses *conséquences* sur un objectif. Forme recommandée : « Du fait de [cause], [événement] peut survenir, ce qui entraînerait [conséquence sur l'objectif]. »

Énoncé	Diagnostic
« Risque cyber »	Une catégorie, pas un risque : ni cause, ni événement, ni conséquence
« Manque de sauvegardes »	Une cause, pas un risque
« Perte de clients »	Une conséquence, pas un risque
« Du fait d'un accès distant du prestataire sans second facteur, un attaquant peut chiffrer les serveurs, ce qui arrêterait la facturation plusieurs jours »	Un risque bien formulé

Tableau 6.1. Formuler un risque

Attention

Violation typique. Inscrire au registre des mots-clés (« cyber », « réputation », « RH »).

Règle : un mot-clé ne se cote pas et ne se traite pas. On le décompose en scénarios formulés, chacun avec sa cause, son événement et sa conséquence.

6.2 Partir des Objectifs et des Processus

L'ISO 31000 rattache le risque aux objectifs : on identifie d'abord ce que l'organisation doit atteindre, puis ce qui peut l'en empêcher. Une méthode sûre consiste à parcourir les *processus* de l'entreprise et, pour chacun, ses ressources (personnes, systèmes, fournisseurs, locaux) et ses dépendances.

Processus	Ressources critiques	Exemple de risque
Facturer	Application intégrée, base de Douala, comptabilité	Arrêt de l'application plus de deux jours
Expédier	Agences, véhicules, suivi des expéditions	Inondation d'un entrepôt (Bonabéri)
Payer	Banque, double validation, trésorerie	Fraude au virement par usurpation d'un dirigeant
Administrer le SI	SAHEL INFOGÉRANCE, comptes à privilèges	Usurpation du compte du prestataire

Tableau 6.2. Identifier par les processus

6.3 Les Techniques d'Identification

Technique	Apport	Limite
Atelier pluridisciplinaire	Croise les points de vue, fait émerger les risques transversaux	Biais de groupe (Chapitre 2)
Entretiens individuels	Libère la parole, détaille un processus	Long ; vision partielle
Listes de contrôle	Ne rien oublier de connu	N'invente rien de nouveau
Historique des incidents	Données réelles	Ne montre que le passé
Revue de l'écosystème	Prestataires, clients, partenaires	Dépend de l'information obtenue des tiers
Analyse de scénarios	Explore l'inhabituel	Demande une animation experte

Tableau 6.3. Techniques d'identification (d'après l'IEC 31010)

Procédure de crise

Conduire un atelier d'identification

1. Envoyer à l'avance les objectifs, la liste des processus et l'historique des incidents.
2. Faire écrire à chacun, en silence, ses risques pendant dix minutes, avant toute discussion.
3. Regrouper, reformuler selon la forme cause, événement, conséquence ; supprimer les doublons.
4. Parcourir chaque processus et chaque tiers : « qu'a-t-on oublié ? »
5. Désigner pour chaque risque un propriétaire provisoire.

6. Consigner les risques écartés et la raison de leur exclusion.

Scénario Opérationnel · Opération LIZBIZ. L'atelier de mai

Constatation. L'atelier réunit huit personnes de six directions. Après la phase d'écriture silencieuse, 63 propositions ; après regroupement et reformulation, 41 risques. Le parcours des tiers en ajoute cinq, dont l'usurpation du compte du prestataire et la défaillance de l'unique opérateur de télécommunications de Garoua.

Analyse (confiance élevée). Les cinq risques ajoutés par la revue de l'écosystème n'avaient été cités par personne : l'identification par direction laisse passer les risques qui n'appartiennent à aucune.

6.4 Classer : les Taxonomies

Une **taxonomie des risques** répartit les risques en familles stables, pour vérifier que chacune a été examinée et consolider les résultats. Elle ne doit être ni trop fine (on ne s'y retrouve plus), ni trop grossière (« opérationnel » couvre tout).

Famille	Exemples chez LiZbiZ
Stratégique	Perte d'un client majeur ; arrivée d'un concurrent
Opérationnel	Inondation d'entrepôt ; panne de l'application ; erreur de saisie
Numérique	Rançongiciel ; fuite de données ; usurpation d'accès
Financier	Fraude au virement ; impayé d'un client
Conformité	Méconnaissance de l'article 26 ; données personnelles
Tiers	Défaillance du prestataire ; dépendance à un opérateur

Tableau 6.4. Une taxonomie pour LiZbiZ

6.5 Les Signaux Faibles

Définition

Signal faible : information partielle, isolée ou ambiguë, qui peut annoncer un risque nouveau ou l'aggravation d'un risque connu.

Les signaux faibles se trouvent dans les quasi-incidents, les plaintes des clients, les alertes des autorités, l'actualité des pairs. En janvier 2026, une entreprise de logistique voisine avait été frappée par un rançongiciel entré par l'accès d'un prestataire ; l'information avait circulé, sans être rapprochée de la situation de LiZbiZ.

Fiche de risque · R-03 · Défaillance de l'opérateur de Garoua

Scénario : du fait d'un opérateur unique à Garoua, une coupure prolongée du réseau isole l'agence, ce qui empêche le suivi et la facturation des expéditions du Nord. **Cotation :** vraisemblance 2, impact 3. **Traitement :** réduire (second lien par un autre opérateur, mode dégradé papier). **Propriétaire :** M. NGUELE. **Indicateur :** durée cumulée des coupures du trimestre.

Application Gestionnaire de risques

Tenir une veille. Mme MOUAFO tient une liste des incidents publiés dans le secteur et, pour chacun, se demande : « cela pourrait-il nous arriver, par où, et l'avons-nous au registre ? »

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Un risque se formule** : cause, événement, conséquence sur un objectif.
- **On part des objectifs et des processus**, et l'on parcourt les tiers.
- **Les techniques se combinent** : atelier, entretiens, listes, historique, écosystème, scénarios.
- **Une taxonomie** vérifie la couverture et consolide.
- **Les signaux faibles** nourrissent le registre ; la veille les rapproche de sa propre situation.

● Note

Points de contrôle de l'élève. Je sais : formuler un risque ; identifier par les processus ; animer un atelier ; choisir une technique ; classer selon une taxonomie ; exploiter un signal faible.

✍ Exercice 6.1. Diagnostiquer ★☆☆

Dites s'il s'agit d'une cause, d'un événement, d'une conséquence ou d'un risque formulé : « absence de second facteur » ; « publication des données clients » ; « arrêt de la facturation ».

✍ Exercice 6.2. Formuler ★☆☆

Formulez trois risques pour le processus « Payer » de LiZbiZ.

✍ Exercice 6.3. Classer ★☆☆

Classez dans la taxonomie du Tableau 6.4 les risques R-01, R-02 et R-03.

✍ Exercice 6.4. L'atelier ★★☆

Pourquoi faire écrire chacun en silence avant la discussion ? Quel biais du Chapitre 2 la règle combat-elle ?

✍ Exercice 6.5. Les tiers ★★☆

Dressez la liste des tiers dont dépend la facturation de LiZbiZ, et un risque pour chacun.

✍ Exercice 6.6. Écarter ★★☆

Pourquoi consigner les risques écartés et la raison de leur exclusion ?

✍ Exercice 6.7. Signal faible ★★☆

L'attaque d'une entreprise voisine en janvier était un signal faible. Décrivez le circuit qui aurait permis de le rapprocher de LiZbiZ.

✍ Exercice 6.8. Inondation ★★☆

Identifiez les risques de l'entrepôt de Bonabéri pendant la saison des pluies : causes, événements, conséquences.

✍ Exercice 6.9. Une banque ★★★

Préparez l'atelier d'identification des risques du système central de la BANQUE SANAGA : participants, documents, déroulé, taxonomie.

✍ Exercice 6.10. Complétude ★★★

Comment vérifier qu'un registre de 46 risques est complet ? Proposez trois contrôles indépendants.

● Note

Pour aller plus loin.

- ISO 31000 [16] ; IEC 31010 [10].
- ISO/IEC 27005 [20].

Note

Transition. Une fois identifiés, les risques doivent être cotés. Le Chapitre 7 présente les échelles et les matrices, avec leurs limites.

7

ESTIMER : ÉCHELLES ET MATRICES

« Une matrice de risques classe les risques ;
elle ne les mesure pas. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 1 et 6.

✦ Objectifs du chapitre

- ➢ Construire des échelles de vraisemblance et d'impact ancrées sur des valeurs.
- ➢ Coter un risque et le placer dans une matrice.
- ➢ Relier la matrice à l'appétence du conseil.
- ➢ Expliquer les limites des matrices décrites par Cox.
- ➢ Repérer une inversion de priorité et la corriger.

Question directrice : comment classer 46 risques en une séance de comité ?

Le registre de LiZbiZ compte 46 risques. Le comité de juin dispose de deux heures. Il lui faut un classement rapide, compréhensible et reproductible pour décider lesquels traiter d'abord. La matrice le permet ; elle peut aussi tromper. Ce chapitre montre comment s'en servir sans s'y fier aveuglément.

Plan du chapitre.

1. Les échelles (section 7.1).
2. Coter et placer (section 7.2).
3. Matrice et appétence (section 7.3).
4. Les limites des matrices (section 7.4).
5. Bien utiliser une matrice (section 7.5).

© MaletYon

7.1 Les Échelles

■ Définition

Échelle de cotation : suite ordonnée de niveaux, chacun défini par une description *et* une plage de valeurs, qui permet à deux personnes de donner la même cote au même risque.

Niveau	Vraisemblance (fréquence)	Impact (le plus élevé des critères)
1	Rare : moins d'une fois en dix ans	Mineur : moins de 5 millions de FCFA, arrêt de moins de 4 h
2	Possible : une fois en trois à dix ans	Modéré : 5 à 50 millions, arrêt de moins de 24 h
3	Probable : une fois en un à trois ans	Majeur : 50 à 500 millions, arrêt de 1 à 3 jours
4	Quasi certain : plus d'une fois par an	Critique : plus de 500 millions, arrêt de plus de 3 jours, sanction ou atteinte grave aux personnes

Tableau 7.1. Échelles de LiZbiZ (convention du cours)

★ Attention

Violation typique. Des échelles purement verbales (« faible », « moyen », « fort »).

Règle : chaque niveau porte une plage de valeurs (fréquence, montant, durée). Sans ancrage, « probable » signifie 10 % pour l'un et 70 % pour l'autre : les cotes ne se comparent plus.

7.2 Coter et Placer

On cote chaque risque en vraisemblance (V) et en impact (I), sur la base des mesures *en place et vérifiées* : c'est le **risque brut** (ou inhérent, si l'on raisonne sans aucune mesure). Le score $V \times I$ va de 1 à 16.

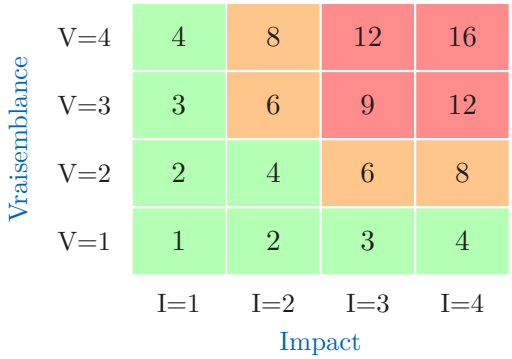


Figure 7.1. Matrice 4 × 4 de LiZbiZ : vert acceptable, orange à traiter, rouge intolérable

Réf.	Risque	V	I	Score	Zone
R-02	Usurpation de l'accès distant du prestataire	3	4	12	Intolérable
R-01	Arrêt de la facturation plus de deux jours	3	3	9	Intolérable
R-07	Fuite de données personnelles de clients	2	4	8	À traiter
R-11	Inondation de l'entrepôt de Bonabéri	2	3	6	À traiter
R-03	Défaillance de l'opérateur de Garoua	2	3	6	À traiter
R-15	Défiguration du portail de suivi	2	2	4	Acceptable

Tableau 7.2. Extrait du registre de LiZbiZ (juin 2026)

7.3 Matrice et Appétence

Les zones de la matrice traduisent l'appétence du conseil (Chapitre 3) : un score de 9 ou plus est intolérable et traité sans délai ; de 5 à 8, il est traité dans l'année ; de 1 à 4, il est accepté sous surveillance. Mais certains énoncés d'appétence ne passent pas par le score : « aucune fuite de données personnelles acceptée » rend R-07 intolérable quel que soit son score.

Scénario Opérationnel · Opération LIZBIZ. La règle d'exception

Constatation. R-07 a un score de 8 (à traiter dans l'année), mais l'appétence du conseil n'accepte aucune fuite de données personnelles.

Décision du comité. Un risque qui heurte un énoncé d'appétence est traité comme intolérable, quel que soit son score. R-07 passe en priorité.

7.4 Les Limites des Matrices

Louis Anthony Cox a montré en 2008 que les matrices de risques peuvent classer les risques plus mal qu'un tirage au hasard dans certains cas [5]. Ses critiques principales :

Limite	Explication
Compression	Des risques très différents tombent dans la même case : un impact de 60 et un de 480 millions ont la même cote 3
Inversion	Un risque plus coûteux en moyenne peut recevoir un score plus faible qu'un autre
Multiplication d'ordinaux	$V \times I$ multiplie des rangs, pas des grandeurs : « 2 » n'est pas « deux fois 1 »
Ambiguïté	La cote dépend de qui cote et de ce qu'il imagine
Pas d'agrégation	On ne peut pas additionner des scores pour obtenir le risque global

Tableau 7.3. Les limites des matrices (d'après Cox, 2008)

Scénario Opérationnel · Opération LIZBIZ. Une inversion

Constatation. Risque X, « incendie du centre de Douala » : fréquence estimée 0,08 par an (V=1), perte 600 millions (I=4), score 4, acceptable. Risque Y, « erreurs de saisie des bordereaux » : fréquence 0,5 par an (V=3), perte 10 millions (I=2), score 6, à traiter.

Analyse (confiance moyenne). Perte annuelle attendue de X : $0{,}08 \times 600 = 48$ millions ; de Y : $0{,}5 \times 10 = 5$ millions. La matrice classe Y avant X alors que X coûte près de dix fois plus en moyenne, et peut menacer l'entreprise. C'est une inversion au sens de Cox.

7.5 Bien Utiliser une Matrice

Procédure de crise

Cinq règles pour une matrice utile

1. **Ancrer** chaque niveau sur des valeurs (Tableau 7.1).
2. **Garder les valeurs** estimées à côté des cotes : fréquence et perte, avec leur intervalle.
3. **Examiner à part** les impacts critiques à faible vraisemblance (la colonne I=4), quel que soit leur score.
4. **Appliquer les énoncés d'appétence** qui ne passent pas par le score.
5. **Passer au quantitatif** pour les cinq ou dix risques les plus élevés (Chapitre 9).

Fiche de risque · R-11 · Inondation de l'entrepôt de Bonabéri

Scénario : du fait de l'implantation de l'entrepôt en zone basse près du Wouri, de fortes pluies l'inondent, ce qui détruit des marchandises de clients et arrête les

expéditions de Douala. **Cotation :** V=2, I=3 (score 6). **Traitement :** réduire (rayonnages surélevés, pompes, alerte météo) et transférer (assurance des marchandises). **Propriétaire :** M. NGUELE. **Indicateur :** hauteur des marchandises stockées au sol en saison des pluies.

Application Auditeur des systèmes d'information

Tester la reproductibilité. L'auditeur fait coter cinq risques du registre par deux personnes, séparément. Si les cotes divergent de plus d'un niveau, les échelles ne sont pas assez ancrées.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Des échelles ancrées** sur des valeurs rendent les cotes comparables.
- **Le score** $V \times I$ classe ; les zones traduisent l'appétence.
- **Certains énoncés d'appétence** rendent un risque intolérable quel que soit son score.
- **Les matrices compriment, inversent, ne s'additionnent pas** (Cox).
- **On garde les valeurs** à côté des cotes, et l'on passe au quantitatif pour les risques majeurs.

● Note

Points de contrôle de l'élève. Je sais : construire une échelle ancrée ; coter un risque et le placer ; appliquer l'appétence ; énoncer les limites de Cox ; détecter une inversion par la perte annuelle attendue.

✍ Exercice 7.1. Coter ★☆☆

Une panne de l'onduleur de Yaoundé survient une fois tous les deux ans et arrête le centre six heures pour un coût de 8 millions. Cotez V et I, calculez le score, donnez la zone.

✍ Exercice 7.2. Ancrer ★☆☆

Pourquoi le niveau d'impact retenu est-il « le plus élevé des critères » ? Donnez un exemple où le montant est faible mais la durée longue.

✍ Exercice 7.3. Zones ★☆☆

Combien de cases de la matrice 4 × 4 sont intolérables, à traiter, acceptables ?

✍ Exercice 7.4. Compression ★★☆

Donnez deux risques de même cote d'impact dont les pertes diffèrent d'un facteur huit. Que perd le comité à ne voir que la cote ?

✍ Exercice 7.5. Inversion ★★☆

Construisez un exemple d'inversion avec deux risques de votre choix, et montrez-la par la perte annuelle attendue.

✍ Exercice 7.6. Appétence ★★☆

Quels risques du Tableau 7.2 heurtent un énoncé d'appétence du Tableau 3.2, indépendamment de leur score ?

✍ Exercice 7.7. Additionner ★★☆

Un directeur propose de mesurer le « risque global » de LiZbiZ par la somme des scores du registre. Que lui répondez-vous ?

✍ Exercice 7.8. Reproductibilité ★★☆

Deux directeurs cotent R-03 en V=2 et V=4. Que faites-vous ?

✍ Exercice 7.9. Une échelle bancaire ★★★

Proposez des échelles adaptées à la BANQUE SANAGA (montants, durées, critères réglementaires et de réputation).

✍ Exercice 7.10. Au-delà de la matrice ★★★

Rédigez une page pour convaincre le comité de LiZbiZ de compléter la matrice par des estimations chiffrées pour ses cinq premiers risques.

Note

Pour aller plus loin.

- L. A. Cox, « What's Wrong with Risk Matrices ? » [5].
- IEC 31010 [10].

Note

Transition. Pour les risques numériques majeurs, LiZbiZ applique une méthode par scénarios. Le Chapitre 8 présente l'ISO/IEC 27005 et EBIOS Risk Manager.

8

ISO/IEC 27005 ET EBIOS RISK MANAGER

« L'attaquant ne vise pas vos serveurs ;
il vise ce qu'ils permettent. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 4 à 7 ; cours SEC3266, chapitre sur les risques.

✦ Objectifs du chapitre

- ➢ Situer l'ISO/IEC 27005 dans le système de management de l'ISO/IEC 27001.
- ➢ Distinguer l'approche par les événements et l'approche par les actifs.
- ➢ Conduire les cinq ateliers d'EBIOS Risk Manager.
- ➢ Coter la menace des parties prenantes de l'écosystème.
- ➢ Construire un scénario stratégique et un scénario opérationnel.

Question directrice : l'attaque de mars pouvait-elle être écrite d'avance ?

En juillet, Mme MOUAFO conduit la première étude EBIOS Risk Manager de LiZbiZ. Au troisième atelier, la cartographie de l'écosystème place SAHEL INFOGÉRANCE seule dans la zone de danger. Au quatrième, le scénario opérationnel décrit, étape par étape, l'attaque de mars. Ce chapitre déroule la méthode, deux séances durant.

Plan du chapitre.

1. L'ISO/IEC 27005 (section 8.1).
2. EBIOS Risk Manager : principes (section 8.2).
3. Ateliers 1 et 2 : socle, sources de risque (section 8.3).
4. Atelier 3 : l'écosystème (section 8.4).
5. Atelier 4 : les scénarios opérationnels (section 8.5).
6. Atelier 5 : le traitement (section 8.6).

© MaletYon

8.1 L'ISO/IEC 27005

L'[ISO/IEC 27005:2022] donne des recommandations pour gérer les risques liés à la sécurité de l'information, conformément aux exigences de l'[ISO/IEC 27001] [19], [20]. Elle reprend le processus de l'ISO 31000 et l'applique au système de management de la sécurité de l'information.

Approche	Point de départ	Usage
Par les événements	Les scénarios stratégiques, les sources de risque et leurs chemins	Vue de direction, risques majeurs, écosystème
Par les actifs	Les actifs, leurs menaces et leurs vulnérabilités	Analyse détaillée d'un périmètre technique

Tableau 8.1. Les deux approches de l'ISO/IEC 27005:2022

Dans un système de management ISO/IEC 27001, l'appréciation des risques conduit au choix des mesures de l'annexe A et à la **déclaration d'applicabilité**, qui justifie chaque mesure retenue ou exclue.

8.2 EBIOS Risk Manager : Principes

EBIOS Risk Manager, publiée par l'ANSSI en 2018, est une méthode par scénarios, compatible avec l'ISO 31000 et l'ISO/IEC 27005 [1]. Elle s'organise en cinq ateliers.

Atelier	Question	Livrable
1. Cadrage et socle	Que protège-t-on, contre quel événement redouté ?	Valeurs métier, biens supports, événements redoutés et gravité, socle de sécurité
2. Sources de risque	Qui pourrait attaquer, pour quoi ?	Couples source de risque et objectif visé, retenus ou non
3. Scénarios stratégiques	Par quel chemin dans l'écosystème ?	Cartographie de la menace, scénarios stratégiques, mesures sur l'écosystème
4. Scénarios opérationnels	Par quelles étapes techniques ?	Modes opératoires, vraisemblance
5. Traitement	Quelles mesures, quel risque résiduel ?	Stratégie, plan d'amélioration continue, risques résiduels

Tableau 8.2. Les cinq ateliers d'EBIOS Risk Manager

La méthode distingue un **cycle stratégique** (ateliers 1 à 3, repris à un rythme pluriannuel ou lors d'un changement majeur) et un **cycle opérationnel** (ateliers 4 et 5, repris plus souvent, au fil de l'évolution des menaces et des mesures).

8.3 Ateliers 1 et 2 : Socle et Sources de Risque

Valeur métier	Événement redouté	Gravité
Facturation	Facturation arrêtée plus de trois jours	G4
Suivi des expéditions	Suivi indisponible ou faussé plus d'un jour	G3
Données clients	Divulgation de données personnelles	G4
Paiements	Virement frauduleux de plus de 50 millions	G3

Tableau 8.3. Atelier 1 : valeurs métier et événements redoutés de LiZbiZ

Source de risque	Objectif visé	Décision
Groupe criminel	Lucre par rançon et revente de données	Retenu
Complice interne	Fraude au virement	Retenu
Ancien salarié	Revente de données clients	Retenu
Concurrent	Espionnage des tarifs	Non retenu (motivation faible)
Militant	Défiguration du portail	Non retenu (gravité faible)

Tableau 8.4. Atelier 2 : couples source de risque et objectif visé

8.4 Atelier 3 : l'Écosystème

L'attaquant passe souvent par un tiers moins protégé. L'atelier 3 cote chaque partie prenante sur quatre critères, de 1 à 4.

Définition

Niveau de menace d'une partie prenante (EBIOS RM) :

$$\text{Menace} = \frac{\text{Dépendance} \times \text{Pénétration}}{\text{Maturité cyber} \times \text{Confiance}}$$

La *dépendance* et la *pénétration* (accès au système) exposent ; la *maturité cyber* et la *confiance* protègent. Les seuils des zones de danger, de contrôle et de veille sont

fixés par l'étude.

Partie prenante	Dép.	Pén.	Mat.	Conf.	Menace
SAHEL INFOGÉRANCE	4	4	2	2	4,00
Transporteurs sous-traitants	2	2	1	2	2,00
Éditeur de l'application	3	2	3	3	0,67
Clients reliés par échange de données	2	2	2	3	0,67
Opérateur de Garoua	3	1	3	3	0,33
Banque	2	1	4	4	0,13

Tableau 8.5. Atelier 3 : menace des parties prenantes de LiZbiZ

Scénario Opérationnel · Opération LIZBIZ. La cartographie de juillet

Seuils retenus par l'étude : danger au-dessus de 2,5 ; contrôle de 0,9 à 2,5 ; veille en dessous de 0,9.

Constatation. SAHEL INFOGÉRANCE (4,00) est seule en zone de danger ; les transporteurs (2,00) sont en zone de contrôle ; les autres parties prenantes sont en veille.

Scénario stratégique retenu. Un groupe criminel compromet un technicien du prestataire, utilise son accès distant pour atteindre le domaine, chiffre les serveurs et exige une rançon (événement redouté : facturation arrêtée plus de trois jours, G4).

Mesures sur l'écosystème. Second facteur et bastion pour le prestataire (pénétration et maturité) ; clauses de sécurité et audit annuel (confiance). Objectif : ramener la menace sous 2,5.

8.5 Atelier 4 : les Scénarios Opérationnels

L'atelier 4 décrit le mode opératoire, étape par étape, et cote sa vraisemblance sur une échelle V1 à V4.

Étape	Action de l'attaquant	Mesure qui l'arrête
Connaître	Identifier un technicien du prestataire et son fournisseur de messagerie	Sensibilisation
Entrer	Hameçonner, puis se connecter à la passerelle avec le mot de passe	Second facteur
Trouver	Explorer le réseau, trouver un serveur non corrigé	Correctifs, segmentation
Exploiter	Obtenir les droits d'administrateur du domaine	Mots de passe locaux uniques, bastion
Agir	Copier, détruire les sauvegardes, chiffrer	Sauvegardes hors ligne, détection

Tableau 8.6. Atelier 4 : scénario opérationnel du rançongiciel

Vraisemblance. Avant mesures : V4 (quasi certain), chaque étape étant facile. Après second facteur, correctifs et sauvegardes hors ligne : V2, l'attaquant devant franchir plusieurs barrières indépendantes.

8.6 Atelier 5 : le Traitement

Procédure de crise

Atelier 5 chez LiZbiZ

1. Choisir, pour chaque risque, une option (réduire, transférer, éviter, accepter) au regard de l'appétence.
2. Inscrire les mesures dans un **plan d'amélioration continue de la sécurité** (PACS) : responsable, échéance, coût, indicateur.
3. Réévaluer gravité et vraisemblance avec les seules mesures en place et vérifiées : c'est le risque résiduel.
4. Faire accepter formellement les risques résiduels par la direction.
5. Fixer la date de la prochaine revue du cycle opérationnel.

Fiche de risque · R-02 · Usurpation de l'accès distant du prestataire

Scénario : stratégique et opérationnel des Tableaux 8.5 et 8.6. **Cotation :** G4, V4 avant mesures ; G4, V2 cible. **Traitement :** second facteur (juillet), bastion (septembre), clauses et audit (contrat renouvelé en octobre). **Propriétaire :** M. NGUELE. **Indicateur :** niveau de menace de SAHEL INFOGÉRANCE recoté à chaque revue.

Application Gestionnaire de risques

Faire écrire le scénario par ceux qui le vivraient. Mme MOUAFO fait rédiger le mode opératoire par l'informatique et le prestataire ensemble : c'est en décrivant l'attaque étape par étape que chacun voit la barrière qui manque.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'ISO/IEC 27005** applique l'ISO 31000 au système de management de la sécurité de l'information ; deux approches, par les événements ou par les actifs.
- **EBIOS RM** : cinq ateliers, un cycle stratégique et un cycle opérationnel.
- **L'écosystème** se cote : dépendance × pénétration, divisé par maturité × confiance.
- **Le scénario opérationnel** montre, étape par étape, la barrière qui manque.
- **Le traitement** produit un plan, un risque résiduel et une acceptation formelle.

Note

Points de contrôle de l'élève. Je sais : situer l'ISO/IEC 27005 ; nommer les cinq ateliers ; formuler un couple source de risque et objectif visé ; calculer le niveau de menace d'une partie prenante ; décrire un scénario opérationnel et ses barrières.

Exercice 8.1. Les ateliers ★☆☆

Dans quel atelier d'EBIOS RM se rangent : la liste des valeurs métier ; la cotation de la maturité du prestataire ; le plan d'amélioration continue ?

Exercice 8.2. Calculer la menace ★☆☆

Une société de gardiennage a une dépendance de 2, une pénétration de 1, une maturité de 1 et une confiance de 2. Calculez sa menace et sa zone.

Exercice 8.3. Les couples ★☆☆

Formulez deux couples source de risque et objectif visé pour l'ANPP.

Exercice 8.4. Recoter le prestataire ★★☆

Après les mesures, la pénétration de SAHEL INFOGÉRANCE passe à 2, sa maturité à 3 et la confiance à 3. Recalculez sa menace. Quitte-t-elle la zone de danger ?

✍ Exercice 8.5. Les transporteurs ★★☆

Les transporteurs sont en zone de contrôle. Quelles mesures proposer, sur quels critères agissent-elles ?

✍ Exercice 8.6. Écarter ★★☆

Pourquoi le couple « concurrent, espionnage des tarifs » n'a-t-il pas été retenu ? Dans quelles circonstances faudrait-il le réexaminer ?

✍ Exercice 8.7. Un scénario opérationnel ★★☆

Décrivez le scénario opérationnel « complice interne, fraude au virement » en cinq étapes, avec une barrière par étape.

✍ Exercice 8.8. Barrières indépendantes ★★☆

Pourquoi plusieurs barrières *indépendantes* réduisent-elles la vraisemblance plus qu'une seule barrière très forte ?

✍ Exercice 8.9. L'atelier 1 de la banque ★★★

Conduisez l'atelier 1 pour la BANQUE SANAGA : quatre valeurs métier, leurs biens supports, les événements redoutés et leur gravité.

✍ Exercice 8.10. Déclaration d'applicabilité ★★★

À partir du Tableau 8.6, indiquez quatre mesures de l'annexe A de l'ISO/IEC 27001 que LiZbiZ doit retenir, avec leur justification.

● Note

Pour aller plus loin.

- ANSSI, *EBIOS Risk Manager* [1].
- ISO/IEC 27005 [20] ; ISO/IEC 27001 [19].

● Note

Transition. Une vraisemblance V2 ou V4 reste une cote. Le Chapitre 9 apprend à estimer le risque en fréquences et en montants, avec la méthode FAIR.

9

L'ANALYSE QUANTITATIVE : FAIR ET PERTES ANNUELLES

« Si vous savez qu'un chiffre est entre deux bornes,
vous savez déjà quelque chose de mesurable. »

Principe du cours, d'après D. Hubbard

Niveau : *Intermédiaire à expert* • Chapitres 1, 2 et 7.

✦ Objectifs du chapitre

- ➢ Décomposer un risque selon la taxonomie FAIR (fréquence et ampleur des pertes).
- ➢ Estimer chaque facteur par un minimum, une valeur la plus probable et un maximum.
- ➢ Calculer une moyenne PERT et une perte annuelle attendue.
- ➢ Comparer deux options de traitement en pertes évitées.
- ➢ Présenter une estimation avec ses hypothèses et ses limites.

Question directrice : combien le risque de rançongiciel coûtait-il à LiZbiZ chaque année ?

En juin, le conseil demande un chiffre : « combien ce risque nous coûte-t-il ? » Une cote « 12, intolérable » ne répond pas. Mme MOUAFO applique la méthode FAIR au risque R-02, avec les directeurs et le prestataire, sur deux séances.

Plan du chapitre.

1. La taxonomie FAIR (section 9.1).
2. Estimer par trois points (section 9.2).
3. La fréquence des pertes (section 9.3).
4. L'ampleur des pertes (section 9.4).

© MaletYon

5. La perte annuelle attendue (section 9.5).
6. Comparer des options (section 9.6).

9.1 La Taxonomie FAIR

FAIR (*Factor Analysis of Information Risk*) décompose le risque en facteurs que l'on peut estimer séparément [6].

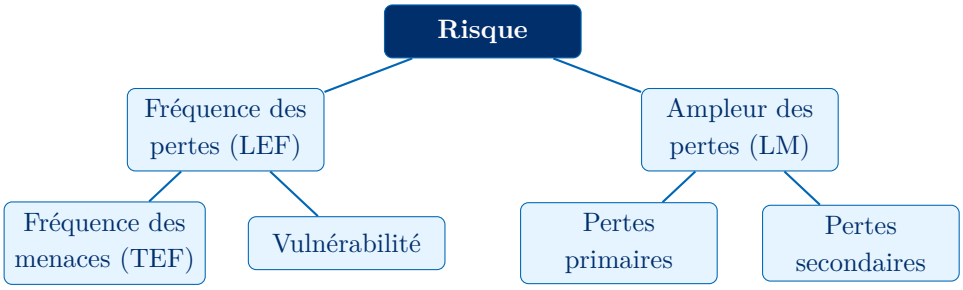


Figure 9.1. La taxonomie FAIR (simplifiée)

Définition

Facteurs FAIR. La **fréquence des pertes** (LEF) est le nombre d'événements de perte par an ; elle est le produit de la *fréquence des menaces* (TEF, tentatives par an) et de la *vulnérabilité* (probabilité qu'une tentative réussisse). L'**ampleur des pertes** (LM) réunit les pertes *primaires* (subies par l'organisation) et *secondaires* (dues aux réactions des tiers).

Forme de perte	Exemple chez LiZbiZ
Productivité	Marge perdue pendant l'arrêt, heures supplémentaires
Réponse	Prestataires de remise en état, conseil, communication
Remplacement	Matériel, licences
Amendes et jugements	Condamnations, sanctions
Avantage concurrentiel	Tarifs ou secrets divulgués
Réputation	Clients perdus, contrats non renouvelés

Tableau 9.1. Les six formes de perte de FAIR

9.2 Estimer par Trois Points

Chaque facteur est estimé par un *minimum*, une *valeur la plus probable* et un *maximum*, par des experts calibrés (Chapitre 2). La loi **PERT** en tire une moyenne :

$$\text{moyenne} = \frac{\min + 4 \times \text{plus probable} + \max}{6}.$$

Elle pondère la valeur la plus probable sans ignorer les extrêmes.

★ Attention

Violation typique. Demander à l'expert « le » chiffre.

Règle : demander trois valeurs et les raisons des bornes. Un chiffre unique cache l'incertitude ; trois valeurs la montrent, et la simulation (Chapitre 10) la propage.

9.3 La Fréquence des Pertes

Facteur	Min.	Plus prob.	Max.	Moyenne
TEF (tentatives sérieuses par an)	2	2,5	4	2,67
Vulnérabilité sans second facteur	5 %	10 %	20 %	10,8 %
Vulnérabilité avec second facteur	1 %	2 %	5 %	2,3 %

Tableau 9.2. Fréquence des pertes de R-02 (estimations de juin)

Calcul. LEF sans second facteur : $2{,}67 \times 0{,}108 \approx 0{,}29$ événement par an, soit un tous les trois à quatre ans environ. Avec second facteur : $2{,}67 \times 0{,}023 \approx 0{,}06$, un tous les seize ans environ. Les valeurs les plus probables donnent $2{,}5 \times 0{,}10 = 0{,}25$, l'hypothèse du Chapitre 1.

9.4 L'Ampleur des Pertes

Perte (millions de FCFA)	Min.	Plus prob.	Max.	Moyenne
Pertes primaires				
Productivité	30	60	150	70,0
Réponse	40	80	120	80,0
Remplacement	10	16	40	19,0
Pertes secondaires (probabilité 0,8 par événement)				
Pénalités contractuelles	20	74	120	72,7
Réputation (clients perdus)	0	110	250	115,0
Amendes et jugements	0	0	50	8,3

Tableau 9.3. Ampleur des pertes de R-02

Calcul. Pertes primaires moyennes : $70 + 80 + 19 = 169$ millions. Pertes secondaires moyennes : $72{,}7 + 115 + 8{,}3 = 196$ millions, à pondérer par leur probabilité : $0{,}8 \times 196 \approx 157$. Ampleur moyenne par événement : $169 + 157 \approx 326$ millions de FCFA.

Scénario Opérationnel · Opération GAROUA. L'estimation confrontée au réel

Constatation. Coût estimé de la crise de mars : 312 millions (Tableau 0.4), dans l'intervalle de l'estimation FAIR et proche de sa moyenne (326 millions).

Analyse (confiance moyenne). Un seul événement ne valide pas un modèle ; il montre seulement que l'ordre de grandeur n'était pas absurde. Les experts ont d'ailleurs utilisé le coût de mars pour estimer certaines valeurs : la concordance est en partie construite.

9.5 La Perte Annuelle Attendue

Définition

Perte annuelle attendue (FAIR) : produit de la fréquence moyenne des pertes et de l'ampleur moyenne d'un événement. Elle compare des risques et des options ; elle ne dit rien de la pire année, que donne la simulation.

	LEF (par an)	LM (millions)	Perte annuelle
Sans second facteur	0,289	326	94
Avec second facteur	0,062	326	20

Tableau 9.4. Perte annuelle attendue de R-02 (millions de FCFA)

9.6 Comparer des Options

Le second facteur coûte 6 millions par an. Il évite environ $94 - 20 = 74$ millions de pertes annuelles attendues. Le rapport entre pertes évitées nettes et coût :

$$\frac{74 - 6}{6} \approx 11.$$

Chaque franc dépensé en évite, en moyenne, une dizaine. Même avec les bornes les plus défavorables (TEF de 2, vulnérabilité de 5 % sans et de 5 % avec, ce qui annule l'effet), le calcul montre de quoi dépend la décision : la réduction de la vulnérabilité, qu'il faut donc vérifier.

Fiche de risque · R-02 · Estimation FAIR (juin 2026)

Scénario : rançongiciel par l'accès distant du prestataire. **Estimation :** 0,29 événement par an, 326 millions par événement, 94 millions de perte annuelle attendue. **Traitement :** second facteur (perte attendue ramenée à 20 millions). **Propriétaire :** M. NGUELE. **Indicateur :** part des connexions distantes avec second facteur (cible : 100 %).

Application Gestionnaire de risques

Montrer les hypothèses sur la même page que le chiffre. Mme MOUAFO présente au conseil la perte annuelle attendue, l'intervalle des estimations et les deux hypothèses dont le résultat dépend le plus.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **FAIR** : risque = fréquence des pertes × ampleur ; fréquence = menaces × vulnérabilité.
- **Six formes de perte**, primaires et secondaires.
- **Trois points** par facteur, moyenne PERT : (min + 4 × plus probable + max) / 6.
- **La perte annuelle attendue** compare des options ; elle ne décrit pas la pire année.
- **Pertes évitées nettes sur coût** : le langage du conseil.

Note

Points de contrôle de l'élève. Je sais : décomposer un risque selon FAIR ; nommer les six formes de perte ; calculer une moyenne PERT, une LEF, une ampleur et une perte annuelle attendue ; comparer deux options en pertes évitées nettes.

Exercice 9.1. PERT ★☆☆

Un expert estime une perte entre 10 et 70 millions, le plus probablement 25. Calculez la moyenne PERT.

✍ Exercice 9.2. LEF ★☆☆

Une fraude au virement est tentée en moyenne 6 fois par an et réussit une fois sur cinquante. Quelle est la fréquence des pertes ?

✍ Exercice 9.3. Formes de perte ★☆☆

Classez dans les six formes de FAIR : le salaire des agents qui ressaisissent les factures ; le client qui ne renouvelle pas son contrat ; l'achat d'un nouveau serveur.

✍ Exercice 9.4. Ampleur ★★☆

Refaites le calcul de l'ampleur moyenne de R-02 si la probabilité des pertes secondaires passe de 0,8 à 0,5.

✍ Exercice 9.5. La fraude ★★☆

Avec la LEF de l'exercice 9.2 et une perte moyenne de 60 millions, calculez la perte annuelle attendue. Une double validation à 4 millions par an qui divise la réussite par cinq est-elle justifiée ?

✍ Exercice 9.6. Les bornes ★★☆

Calculez la perte annuelle attendue de R-02 sans second facteur en prenant les minima de tous les facteurs, puis les maxima. Que vous apprend l'écart ?

✍ Exercice 9.7. Construite ★★☆

Pourquoi la concordance entre l'estimation et le coût réel de mars est-elle « en partie construite » ? Comment l'éviter dans une estimation future ?

✍ Exercice 9.8. Moyenne et pire année ★★☆

La perte annuelle attendue de R-02 avec second facteur est de 20 millions. LiZbiZ respecte-t-elle pour autant l'appétence « moins de 100 millions neuf ans sur dix » ? Que faut-il pour répondre ?

✍ Exercice 9.9. L'inondation ★★★

Conduisez une estimation FAIR simplifiée du risque R-11 (inondation de Bonabéri) : facteurs, trois points, moyennes, perte annuelle attendue.

✍ Exercice 9.10. La note au conseil ★★★

Rédigez la note d'une page de Mme MOUAFO au conseil sur R-02 : chiffre, intervalle, hypothèses décisives, recommandation.

Note

Pour aller plus loin.

- J. Freund et J. Jones, *Measuring and Managing Information Risk: A FAIR Approach* [6].
- D. Hubbard et R. Seiersen [9].

Note

Transition. La moyenne ne dit rien de la pire année. Le Chapitre 10 propage les incertitudes par simulation de Monte-Carlo.

10

SIMULER : MONTE-CARLO ET SENSIBILITÉ

> « La moyenne d'un fleuve est d'un mètre ;
> on s'y noie pourtant. »
>
> Proverbe repris par les statisticiens

Niveau : *Expert* • Chapitres 1 et 9 ; notions de lois de probabilité.

✦ Objectifs du chapitre

- ➢ Expliquer le principe d'une simulation de Monte-Carlo appliquée aux pertes.
- ➢ Choisir des lois pour le nombre d'événements et pour l'ampleur d'une perte.
- ➢ Lire une distribution de pertes annuelles : moyenne, centiles, probabilité de dépasser un seuil.
- ➢ Vérifier une appétence exprimée en probabilité.
- ➢ Identifier, par une analyse de sensibilité, les hypothèses qui comptent.

Question directrice : LiZbiZ respecte-t-elle son appétence « neuf ans sur dix » ?

Le conseil a fixé : « perte annuelle liée aux incidents informatiques inférieure à 100 millions de FCFA dans neuf ans sur dix ». La perte annuelle attendue de R-02, avec second facteur, est de 20 millions. L'appétence est-elle respectée ? La moyenne ne le dit pas : il faut la distribution.

Plan du chapitre.

1. Le principe (section 10.1).
2. Choisir les lois (section 10.2).
3. Lire les résultats (section 10.3).
4. La courbe de dépassement (section 10.4).
5. L'analyse de sensibilité (section 10.5).

© *MaletYon*

10.1 Le Principe

Définition

Simulation de Monte-Carlo : méthode qui tire au hasard, un grand nombre de fois, des valeurs des facteurs incertains selon leurs lois, calcule pour chaque tirage le résultat, et étudie la distribution des résultats obtenus.

Procédure de crise

Simuler une année de pertes, cent mille fois

1. Tirer le nombre d'événements de l'année selon une loi de fréquence.
2. Pour chaque événement, tirer une perte selon une loi d'ampleur.
3. Additionner les pertes de l'année.
4. Recommencer cent mille fois.
5. Trier les cent mille années et lire la moyenne, les centiles et la part des années au-dessus de chaque seuil.

10.2 Choisir les Lois

Grandeur	Loi usuelle	Pourquoi
Nombre d'événements par an	Poisson de paramètre λ	Événements indépendants, rares ; λ = fréquence moyenne (LEF)
Perte par événement	Log-normale	Toujours positive, asymétrique : beaucoup de pertes modérées, quelques très grosses
Facteur estimé par trois points	PERT ou triangulaire	Bornée, centrée sur la valeur la plus probable

Tableau 10.1. Les lois d'une simulation de pertes

Pour R-02, LiZbiZ retient une loi de Poisson de paramètre 0,29 (sans second facteur) ou 0,062 (avec), et une perte log-normale de médiane 290 millions et de 90e centile 540 millions, dont la moyenne (326 millions) est celle de l'estimation FAIR.

10.3 Lire les Résultats

Sur 100 000 années simulées	Sans second facteur	Avec second facteur
Perte annuelle moyenne	94	20
Part des années avec au moins une perte	25,0 %	6,0 %
90e centile	367	0
95e centile	517	184
99e centile	863	482
Part des années au-delà de 100 millions	24,7 %	5,9 %
Part des années au-delà de 500 millions	5,4 %	0,9 %

Tableau 10.2. Distribution des pertes annuelles de R-02 (millions de FCFA)

Scénario Opérationnel · Opération LIZBIZ. L'appétence vérifiée

Constatation. Sans second facteur, une année sur quatre environ (24,7 %) dépasse 100 millions ; avec second facteur, environ une sur dix-sept (5,9 %).

Analyse (confiance moyenne). L'appétence « moins de 100 millions neuf ans sur dix » demande moins de 10 % d'années au-delà du seuil. Elle n'était pas respectée sans second facteur ; elle l'est avec, pour ce seul risque. Il faut encore ajouter les autres risques numériques du registre pour conclure sur l'ensemble.

★ Attention

Violation typique. Lire le 90e centile « 0 » comme « aucun risque ».

Règle : avec second facteur, plus de 90 % des années sont sans perte, d'où un 90e centile nul ; mais le 95e centile atteint 184 millions. Un risque rare se lit dans les centiles élevés et dans la probabilité de dépassement.

10.4 La Courbe de Dépassement

■ Définition

Courbe de dépassement des pertes : courbe qui donne, pour chaque montant, la probabilité que la perte annuelle le dépasse. On la compare à la *courbe de tolérance* du conseil.

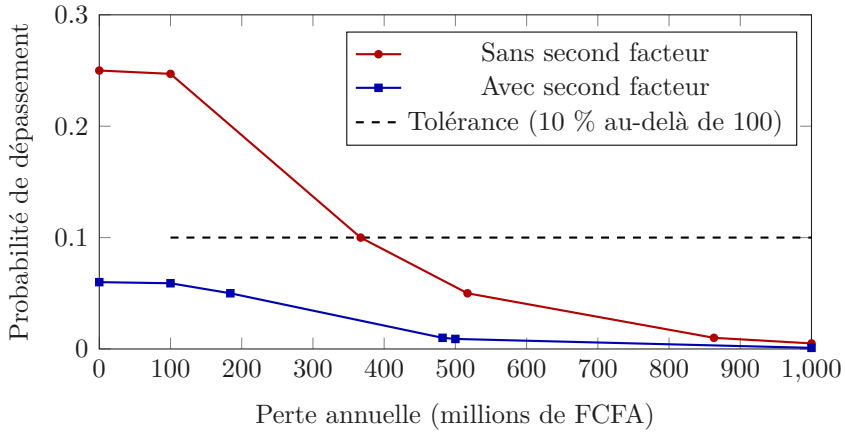


Figure 10.1. Courbes de dépassement de R-02 (points issus du Tableau 10.2)

10.5 L'Analyse de Sensibilité

Quelles hypothèses comptent le plus ? On fait varier chacune entre ses bornes plausibles, les autres restant fixes, et l'on observe la perte annuelle moyenne.

Hypothèse (sans second facteur)	Plage	Perte moyenne
Fréquence λ	0,20 à 0,40	65 à 130
Médiane de la perte	200 à 380	65 à 124

Tableau 10.3. Sensibilité de la perte moyenne (millions de FCFA)

Analyse. Les deux hypothèses pèsent autant. Mais la décision (le second facteur) agit sur la fréquence, qu'elle divise par près de cinq : c'est elle qu'il faut vérifier en priorité, par l'indicateur de couverture du second facteur. Une analyse de sensibilité dit où dépenser l'effort de mesure.

Application Gestionnaire de risques

Publier le code et les hypothèses. Mme MOUAFO conserve le programme de simulation, les lois, les paramètres et la graine du tirage aléatoire : un tiers doit pouvoir refaire le calcul et obtenir les mêmes chiffres.

Application Auditeur des systèmes d'information

Refaire un point. L'auditeur ne refait pas toute la simulation ; il vérifie un résultat simple, par exemple que la moyenne est proche de $\lambda \times$ perte moyenne ($0{,}29 \times 326 \approx 94$).

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Monte-Carlo** tire des milliers d'années et en étudie la distribution.
- **Poisson** pour le nombre d'événements, **log-normale** pour l'ampleur.
- **Les centiles et la probabilité de dépassement** disent la pire année, que la moyenne cache.
- **La courbe de dépassement** se compare à la tolérance du conseil.
- **La sensibilité** dit quelles hypothèses vérifier d'abord.

● Note

Points de contrôle de l'élève. Je sais : décrire les étapes d'une simulation ; choisir les lois ; lire moyenne, centiles et probabilités de dépassement ; vérifier une appétence en probabilité ; mener une analyse de sensibilité.

✍ **Exercice 10.1. Les étapes** ★☆☆

Décrivez, en cinq lignes, ce que fait la simulation pour une seule année.

✍ **Exercice 10.2. Lire** ★☆☆

D'après le Tableau 10.2, sans second facteur, combien d'années sur cent dépassent 500 millions ?

✍ **Exercice 10.3. Poisson** ★☆☆

Avec $\lambda = 0{,}29$, quelle est la probabilité d'une année sans aucun événement ? Comparez au tableau.

✍ **Exercice 10.4. Le centile nul** ★★☆

Expliquez pourquoi le 90e centile est nul avec second facteur, alors que le 95e atteint 184 millions.

✍ **Exercice 10.5. L'appétence** ★★☆

Montrez, à partir du Tableau 10.2, que l'appétence est respectée avec second facteur et ne l'est pas sans.

✍ **Exercice 10.6. Vérifier la moyenne** ★★☆

Vérifiez que les moyennes du Tableau 10.2 sont cohérentes avec les estimations FAIR du Chapitre 9.

✍ Exercice 10.7. Pourquoi log-normale ★★☆

Pourquoi une loi normale conviendrait-elle mal à l'ampleur d'une perte ?

✍ Exercice 10.8. Sensibilité ★★☆

Si la fréquence réelle sans second facteur était de 0,40, l'appétence serait-elle encore plus loin d'être respectée ? Justifiez.

✍ Exercice 10.9. Plusieurs risques ★★★

Décrivez comment simuler ensemble les cinq risques numériques majeurs de LiZbiZ pour vérifier l'appétence globale. Quelle difficulté pose leur éventuelle dépendance ?

✍ Exercice 10.10. Programmer ★★★

Écrivez, en Python ou dans un tableur, une simulation de 10 000 années pour R-02 avec second facteur, et comparez vos résultats au Tableau 10.2.

Note

Pour aller plus loin.

- IEC 31010, fiche sur la simulation de Monte-Carlo [10].
- D. Hubbard et R. Seiersen [9].

Note

Transition. Estimer ne suffit pas : il faut traiter, suivre et rendre compte. C'est l'objet du Chapitre 11.

11

TRAITER, SUIVRE ET RENDRE COMPTE

« Un risque n'est traité
que lorsque la mesure fonctionne. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 3, 7 et 9.

✦ Objectifs du chapitre

- ➢ Choisir une option de traitement selon l'ISO 31000.
- ➢ Rédiger un plan de traitement complet.
- ➢ Arbitrer un budget par les pertes évitées.
- ➢ Définir des indicateurs clés de risque avec des seuils.
- ➢ Rendre compte au comité et au conseil.

Question directrice : comment dépenser les 180 millions votés en avril ?

En avril, sous le choc, le comité de direction a voté 180 millions de FCFA pour la sécurité. En juin, le registre et les estimations sont prêts. Il reste à choisir les traitements, à les confier à des responsables, et à savoir, chaque trimestre, si le risque baisse vraiment.

Plan du chapitre.

1. Les options de traitement (section 11.1).
2. Le plan de traitement (section 11.2).
3. Arbitrer le budget (section 11.3).
4. Les indicateurs clés de risque (section 11.4).
5. Rendre compte (section 11.5).

© MaletYon

11.1 Les Options de Traitement

L'ISO 31000 énumère plusieurs options, qui se combinent [16].

Option	Principe	Exemple chez LiZbiZ
Éviter	Renoncer à l'activité qui crée le risque	Supprimer l'accès distant permanent du prestataire
Retirer la source	Supprimer la cause	Remplacer FTP par SFTP
Modifier la vraisemblance	Rendre l'événement moins probable	Second facteur, correctifs
Modifier les conséquences	Limiter les dommages	Sauvegardes hors ligne, mode dégradé
Partager	Transférer une part des conséquences	Assurance cyber, clauses du contrat
Maintenir	Accepter en connaissance de cause, par écrit	Défiguration du portail, sous surveillance
Prendre le risque	Saisir une opportunité	Ouvrir un portail client en ligne, avec ses mesures

Tableau 11.1. Les options de traitement (d'après l'ISO 31000:2018)

★ Attention

Violation typique. Croire que l'assurance « traite » le risque.

Règle : l'assurance partage une part des pertes financières ; elle ne réduit ni la vraisemblance, ni l'arrêt de l'activité, ni l'atteinte aux clients. Elle complète la réduction, elle ne la remplace pas. Et l'assureur exige souvent, en contrepartie, des mesures (second facteur, sauvegardes).

11.2 Le Plan de Traitement

■ Définition

Plan de traitement : document qui précise, pour chaque risque traité, les actions retenues, leur justification, le responsable, les ressources, l'échéance, l'indicateur de suivi et le risque résiduel visé.

Risque	Action	Responsable	Échéance	Indicateur
R-02	Second facteur sur la passerelle	M. KOUNOU	Juillet	Part des connexions avec second facteur
R-02	Bastion d'administration	M. KOUNOU	Septembre	Part des accès du prestataire par le bastion
R-01	Sauvegardes hors ligne et immuables	M. KOUNOU	Août	Durée du dernier test de restauration
R-07	Chiffrement des bases clients	M. KOUNOU	Octobre	Part des bases chiffrées
R-11	Rayonnages surélevés et pompes	M. NGUELE	Septembre	Hauteur des stocks au sol
R-03	Second lien télécom à Garoua	M. NGUELE	Novembre	Durée des coupures

Tableau 11.2. Extrait du plan de traitement de LiZbiZ

Le **risque résiduel** est réévalué avec les seules mesures en place et vérifiées ; il est *accepté par écrit* par le propriétaire et, au besoin, par la direction. Une mesure décidée mais non mise en œuvre ne réduit rien (cours SEC3266, Chapitre sur les risques).

11.3 Arbitrer le Budget

On classe les traitements par *pertes annuelles évitées nettes* et par rapport au coût annuel. Les pertes évitées viennent des estimations FAIR (Chapitre 9) pour les risques majeurs, et d'ordres de grandeur pour les autres.

Traitement	Coût annuel	Pertes évitées	Rapport net
Second facteur (R-02)	6	74	11,3
Sauvegardes hors ligne (R-01)	15	60	3,0
Bastion (R-02)	10	25	1,5
Rayonnages et pompes (R-11)	4	9	1,3
Surveillance externalisée (SOC)	60	45	-0,25

Tableau 11.3. Arbitrage des traitements (millions de FCFA par an ; rapport = (évité moins coût) / coût)

Scénario Opérationnel · Opération LIZBIZ. La décision de juin

Constatation. Les quatre premiers traitements coûtent 35 millions par an et évitent environ 168 millions de pertes attendues. La surveillance externalisée coûte plus qu'elle n'évite, selon les estimations.

Analyse (confiance faible). La surveillance réduit surtout le délai de détection, dont l'effet sur les pertes est mal estimé ; le rapport négatif peut venir de cette sous-estimation. Le comité retient les quatre premiers traitements, et une surveillance limitée aux heures de nuit, à réévaluer après six mois de mesures.

11.4 Les Indicateurs Clés de Risque

Définition

Indicateur clé de risque (KRI) : mesure qui signale à l'avance l'évolution d'un risque, assortie de seuils d'alerte. Il se distingue de l'indicateur de performance, qui mesure l'atteinte d'un objectif.

Indicateur	Risque	Vert	Orange	Rouge
Connexions distantes avec second facteur	R-02	100 %	95 à 99 %	moins de 95 %
Âge du dernier test de restauration réussi	R-01	moins de 3 mois	3 à 6 mois	plus de 6 mois
Correctifs critiques en retard	R-02	0	1 à 3	plus de 3
Comptes orphelins actifs	R-07	0	1 à 5	plus de 5

Tableau 11.4. Indicateurs clés de risque de LiZbiZ

Un bon indicateur clé de risque est *avancé* (il bouge avant l'incident), *mesurable* automatiquement si possible, et rattaché à un *propriétaire* qui agit quand il passe à l'orange.

11.5 Rendre Compte

Procédure de crise

Le rapport trimestriel au comité des risques

1. Les dix premiers risques, avec leur score et leur évolution depuis le trimestre précédent.
2. L'avancement du plan de traitement : actions faites, en retard, bloquées.
3. Les indicateurs clés de risque passés à l'orange ou au rouge, et ce qui a été fait.
4. Les incidents du trimestre et les risques qu'ils révèlent.

5. Les risques nouveaux ou émergents.
6. Les décisions demandées au comité.

Fiche de risque · R-01 · Arrêt de la facturation (suivi)

Cotation : V=3, I=3 (score 9) en juin ; cible V=2, I=2 après sauvegardes testées et mode dégradé. **Traitement :** sauvegardes hors ligne (août), test trimestriel. **Propriétaire :** Mme MBALLA. **Indicateur :** âge du dernier test de restauration réussi (vert sous trois mois).

Application Gestionnaire de risques

Une page pour le conseil. Le conseil reçoit chaque semestre une seule page : respect de l'appétence, les cinq risques majeurs, les décisions qui lui reviennent. Le détail est en annexe.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Plusieurs options** se combinent ; l'assurance partage, elle ne réduit pas.
- **Le plan de traitement** nomme l'action, le responsable, l'échéance, l'indicateur et le résiduel visé.
- **On arbitre** par les pertes évitées nettes, en disant la confiance de l'estimation.
- **Les indicateurs clés de risque** sont avancés, mesurables, à seuils, et ont un propriétaire.
- **Rendre compte** : dix risques, plan, indicateurs, incidents, émergents, décisions.

Note

Points de contrôle de l'élève. Je sais : choisir une option de traitement ; rédiger une ligne de plan de traitement ; calculer un rapport net ; définir un indicateur clé de risque et ses seuils ; structurer un rapport trimestriel.

Exercice 11.1. Quelle option ? ★☆☆

Donnez l'option de traitement : souscrire une assurance ; fermer l'agence de Garoua ; installer des pompes à Bonabéri ; accepter la défiguration du portail.

✍ Exercice 11.2. Rapport net ★☆☆

Un traitement coûte 8 millions par an et évite 20 millions de pertes attendues. Calculez le rapport net.

✍ Exercice 11.3. KRI ou KPI ★☆☆

Classez en indicateur clé de risque ou de performance : le chiffre d'affaires mensuel ; le nombre de correctifs critiques en retard ; le taux de livraison à l'heure.

✍ Exercice 11.4. L'assurance ★★☆

Pourquoi l'assurance seule ne suffit-elle pas pour R-02 ? Que demandera probablement l'assureur à LiZbiZ ?

✍ Exercice 11.5. Une ligne de plan ★★☆

Rédigez la ligne du plan de traitement pour le chiffrement des ordinateurs portables de la direction.

✍ Exercice 11.6. Le budget ★★☆

Sur les 180 millions votés, combien restent après les quatre premiers traitements du Tableau 11.3 la première année ? Que proposez-vous d'en faire ?

✍ Exercice 11.7. Le SOC ★★☆

Le rapport net de la surveillance externalisée est négatif. Quelles pertes évitées l'estimation a-t-elle pu oublier ?

✍ Exercice 11.8. Seuils ★★☆

Proposez des seuils vert, orange et rouge pour l'indicateur « hauteur des marchandises stockées au sol à Bonabéri en saison des pluies ».

✍ Exercice 11.9. Le rapport ★★★

Rédigez le rapport trimestriel de septembre au comité des risques de LiZbiZ, à partir des éléments du chapitre.

✍ Exercice 11.10. La page du conseil ★★★

Rédigez la page semestrielle au conseil : appétence, cinq risques majeurs, décisions demandées.

Note

Pour aller plus loin.

- ISO 31000, traitement, suivi et rapport [16].
- COSO ERM [3].

Note

Transition. Un dispositif de risques se vérifie. La Partie III apprend à l'auditer, en commençant par l'ISO 19011 (Chapitre 12).

partie III

Auditer le Dispositif

© MaletYon

12

L'AUDIT SELON L'ISO 19011

« Auditer, ce n'est pas chercher des fautes ;
c'est établir, preuves à l'appui, ce qui fonctionne et ce qui manque. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 3, 5 et 11 ; cours INF3226.

✦ Objectifs du chapitre

- ➢ Distinguer les audits de première, deuxième et troisième partie.
- ➢ Énoncer les sept principes de l'audit de l'ISO 19011.
- ➢ Établir un programme d'audit fondé sur les risques.
- ➢ Définir les rôles d'une équipe d'audit et les compétences attendues.
- ➢ Situer l'ISO/IEC 27007 pour l'audit d'un système de management de la sécurité.

Question directrice : que fallait-il auditer, et quand, chez LiZbiZ ?

Le dernier audit de sécurité de LiZbiZ datait de 2023 et ne couvrait pas le prestataire. Au printemps 2026, la mission d'AUDIX CONSEIL a examiné cinq domaines du système d'information (cours INF3226). En septembre, le comité d'audit demande à Mme NKENG un *programme* d'audit sur deux ans, qui couvre en priorité ce qui présente le plus de risques, y compris le dispositif de gestion des risques lui-même.

Plan du chapitre.

1. Les types d'audit (section 12.1).
2. Les principes de l'audit (section 12.2).
3. Le programme d'audit (section 12.3).
4. Les rôles et les compétences (section 12.4).

© MaletYon

5. L'audit d'un système de management de la sécurité (section 12.5).

12.1 Les Types d'Audit

Définition

Audit (ISO 19011) : processus méthodique, indépendant et documenté, permettant d'obtenir des preuves objectives et de les évaluer de manière objective pour déterminer dans quelle mesure les critères d'audit sont satisfaits [12].

Type	Qui audite	Exemple
Première partie	L'organisation elle-même (audit interne)	Mme NKENG audite le dispositif de risques
Deuxième partie	Un client ou un donneur d'ordre	LiZbiZ audite SAHEL INFOGÉRANCE, selon la clause du contrat
Troisième partie	Un organisme indépendant	Certification ISO/IEC 27001 ; audit de l'Agence au titre de l'article 32

Tableau 12.1. Les trois types d'audit

Les **critères d'audit** sont le référentiel auquel on compare les preuves : une norme, une politique interne, une clause de contrat, un article de loi. Sans critère, il n'y a pas d'écart, seulement des opinions.

12.2 Les Principes de l'Audit

Principe	Ce qu'il exige
Intégrité	Honnêteté, diligence, respect de la loi, impartialité
Présentation impartiale	Rapporter fidèlement, y compris les désaccords non résolus
Conscience professionnelle	Diligence et jugement proportionnés à l'importance de la tâche
Confidentialité	Protéger les informations obtenues
Indépendance	Ne pas auditer son propre travail ; rester libre de tout conflit d'intérêts
Approche fondée sur la preuve	Des conclusions vérifiables, fondées sur un échantillon d'informations disponibles
Approche fondée sur le risque	Concentrer l'audit sur ce qui compte pour l'organisation et pour l'atteinte des objectifs de l'audit

Tableau 12.2. Les sept principes de l'audit (ISO 19011:2018)

★ Attention

Violation typique. Confier l'audit du dispositif de risques à la personne qui l'a conçu.

Règle : Mme MOUAFO ne peut pas auditer le registre qu'elle tient ; Mme NKENG le peut, parce qu'elle n'y a pas pris part (Chapitre 3). Si l'auditeur a conseillé la conception, il le déclare et l'on confie le sujet à un autre.

12.3 Le Programme d'Audit

■ Définition

Programme d'audit : ensemble d'un ou plusieurs audits planifiés pour une durée donnée et dirigés vers un but spécifique. Il précise les objectifs, les risques et opportunités du programme, l'étendue, les ressources, le calendrier et la manière de le surveiller.

Un programme fondé sur les risques consacre plus d'audits, et plus tôt, aux processus les plus exposés, en s'appuyant sur le registre des risques (Chapitre 7).

Audit	Risques	Période	Type
Accès distants et prestataire	R-02	Octobre 2026	1re et 2e partie
Dispositif de gestion des risques	Tous	Octobre 2026	1re partie
Sauvegardes et reprise	R-01	Janvier 2027	1re partie
Données personnelles	R-07	Mars 2027	1re partie, avec conseil
Continuité des agences	R-03, R-11	Juin 2027	1re partie
Préparation à la certification ISO/IEC 27001	SMSI	Septembre 2027	Audit à blanc

Tableau 12.3. Programme d'audit 2026-2027 de LiZbiZ

Scénario Opérationnel · Opération LIZBIZ. Le programme validé

Constatation. Le comité d'audit valide le programme le 30 septembre. Le premier audit, « accès distants et prestataire », combine un audit interne et l'audit de SAHEL INFOGÉRANCE prévu par la nouvelle clause du contrat.

Analyse (confiance élevée). Le programme suit l'ordre des risques du registre : c'est l'approche fondée sur le risque. Il prévoit en outre d'auditer le dispositif de risques lui-même, sans quoi un registre faux orienterait faussement tout le programme.

12.4 Les Rôles et les Compétences

Rôle	Responsabilité
Responsable du programme	Établit, met en œuvre, surveille et améliore le programme
Responsable de l'équipe d'audit	Prépare et conduit un audit, répartit les tâches, rédige le rapport
Auditeur	Recueille et évalue les preuves, rédige les constats
Expert technique	Apporte une compétence particulière, sous la responsabilité d'un auditeur
Guide et observateur	Accompagnent l'équipe sans participer à l'évaluation

Tableau 12.4. Les rôles d'un audit

L'ISO 19011 décrit les compétences de l'auditeur : comportement professionnel (éthique, ouverture, observation, ténacité), connaissances génériques (principes, méthodes, systèmes de management) et connaissances propres à la discipline (ici, les risques et la sécurité de l'information).

12.5 L'Audit d'un Système de Management de la Sécurité

L'**[ISO/IEC 27007:2020]** complète l'ISO 19011 pour l'audit d'un système de management de la sécurité de l'information [18]. Elle précise ce qu'il faut examiner aux clauses 4 à 10 de l'ISO/IEC 27001 (contexte, leadership, planification dont l'appréciation des risques, support, fonctionnement, évaluation, amélioration) et comment relier les mesures de l'annexe A aux risques.

Fiche de risque · R-02 · Point d'audit

Scénario audité : usurpation de l'accès distant du prestataire. **Critères :** politique d'accès distant, clause du contrat (octobre 2026), article 29, alinéa 2 de la loi n° 2010/012. **Preuves attendues :** configuration de la passerelle, journaux de connexion, liste des comptes du prestataire, procès-verbal de l'audit du prestataire. **Propriétaire :** M. NGUELE.

Application Auditeur des systèmes d'information

Écrire les critères avant d'arriver. L'auditeur liste, avant la réunion d'ouverture, chaque critère et la preuve qui permettra de dire s'il est satisfait. Ce qu'il ne peut pas relier à un critère n'ira pas dans le rapport comme écart.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'audit** compare des preuves objectives à des critères ; il est interne, de deuxième ou de troisième partie.
- **Sept principes**, dont l'indépendance, l'approche fondée sur la preuve et l'approche fondée sur le risque.
- **Le programme** suit le registre des risques et audite aussi le dispositif de risques.
- **Les rôles** sont distincts ; l'expert technique travaille sous la responsabilité d'un auditeur.
- **L'ISO/IEC 27007** adapte l'ISO 19011 au système de management de la sécurité.

● Note

Points de contrôle de l'élève. Je sais : définir l'audit et les critères d'audit ; distinguer les trois types ; citer les sept principes ; construire un programme fondé sur les risques ; situer l'ISO/IEC 27007.

✍ Exercice 12.1. Quel type ? ★☆☆

Classez : l'audit de LiZbiZ par son assureur ; l'audit de la paie par Mme NKENG ; l'audit de certification par un organisme accrédité.

✍ Exercice 12.2. Les critères ★☆☆

Donnez trois critères d'audit possibles pour l'audit « sauvegardes et reprise ».

✍ Exercice 12.3. Principes ★☆☆

Quel principe un auditeur viole-t-il en omettant du rapport un désaccord avec l'audité ?

✍ Exercice 12.4. Indépendance ★★☆

M. KOUNOU propose d'auditer lui-même les sauvegardes, qu'il connaît mieux que quiconque. Que répondez-vous ? Comment utiliser sa compétence ?

✍ Exercice 12.5. Fondé sur le risque ★★☆

Justifiez l'ordre du programme du Tableau 12.3 par le registre des risques du Chapitre 7.

✍ Exercice 12.6. Le prestataire ★★☆

Quelles conditions doit réunir l'audit de SAHEL INFOGÉRANCE par LiZbiZ pour être possible et utile ?

✍ Exercice 12.7. L'expert ★★☆

AUDIX CONSEIL fournit un expert des passerelles d'accès distant. Quel est son rôle, et qui signe les constats ?

✍ Exercice 12.8. Les risques du programme ★★☆

Citez trois risques qui menacent le programme d'audit lui-même, et une parade pour chacun.

✍ Exercice 12.9. Un programme bancaire ★★★

Construisez le programme d'audit sur deux ans de la BANQUE SANAGA, fondé sur ses risques.

✍ Exercice 12.10. Clauses 4 à 10 ★★★

Pour chaque clause de 4 à 10 de l'ISO/IEC 27001, donnez une preuve que l'auditeur demandera à LiZbiZ.

Note

Pour aller plus loin.

➢ ISO 19011 [12] ; ISO/IEC 27007 [18].

Note

Transition. Le programme posé, il faut conduire chaque audit. Le Chapitre 13 traite des preuves, des échantillons et des constats.

13

CONDUIRE L'AUDIT : PREUVES, ÉCHANTILLONS, CONSTATS

« Zéro anomalie dans un échantillon
ne veut pas dire zéro anomalie dans la population. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitre 12 ; notions de probabilité.

✦ Objectifs du chapitre

- ➢ Dérouler les étapes d'un audit, de la préparation à la réunion de clôture.
- ➢ Juger la force d'une preuve selon sa source.
- ➢ Dimensionner un échantillon par attributs et en tirer une limite supérieure d'anomalies.
- ➢ Rédiger un constat : critère, fait, preuve, cause, conséquence.
- ➢ Distinguer non-conformité, opportunité d'amélioration et conformité.

Question directrice : 29 connexions examinées suffisent-elles à conclure sur 1 340 ?

En octobre, Mme NKENG audite les accès distants de LiZbiZ. En septembre, la passerelle a enregistré 1 340 connexions. Elle ne peut pas les examiner toutes à la main. Combien en examiner, comment les choisir, et que conclure si elle trouve une ou deux connexions sans second facteur ?

Plan du chapitre.

1. Les étapes d'un audit (section 13.1).
2. Les preuves (section 13.2).
3. Échantillonner (section 13.3).
4. Conclure sur la population (section 13.4).

5. Rédiger un constat (section 13.5).

13.1 Les Étapes d'un Audit

Étape	Contenu (d'après l'ISO 19011:2018)
Déclenchement	Contact avec l'audité, faisabilité, accès aux informations
Préparation	Revue documentaire, plan d'audit, répartition des tâches, documents de travail (listes de vérification, plans d'échantillonnage)
Réunion d'ouverture	Confirmer le périmètre, les critères, le calendrier, les modalités
Collecte et vérification	Entretiens, observations, examen de documents et d'enregistrements, essais
Constats	Comparer les preuves aux critères
Conclusions	Synthèse des constats au regard des objectifs de l'audit
Réunion de clôture	Présenter constats et conclusions, recueillir les désaccords
Rapport et suivi	Rapport, actions correctives, vérification (Chapitre 15)

Tableau 13.1. Les étapes d'un audit

13.2 Les Preuves

Définition

Preuve d'audit : enregistrements, énoncés de faits ou autres informations, pertinents pour les critères d'audit et vérifiables.

Source	Force	Exemple
Essai refait par l'auditeur	Élevée	Tenter une connexion à la passerelle sans second facteur
Enregistrement produit par le système	Élevée	Journal de la passerelle, exporté en présence de l'auditeur, avec son empreinte
Document	Moyenne	Politique d'accès distant signée
Observation	Moyenne	Voir le technicien se connecter par le bastion
Déclaration	Faible	« Tout le monde a le second facteur depuis juillet »

Tableau 13.2. Force des preuves selon leur source

★ Attention

Violation typique. Conclure sur une déclaration.

Règle : une déclaration oriente la recherche, elle ne prouve pas. On la corrobore par un enregistrement ou un essai. Faute de corroboration, le point reste ouvert (au Chapitre 26, on le cotera NEK).

13.3 Échantillonner

Quand la population est trop grande, l'auditeur examine un **échantillon**. Il peut le choisir *par jugement* (les connexions de nuit, celles du prestataire) ou *statistiquement* (au hasard), ce qui seul permet d'étendre une conclusion chiffrée à la population.

■ Définition

Échantillonnage par attributs : on compte, dans un échantillon tiré au hasard, les éléments qui présentent une anomalie (oui ou non). On fixe un *taux tolérable* d'anomalies et un *niveau de confiance*.

Si l'on s'attend à ne trouver aucune anomalie, la taille minimale n pour conclure, avec une confiance de 95 %, que le taux d'anomalies est inférieur au taux tolérable t vérifie $(1-t)^n \leq 0{,}05$:

$$n \geq \frac{\ln 0{,}05}{\ln(1-t)}.$$

Taux tolérable	Taille minimale
10 %	29
5 %	59
3 %	99

Tableau 13.3. Tailles d'échantillon, confiance 95 %, aucune anomalie attendue

La taille dépend du taux tolérable et de la confiance, presque pas de la taille de la population, dès que celle-ci est grande. 29 connexions suffisent pour 1 340 comme pour 100 000.

13.4 Conclure sur la Population

Si l'échantillon contient des anomalies, on calcule la **limite supérieure** du taux d'anomalies dans la population, à 95 % de confiance.

Anomalies trouvées	Échantillon de 29	Échantillon de 59
0	9,8 %	5,0 %
1	15,3 %	7,8 %
2	20,2 %	10,3 %

Tableau 13.4. Limite supérieure du taux d'anomalies, confiance 95 %

Scénario Opérationnel · Opération LIZBIZ. Les connexions de septembre

Constatation. Sur 29 connexions tirées au hasard parmi 1 340, une s'est faite sans second facteur, par le compte « vpn_secours », exclu de la politique pour « dépannage ». L'essai de l'auditrice confirme que ce compte se connecte avec son seul mot de passe.

Analyse (confiance élevée). Avec une anomalie sur 29, le taux réel peut atteindre 15,3 % : on ne peut pas conclure que 90 % au moins des connexions ont un second facteur. Mais l'enjeu n'est plus statistique : la cause est identifiée (un compte exclu), et toutes les connexions de ce compte sont à examiner, par un test exhaustif ciblé.

13.5 Rédiger un Constat

Procédure de crise

Les éléments d'un constat

1. **Critère** : l'exigence (politique, clause, article).
2. **Constat** : le fait observé, chiffré.
3. **Preuve** : la pièce qui l'établit, avec sa référence.
4. **Cause** : pourquoi l'écart existe.
5. **Conséquence** : le risque qui en résulte, relié au registre.
6. **Classement** : non-conformité (majeure ou mineure), opportunité d'amélioration, ou conformité.

Fiche de risque · Constat A-03 · Compte d'accès distant sans second facteur

Critère : politique d'accès distant (juillet 2026) : « toute connexion distante exige un second facteur ». **Constat :** le compte « vpn_secours » se connecte sans second facteur ; 46 connexions en septembre. **Preuve :** journal de la passerelle (export du 8 octobre, empreinte SHA-256 consignée), essai du 9 octobre. **Cause :** exception accordée oralement en juillet, jamais revue. **Conséquence :** R-02 n'est pas réduit comme le registre l'indique. **Classement :** non-conformité majeure.

Application Auditeur des systèmes d'information

Chiffrer, puis expliquer. L'auditeur ne se contente pas d'écrire « certaines connexions » : il donne le nombre, la période, la preuve, et passe du sondage au test exhaustif dès qu'il a identifié une cause.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Un audit** se prépare, s'ouvre, collecte, constate, conclut et se clôt en réunion.
- **Une preuve** vaut selon sa source : essai et enregistrement avant document, observation et déclaration.
- **L'échantillon statistique** seul permet d'étendre une conclusion : 29 pour 10 % de taux tolérable à 95 %.
- **Une anomalie trouvée** élève la limite supérieure ; une cause identifiée appelle un test exhaustif.
- **Un constat** : critère, fait, preuve, cause, conséquence, classement.

● Note

Points de contrôle de l'élève. Je sais : dérouler les étapes d'un audit ; classer une preuve par sa force ; calculer une taille d'échantillon sans anomalie attendue ; lire une limite supérieure ; rédiger un constat complet.

✍ **Exercice 13.1. Les étapes** ★☆☆

À quelle étape de l'audit se fait : la confirmation du périmètre avec l'audité ; l'export du journal ; la présentation des constats ?

✍ **Exercice 13.2. Classer les preuves** ★☆☆

Classez par force décroissante : un courriel du prestataire ; l'export du journal ; la politique signée ; un essai de connexion.

✍ **Exercice 13.3. Taille** ★☆☆

Quelle taille d'échantillon faut-il pour conclure, à 95 % de confiance et sans anomalie attendue, à un taux d'anomalies inférieur à 5 % ?

✍ **Exercice 13.4. La formule** ★★☆

Vérifiez par le calcul que 29 est la plus petite taille qui satisfait $(1 - 0{,}10)^n \leq 0{,}05$.

✍ **Exercice 13.5. Lire la limite** ★★☆

Avec deux anomalies dans un échantillon de 59, peut-on conclure à un taux inférieur à 10 % ? Justifiez par le Tableau 13.4.

✍ Exercice 13.6. Par jugement ★★☆

Dans quels cas l'auditeur doit-il préférer un échantillon par jugement ? Que ne peut-il alors pas conclure ?

✍ Exercice 13.7. Le constat ★★☆

Rédigez un constat complet pour l'écart suivant : la sauvegarde de la facturation n'a pas été testée depuis sa mise en place en août.

✍ Exercice 13.8. Majeure ou mineure ★★☆

Classez en non-conformité majeure, mineure ou opportunité d'amélioration : une politique non signée ; aucun registre des dérogations ; le compte « vpn_secours ».

✍ Exercice 13.9. Le plan d'audit ★★★

Rédigez le plan de l'audit « accès distants et prestataire » : objectifs, critères, périmètre, calendrier, échantillons, preuves attendues.

✍ Exercice 13.10. Calculer une limite ★★★

Écrivez la méthode (ou le programme) qui calcule la limite supérieure à 95 % du taux d'anomalies pour k anomalies dans un échantillon de n, et vérifiez la valeur 15,3 % pour $k = 1$, $n = 29$.

Note

Pour aller plus loin.

- ISO 19011, conduite de l'audit [12].
- ISO/IEC 27007 [18].

Note

Transition. Le Chapitre 14 applique la méthode à un objet particulier : le dispositif de gestion des risques et le système de management de la sécurité.

14

AUDITER LA GESTION DES RISQUES ET LE SMSI

« Un registre qui n'a jamais été surpris par un incident
n'a probablement jamais été confronté à un incident. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitres 11, 12 et 13.

✦ Objectifs du chapitre

- ➢ Auditer la conception, le fonctionnement et l'efficacité d'un dispositif de gestion des risques.
- ➢ Rapprocher les incidents du registre pour trouver les risques oubliés.
- ➢ Tester la reproductibilité des cotations et la réalité des mesures déclarées.
- ➢ Auditer un indicateur clé de risque : définition, population, source.
- ➢ Relier l'audit aux clauses de l'ISO/IEC 27001.

Question directrice : le registre de LiZbiZ dit-il vrai ?

En octobre, Mme NKENG audite le dispositif mis en place par Mme MOUAFO depuis avril. Le registre compte 46 risques, le plan de traitement six actions, le tableau de bord quatre indicateurs, tous verts. Tout semble en ordre. L'audit doit dire si le dispositif est bien conçu, s'il fonctionne, et s'il produit l'effet attendu.

Plan du chapitre.

1. Trois niveaux d'examen (section 14.1).
2. Rapprocher incidents et registre (section 14.2).
3. Tester cotations et mesures (section 14.3).
4. Auditer un indicateur (section 14.4).
5. Les clauses de l'ISO/IEC 27001 (section 14.5).

© MaletYon

14.1 Trois Niveaux d'Examen

Niveau	Question	Preuves
Conception	Le dispositif est-il bien pensé ?	Politique, appétence, critères, rôles, méthode
Fonctionnement	Est-il appliqué comme prévu ?	Registre à jour, comptes rendus du comité, plans suivis, indicateurs mesurés
Efficacité	Atteint-il son but ?	Incidents prévus ou non, appétence respectée, risques réellement réduits

Tableau 14.1. Auditer un dispositif de risques

★ Attention

Violation typique. S'arrêter à la conception (« la méthode existe, elle est conforme à l'ISO 31000 »).

Règle : une méthode excellente, mal appliquée, ne protège de rien. L'auditeur descend jusqu'à l'efficacité : les risques ont-ils baissé, et le registre a-t-il prévu les incidents survenus ?

14.2 Rapprocher Incidents et Registre

Chaque incident survenu est un test du registre : figurait-il parmi les scénarios identifiés ? Avec quelle cote ? Un incident absent du registre révèle un trou d'identification ; un incident d'un risque coté « acceptable » peut révéler une sous-estimation.

Incident du trimestre	Au registre	Lecture
Coupure du lien de Garoua (19 h)	R-03	Prévu, cote cohérente
Hameçonnage d'une assistante, signalé à temps	R-02	Prévu
Erreur de tarif sur un contrat	R-19	Prévu
Vol d'un ordinateur portable d'un commercial	Non	Trou : pas de risque « perte d'équipement nomade »
Panne de la climatisation du centre de Douala	Non	Trou : dépendances techniques des centres non examinées

Tableau 14.2. Rapprochement des incidents de juillet à septembre

14.3 Tester Cotations et Mesures

Procédure de crise

Quatre tests du dispositif

1. **Reproductibilité** : faire recoter cinq risques par deux personnes, séparément ; comparer.
2. **Réalité des mesures** : pour chaque action déclarée réalisée, demander la preuve de mise en œuvre et de vérification.
3. **Acceptations** : vérifier que chaque risque résiduel accepté l'a été par écrit, par la bonne personne.
4. **Propriétaires** : interroger trois propriétaires sur leur risque, son plan et son indicateur.

Scénario Opérationnel · Opération LIZBIZ. Ce que l'audit d'octobre a trouvé

Constatations.

- ➢ Recotation : trois risques sur cinq diffèrent d'au moins un niveau entre les deux cotateurs.
- ➢ Plan de traitement : six actions ; quatre réalisées et vérifiées ; une en retard (second lien de Garoua) ; une déclarée réalisée mais contredite par un essai (second facteur, compte « vpn_secours », Chapitre 13).
- ➢ Acceptations : deux risques résiduels acceptés oralement, sans trace.
- ➢ Propriétaires : deux sur trois connaissent leur plan ; un ignore qu'il est propriétaire.

Analyse (confiance élevée). Le dispositif est bien conçu et fonctionne en partie ; son efficacité est surestimée par un registre qui compte comme réalisée une action incomplète.

14.4 Auditer un Indicateur

Un indicateur vert peut être faux de trois manières : la *définition* ne mesure pas le risque, la *population* est incomplète, la *source* n'est pas fiable.

Fiche de risque · Constat A-05 · Indicateur du second facteur

Critère : indicateur clé de risque « part des connexions distantes avec second facteur » (Tableau 11.4). **Constat :** l'indicateur affiche 100 %, mais il est calculé sur les comptes *nominatifs* seulement ; le compte « vpn_secours » en est exclu

par construction. Sur toutes les connexions de septembre, le taux réel est de $(1\,340-46)/1\,340 \approx 96{,}6\,\%$, soit l'orange. **Preuve :** requête de calcul de l'indicateur, export du journal. **Cause :** population de l'indicateur définie par la même liste que la politique, exceptions comprises. **Classement :** non-conformité mineure (l'écart principal est traité au constat A-03).

Application Auditeur des systèmes d'information

Recalculer un indicateur à partir de la source. L'auditeur ne recopie pas le tableau de bord : il refait le calcul d'au moins un indicateur depuis les données brutes, et compare.

14.5 Les Clauses de l'ISO/IEC 27001

Pour un système de management de la sécurité, l'audit du dispositif de risques s'appuie sur les clauses de l'ISO/IEC 27001 [19] et sur les recommandations de l'ISO/IEC 27007 [18].

Clause	Exigence	Preuve demandée chez LiZbiZ
6.1.2	Appréciation des risques	Méthode, critères, registre daté
6.1.3	Traitement des risques	Plan de traitement, déclaration d'applicabilité, acceptation des résiduels
8.2 et 8.3	Appréciation et traitement réalisés à intervalles planifiés	Comptes rendus des revues trimestrielles
9.1	Surveillance et mesure	Définition et calcul des indicateurs
9.2	Audit interne	Programme et rapports d'audit
9.3	Revue de direction	Compte rendu de la revue
10.2	Non-conformité et action corrective	Suivi des constats A-03 et A-05

Tableau 14.3. Clauses de l'ISO/IEC 27001 relatives aux risques

Application Gestionnaire de risques

Accueillir l'audit comme une aide. Mme MOUAFO fournit les sources brutes, pas seulement les tableaux ; un constat sur son indicateur améliore son dispositif avant qu'un incident ne le fasse.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Trois niveaux** : conception, fonctionnement, efficacité.
- **Chaque incident** teste le registre : prévu ou non, et avec quelle cote.
- **Quatre tests** : reproductibilité, réalité des mesures, acceptations, propriétaires.
- **Un indicateur** se vérifie par sa définition, sa population et sa source.
- **L'ISO/IEC 27001** (6.1, 8, 9, 10) donne les critères pour un système de management.

● Note

Points de contrôle de l'élève. Je sais : distinguer conception, fonctionnement et efficacité ; rapprocher incidents et registre ; conduire les quatre tests ; auditer un indicateur ; citer les clauses de l'ISO/IEC 27001 relatives aux risques.

✍ Exercice 14.1. Quel niveau ? ★☆☆

Classez en conception, fonctionnement ou efficacité : « la méthode n'a pas d'échelle d'impact » ; « le comité ne s'est pas réuni au troisième trimestre » ; « deux incidents n'étaient pas au registre ».

✍ Exercice 14.2. Trous ★☆☆

Formulez les deux risques manquants révélés par le Tableau 14.2.

✍ Exercice 14.3. Recalculer ★☆☆

Vérifiez le taux réel de connexions avec second facteur du constat A-05.

✍ Exercice 14.4. Reproductibilité ★★☆

Trois risques sur cinq sont recotés différemment. Quelles causes possibles, et quelles corrections ?

✍ Exercice 14.5. Acceptation orale ★★☆

Pourquoi une acceptation orale d'un risque résiduel est-elle un écart ? Quel critère méconnaît-elle ?

✍ Exercice 14.6. Le propriétaire qui s'ignore ★★☆

Un directeur ignore qu'il est propriétaire d'un risque. Rédigez le constat et sa recommandation.

✍ Exercice 14.7. Population ★★☆

Donnez un autre exemple d'indicateur vert faussé par sa population, pris dans la sécurité des postes de travail.

✍ Exercice 14.8. Clause 10.2 ★★☆

Que doit contenir, selon la clause 10.2, la réponse de LiZbiZ au constat A-03 ?

✍ Exercice 14.9. Programme de tests ★★★

Construisez la liste de vérification complète de l'audit du dispositif de risques de LiZbiZ : points, critère, preuve, test.

✍ Exercice 14.10. Opinion d'ensemble ★★★

Rédigez la conclusion d'ensemble de Mme NKENG sur le dispositif, en trois paragraphes : conception, fonctionnement, efficacité.

Note

Pour aller plus loin.

- ISO/IEC 27001 [19] ; ISO/IEC 27007 [18].
- IIA, modèle des trois lignes [39].

Note

Transition. Les constats doivent être écrits, présentés et suivis. Le Chapitre 15 traite du rapport et du suivi des actions.

15

LE RAPPORT ET LE SUIVI DES ACTIONS

« Un audit sans suivi
n'est qu'un inventaire des regrets. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 12 à 14.

✦ Objectifs du chapitre

- ➢ Structurer un rapport d'audit pour ses différents lecteurs.
- ➢ Hiérarchiser les constats et formuler des recommandations vérifiables.
- ➢ Recueillir et traiter la réponse de l'audité.
- ➢ Conduire une action corrective selon l'ISO/IEC 27001 (10.2).
- ➢ Suivre la clôture des actions et en vérifier l'efficacité.

Question directrice : les constats de 2023 avaient-ils été suivis ?

En relisant le rapport d'audit de 2023, Mme NKENG découvre une recommandation : « étendre le second facteur aux accès des tiers ». Elle avait été acceptée, puis oubliée. Aucun suivi n'avait été organisé. Ce chapitre montre comment écrire un rapport qui sera lu, et organiser un suivi qui sera tenu.

Plan du chapitre.

1. La structure du rapport (section 15.1).
2. Hiérarchiser et recommander (section 15.2).
3. La réponse de l'audité (section 15.3).
4. L'action corrective (section 15.4).
5. Suivre et clore (section 15.5).

© MaletYon

15.1 La Structure du Rapport

Partie	Contenu
Synthèse	Une page pour la direction : conclusion d'ensemble, trois à cinq constats majeurs, décisions demandées
Cadre	Objectifs, périmètre, critères, période, équipe, limites
Constats	Chaque constat avec critère, fait, preuve, cause, conséquence, classement (Chapitre 13)
Recommandations	Une ou plusieurs par constat, vérifiables
Réponse de l'audité	Accord ou désaccord, plan d'action, responsable, échéance
Annexes	Liste des preuves, échantillons, personnes rencontrées

Tableau 15.1. Structure d'un rapport d'audit

★ Attention

Violation typique. Taire les limites de l'audit.

Règle : le rapport dit ce qui n'a pas été examiné et pourquoi (accès refusé, temps, périmètre). Un lecteur qui croit tout couvert prend les silences pour des conformités.

15.2 Hiérarchiser et Recommander

Priorité	Critère	Délai de traitement
1	Non-conformité majeure ; risque intolérable non réduit	Un mois
2	Non-conformité mineure ; risque à traiter	Trois mois
3	Opportunité d'amélioration	Selon le plan annuel

Tableau 15.2. Hiérarchiser les constats (convention du cours)

Une recommandation *vérifiable* dit ce qui doit être vrai, et non ce qu'il faudrait « envisager » : « au 30 novembre, aucun compte d'accès distant ne se connecte sans second facteur, et l'indicateur est calculé sur toutes les connexions » se vérifie ; « renforcer la sécurité des accès » ne se vérifie pas.

Scénario Opérationnel · Opération LIZBIZ. La synthèse du rapport d'octobre

Conclusion d'ensemble. Le dispositif de gestion des risques est correctement conçu et fonctionne en partie ; son efficacité est surestimée.

Constats majeurs. A-03, compte d'accès distant sans second facteur (priorité 1) ;

A-05, indicateur calculé sur une population incomplète (priorité 2) ; A-07, deux risques résiduels acceptés sans trace (priorité 2) ; A-08, deux risques manquants au registre (priorité 2).

Décision demandée. Supprimer toute exception au second facteur sans validation du comité des risques.

15.3 La Réponse de l'Audité

L'audité répond à chaque constat : il l'accepte ou le conteste, et propose une action, un responsable et une échéance. Un désaccord n'est pas effacé : il figure au rapport, avec les arguments des deux parties (principe de présentation impartiale, Chapitre 12).

Constat	Réponse	Action	Resp.	Échéance
A-03	Accepté	Second facteur sur « vpn_secours », procédure de dérogation	M. KOU-NOU	30 nov.
A-05	Accepté	Recalcul de l'indicateur sur toutes les connexions	Mme MOU	15 nov.
A-07	Accepté	Formulaire d'acceptation signé	Mme MOU	30 nov.
A-08	Partiellement	Ajout du risque « équipement nomade » ; la climatisation est jugée couverte par R-01	Mme MOU	31 déc.

Tableau 15.3. Réponse de la direction au rapport d'octobre

15.4 L'Action Corrective

Procédure de crise

Action corrective (d'après l'ISO/IEC 27001, 10.2)

1. **Réagir** : maîtriser et corriger l'écart (activer le second facteur sur le compte).
2. **Analyser la cause** : pourquoi l'écart existe-t-il, et peut-il exister ailleurs ? (exceptions orales non tracées).
3. **Agir sur la cause** : procédure de dérogation écrite, limitée dans le temps, validée par le comité.
4. **Vérifier l'efficacité** : refaire l'essai, recalculer l'indicateur, rechercher d'autres exceptions.
5. **Mettre à jour** le registre et, si besoin, le système de management.

Définition

Correction et **action corrective** : la correction supprime l'écart constaté ; l'action corrective supprime sa cause pour éviter qu'il ne se reproduise.

15.5 Suivre et Clore

Le suivi est tenu par l'audit (troisième ligne) dans un tableau des recommandations, présenté au comité d'audit. Une action n'est *close* que lorsque l'auditeur en a vérifié l'efficacité, et non lorsque l'audité la déclare faite.

Fiche de risque · Constat A-03 · Suivi

Action : second facteur sur le compte « vpn_secours », procédure de dérogation. **Déclarée réalisée :** 22 novembre. **Vérifiée :** 3 décembre, par un essai de connexion (refusé sans second facteur) et par l'export du journal (aucune connexion sans second facteur depuis le 22 novembre). **Statut :** close.

Indicateur de suivi	Fin décembre
Recommandations émises	9
Closes après vérification	6
En cours, dans les délais	2
En retard	1

Tableau 15.4. Tableau de suivi des recommandations (audit d'octobre)

Application Auditeur des systèmes d'information

Ne clore que ce qu'on a vérifié. Mme NKENG refuse de clore sur une déclaration : elle demande la preuve de mise en œuvre, puis la preuve d'efficacité. La recommandation de 2023, déclarée « en cours » pendant trois ans, ne l'aurait pas été sous ce régime.

À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le rapport** s'adresse à plusieurs lecteurs : synthèse, cadre et limites, constats, recommandations, réponse, annexes.
- **Les constats** se hiérarchisent ; les recommandations sont vérifiables.
- **La réponse de l'audité** figure au rapport, désaccords compris.

- **L'action corrective** traite la cause, pas seulement l'écart, et vérifie son efficacité.
- **Une action est close** quand l'auditeur a vérifié son efficacité.

Note

Points de contrôle de l'élève. Je sais : structurer un rapport ; hiérarchiser des constats ; rédiger une recommandation vérifiable ; distinguer correction et action corrective ; tenir un tableau de suivi.

Exercice 15.1. Vérifiable ★☆☆

Réécrivez de manière vérifiable : « améliorer la gestion des sauvegardes ».

Exercice 15.2. Priorité ★☆☆

Donnez la priorité des constats A-03, A-05 et A-08 selon le Tableau 15.2, et le délai correspondant.

Exercice 15.3. Correction ou action corrective ★☆☆

Classez : activer le second facteur sur le compte ; créer une procédure de dérogation ; supprimer le compte.

Exercice 15.4. La synthèse ★★☆

Réécrivez la synthèse du rapport d'octobre en dix lignes pour le conseil.

Exercice 15.5. Le désaccord ★★☆

La direction conteste en partie A-08. Comment le rapport doit-il présenter ce désaccord ? L'auditrice doit-elle céder ?

Exercice 15.6. Les limites ★★☆

Rédigez la section « limites » du rapport d'octobre : ce qui n'a pas été examiné et pourquoi.

Exercice 15.7. Clore ★★☆

M. KOUNOU déclare l'action A-03 réalisée. Quelles preuves Mme NKENG exige-t-elle avant de la clore ?

Exercice 15.8. Le suivi ★★☆

Calculez le taux de clôture vérifiée du Tableau 15.4. Que proposez-vous pour l'action en retard ?

✍ Exercice 15.9. La recommandation de 2023 ★★★

Analysez pourquoi la recommandation de 2023 a été oubliée, et proposez un dispositif de suivi qui l'aurait empêché.

✍ Exercice 15.10. Un rapport complet ★★★

Rédigez le rapport complet de l'audit « accès distants et prestataire », selon la structure du Tableau 15.1.

Note

Pour aller plus loin.

- ISO 19011, rapport et suivi [12].
- ISO/IEC 27001, clause 10 [19].

Note

Transition. L'audit vérifie que les mesures tiennent. Quand elles cèdent, il faut gérer l'incident. La Partie IV commence par la gestion des incidents (Chapitre 16).

partie IV

Incidents et Continuité

© MaletYon

16

GÉRER LES INCIDENTS DE SÉCURITÉ

« Un incident mal classé est un incident mal traité. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 11 et 15 ; cours SEC3266, chapitre sur les opérations.

✦ Objectifs du chapitre

- ➢ Distinguer événement, incident et crise.
- ➢ Dérouler les phases de la gestion des incidents selon l'ISO/IEC 27035.
- ➢ Classer un incident et l'escalader selon une grille.
- ➢ Organiser l'équipe de réponse et ses liens avec la direction.
- ➢ Mesurer la gestion des incidents et en tirer des enseignements pour le registre.

Question directrice : à partir de quand un incident devient-il l'affaire du directeur général ?

Le 5 mars à 22 h 05, le technicien d'astreinte voit que l'application ne répond plus. Il redémarre les serveurs et rentre chez lui : pour lui, c'est une panne. Le lendemain à 7 h 30, c'est une crise. Entre les deux, aucune grille ne disait qui prévenir, ni à partir de quand. Ce chapitre traite de la gestion des incidents du point de vue de l'organisation.

Plan du chapitre.

1. Événement, incident, crise (section 16.1).
2. Les phases de l'ISO/IEC 27035 (section 16.2).
3. Classer et escalader (section 16.3).
4. L'équipe de réponse (section 16.4).
5. Mesurer et apprendre (section 16.5).

© MaletYon

16.1 Événement, Incident, Crise

Définition

Événement de sécurité : occurrence qui indique une possible violation de la sécurité ou une défaillance des mesures. **Incident de sécurité** : un ou plusieurs événements indésirables qui ont une probabilité significative de compromettre l'activité ou de menacer la sécurité de l'information [21]. Une **crise** est une situation qui dépasse les capacités de la gestion courante et exige des décisions de la direction (Chapitre 21).

Niveau	Exemple	Qui gère
Événement	Une alerte d'antivirus bloquée	Exploitation, sans escalade
Incident	Un poste infecté, isolé	Équipe de réponse
Incident majeur	Un compte à privilèges compromis	Équipe de réponse, RSSI, direction informée
Crise	Serveurs chiffrés sur deux sites	Cellule de crise présidée par le DG

Tableau 16.1. De l'événement à la crise

16.2 Les Phases de l'ISO/IEC 27035

L'**[ISO/IEC 27035-1:2023]** décrit cinq phases de gestion des incidents [21]. Le NIST SP 800-61 Rev. 3 (2025) les relie aux fonctions du NIST CSF 2.0 [33].

Phase	Contenu
Planifier et préparer	Politique, équipe, procédures, outils, grille de gravité, contacts, exercices
Détecter et signaler	Recevoir les alertes et les signalements, les enregistrer
Évaluer et décider	Qualifier l'événement, décider s'il s'agit d'un incident, le classer, l'escalader
Répondre	Confiner, éradiquer, rétablir, préserver les preuves, communiquer
Tirer les enseignements	Analyser les causes, améliorer les mesures, le registre et les procédures

Tableau 16.2. Les cinq phases de l'ISO/IEC 27035-1:2023

★ Attention

Violation typique. Sauter l'évaluation (« on redémarre et on verra »).

Règle : tout événement inhabituel sur un système critique est évalué selon la grille avant d'agir ; en cas de doute, on escalade. Une escalade inutile coûte un appel ; une escalade manquée a coûté, en mars, une nuit et des preuves.

16.3 Classer et Escalader

Gravité	Critère	Escalade
4 · Critique	Activité arrêtée sur plusieurs sites ; données sensibles exfiltrées ; atteinte publique	DG et cellule de crise, sous 1 heure
3 · Haute	Compte à privilèges compromis ; un site arrêté	RSSI et direction, sous 4 heures
2 · Moyenne	Poste ou serveur isolé touché, sans propagation	Équipe de réponse, dans la journée
1 · Basse	Tentative bloquée, signalement	Traitement courant

Tableau 16.3. Grille de gravité et d'escalade de LiZbiZ (convention du cours)

Scénario Opérationnel · Opération GAROUA. Ce que la grille aurait changé

Constatation. À 22 h 05 le 5 mars, l'application de facturation ne répond plus à Douala et à Garoua, et un message de rançon s'affiche sur un serveur.

Analyse (confiance élevée). Selon la grille, deux sites arrêtés et un message de rançon font un incident de gravité 4 : escalade au DG sous une heure, soit avant 23 h 05. La cellule de crise aurait été réunie dans la nuit, au lieu de 10 h 30 le lendemain.

16.4 L'Équipe de Réponse

Rôle	Responsabilité
Responsable de l'incident	Coordonne, décide dans son périmètre, escalade
Analystes	Qualifient, confinent, éradiquent, collectent les preuves
Prestataire	Agit sur les systèmes qu'il administre, selon le contrat
Juridique	Preuves, plainte, obligations envers les tiers
Communication	Messages internes et externes, validés
Direction	Arbitre au-delà du périmètre, décide en cas de crise

Tableau 16.4. Les rôles de la réponse à incident

Procédure de crise

Ouvrir un incident chez LiZbiZ

1. Enregistrer l'incident (numéro, heure, source, description).
2. Classer selon la grille ; en cas de doute, prendre le niveau supérieur.
3. Escalader selon le délai de la grille, par téléphone, puis par écrit.
4. Désigner le responsable de l'incident et ouvrir une main courante.
5. Préserver avant d'agir : ne pas éteindre, isoler, collecter.
6. Reclasser à chaque point de situation.

16.5 Mesurer et Apprendre

Indicateur	Définition
Délai de détection	Du début de l'incident à sa détection
Délai d'escalade	De la détection à l'escalade au niveau de la grille
Délai de confinement	De la détection au confinement
Délai de rétablissement	De la détection au retour à la normale
Part des incidents au registre	Incidents dont le scénario figurait au registre des risques (Chapitre 14)

Tableau 16.5. Indicateurs de la gestion des incidents

Fiche de risque · R-02 · Leçons de l'incident de mars

Scénario : usurpation de l'accès distant du prestataire. **Délais constatés :** détection, 80 h 18 min ; escalade au DG, 15 minutes après la détection ; confinement (coupure des liaisons), 3 h 40 ; rétablissement de la facturation, 11 jours. **Leçons :** grille d'escalade, astreinte formée, guide de réponse au rançongiciel. **Propriétaire :** M. KOUNOU. **Indicateur :** délai d'escalade des incidents de gravité 3 et 4.

Application Responsable de la continuité

Relier incident et continuité. Le responsable de la continuité reçoit toute escalade de gravité 3 ou 4 : c'est lui qui juge s'il faut basculer en mode dégradé ou activer le plan de continuité.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Événement, incident, crise** : trois niveaux, trois gestionnaires.
- **L'ISO/IEC 27035** : préparer, détecter, évaluer, répondre, apprendre.
- **Une grille** classe et fixe le délai d'escalade ; dans le doute, on escalade.
- **L'équipe de réponse** associe technique, prestataire, juridique, communication et direction.
- **On mesure** détection, escalade, confinement, rétablissement, et l'on nourrit le registre.

● Note

Points de contrôle de l'élève. Je sais : distinguer événement, incident et crise ; nommer les cinq phases ; classer un incident et l'escalader ; décrire les rôles de la réponse ; définir les délais qui la mesurent.

✍ Exercice 16.1. Quel niveau ? ★☆☆

Classez en événement, incident, incident majeur ou crise : une alerte d'hameçonnage bloquée ; l'agence de Garoua sans réseau pendant six heures ; la publication de données clients.

✍ Exercice 16.2. Les phases ★☆☆

Dans quelle phase de l'ISO/IEC 27035 se rangent : l'exercice annuel ; la plainte ; la mise à jour du registre après l'incident ?

✍ Exercice 16.3. Le délai ★☆☆

D'après la grille, avant quelle heure le DG devait-il être prévenu le 5 mars ?

✍ Exercice 16.4. L'astreinte ★★☆

Rédigez la fiche réflexe de l'astreinte de LiZbiZ pour un serveur qui ne répond plus la nuit.

✍ Exercice 16.5. Reclasser ★★☆

Un incident ouvert en gravité 2 (un serveur touché) révèle, deux heures plus tard, l'usage d'un compte d'administrateur du domaine. Que faites-vous ?

✍ Exercice 16.6. Le prestataire ★★☆

Quelles obligations le contrat de SAHEL INFOGÉRANCE doit-il prévoir pour la gestion des incidents ?

✍ Exercice 16.7. Les délais ★★☆

Calculez, pour l'incident de mars, le délai entre le chiffrement (5 mars, 21 h 40) et la détection (6 mars, 7 h 30). Pourquoi est-il plus parlant que les 80 heures pour la direction ?

✍ Exercice 16.8. Le registre ★★☆

Pourquoi mesurer la part des incidents dont le scénario figurait au registre ? Que signifie un taux faible ?

✍ Exercice 16.9. Une procédure ★★★

Rédigez la procédure de gestion des incidents de LiZbiZ selon les cinq phases, en deux pages.

✍ Exercice 16.10. Une grille bancaire ★★★

Adaptez la grille du Tableau 16.3 à la BANQUE SANAGA, en tenant compte des clients, des autorités de supervision et des systèmes de paiement.

● Note

Pour aller plus loin.

- ISO/IEC 27035-1 [21].
- NIST SP 800-61 Rev. 3 [33].

● Note

Transition. Pour décider d'un mode dégradé, il faut savoir ce que chaque activité peut supporter. Le Chapitre 17 présente l'analyse d'impact sur l'activité.

17

L'ANALYSE D'IMPACT SUR L'ACTIVITÉ

« On ne reprend pas tout en même temps ;
on reprend d'abord ce qui ne peut pas attendre. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 7 et 16 ; cours SEC3266, chapitre sur la continuité.

✦ Objectifs du chapitre

- ➢ Conduire une analyse d'impact sur l'activité selon l'ISO/TS 22317.
- ➢ Mesurer l'évolution des impacts dans le temps.
- ➢ Fixer la période d'interruption maximale tolérable, le délai de reprise et la perte de données admissible.
- ➢ Recenser les dépendances d'une activité.
- ➢ En déduire l'ordre de reprise.

Question directrice : quelles activités de la BANQUE SANAGA ne peuvent pas attendre ?

La BANQUE SANAGA exploite son système central à Douala. M. EYENGA, responsable de la continuité, doit dire à la direction, pour chaque activité, combien de temps elle peut s'arrêter et combien de données elle peut perdre, avant de choisir et de financer un site de secours. Sans cette analyse, tout semble urgent, et rien n'est priorisé.

Plan du chapitre.

1. L'objet de l'analyse d'impact (section 17.1).
2. Mesurer l'impact dans le temps (section 17.2).
3. Les objectifs de reprise (section 17.3).
4. Les dépendances (section 17.4).
5. L'ordre de reprise (section 17.5).

© *MaletYon*

17.1 L'Objet de l'Analyse d'Impact

Définition

Analyse d'impact sur l'activité (BIA) : processus qui analyse l'impact d'une interruption sur l'organisation au fil du temps, pour fixer les priorités et les objectifs de reprise de chaque activité [11], [22].

L'analyse d'impact précède le choix des stratégies : on ne finance un site chaud que pour les activités qui le justifient. Elle se conduit avec les *responsables d'activité*, et non avec l'informatique seule : c'est le métier qui connaît l'impact d'une heure d'arrêt.

17.2 Mesurer l'Impact dans le Temps

Pour chaque activité, on cote l'impact d'une interruption après une heure, quatre heures, un jour, trois jours, une semaine, sur plusieurs critères : financier, réglementaire, clients, réputation. L'impact retenu à chaque durée est le plus élevé des critères.

Activité	1 h	4 h	1 j	3 j	1 sem.
Virements et compensation	2	4	4	4	4
Retraits aux distributeurs, cartes	1	2	3	4	4
Opérations aux guichets	1	2	3	4	4
Banque en ligne	1	1	2	3	4
Instruction des crédits	1	1	1	2	3
Rapports réglementaires	1	1	1	1	3

Tableau 17.1. Impact dans le temps (1 mineur à 4 critique), BANQUE SANAGA

Lecture. Les virements deviennent critiques en quatre heures, parce que la séance de compensation du jour serait manquée ; les rapports réglementaires peuvent attendre plusieurs jours. L'impact croît par paliers, liés à des échéances externes. La direction a fixé que l'impact devient inacceptable lorsqu'il atteint 3 (majeur) : la première durée où c'est le cas donne la période d'interruption maximale tolérable.

17.3 Les Objectifs de Reprise

■ Définition

Période d'interruption maximale tolérable (MTPD) : durée au-delà de laquelle l'impact d'une interruption devient inacceptable. **Délai de reprise visé** (RTO) : durée, inférieure à la MTPD, au terme de laquelle l'activité doit avoir repris à un niveau minimal. **Perte de données maximale admissible** (RPO) : quantité de données, exprimée en durée, que l'on accepte de perdre. Le **niveau minimal de continuité** (MBCO) est le niveau d'activité acceptable pendant la perturbation.

Activité	MTPD	RTO	RPO	Niveau minimal
Virements et compensation	4 h	2 h	0	Virements urgents, séance du jour
Retraits, cartes	1 j	4 h	15 min	Distributeurs des grandes villes
Guichets	1 j	8 h	15 min	Retraits plafonnés, mode manuel
Banque en ligne	3 j	12 h	1 h	Consultation des comptes
Instruction des crédits	1 sem.	3 j	1 j	Dossiers urgents
Rapports réglementaires	1 sem.	5 j	1 j	Rapports à échéance

Tableau 17.2. Objectifs de reprise de la BANQUE SANAGA (Opération WOURI)

★ Attention

Violation typique. Fixer le RTO égal à la MTPD.

Règle : le RTO laisse une marge sous la MTPD, parce que la détection, la décision et la bascule prennent du temps. Un RTO de 4 h pour une MTPD de 4 h signifie qu'au moindre retard, l'impact devient inacceptable.

17.4 Les Dépendances

Une activité ne reprend que si toutes les ressources dont elle dépend reprennent : personnes, locaux, applications, données, fournisseurs. Le RTO d'une ressource doit être au plus égal au plus petit RTO des activités qui en dépendent.

Ressource	Activités qui en dépendent	RTO exigé	RTO actuel
Système central	Toutes	2 h	24 h
Annuaire et authentification	Toutes	2 h	6 h
Réseau entre agences	Guichets, retraits	4 h	4 h
Prestataire monétique	Retraits, cartes	4 h	2 h
Connexion aux systèmes de paiement	Virements	2 h	8 h

Tableau 17.3. Dépendances et écarts de RTO

Scénario Opérationnel · Opération WOURI. Les écarts

Constatation. Trois ressources ont un RTO actuel supérieur au RTO exigé : le système central (24 h pour 2 h), l'annuaire (6 h pour 2 h) et la connexion aux systèmes de paiement (8 h pour 2 h).

Analyse (confiance élevée). Avec ces écarts, une perte du site de Douala manquerait la séance de compensation du jour : la MTPD des virements serait dépassée. L'analyse d'impact justifie un site de secours chaud pour ces trois ressources, et pas pour les autres (Chapitre 18).

17.5 L'Ordre de Reprise

Procédure de crise

Établir l'ordre de reprise

1. Classer les activités par RTO croissant.
2. Pour chacune, lister ses ressources et leurs dépendances.
3. Reprendre d'abord les ressources dont dépendent les activités les plus urgentes (réseau, annuaire, système central).
4. Puis les activités, dans l'ordre des RTO.
5. Vérifier que la somme des durées de reprise tient dans les RTO.

Fiche de risque · R-W1 · Perte du site de Douala

Scénario : du fait d'un site unique, un incendie ou un rançongiciel rend indisponible le système central, ce qui arrête les virements au-delà de la séance de compensation. **Cotation :** V=2, I=4 (score 8, mais impact critique en quatre heures). **Traitement :** site de secours chaud pour le système central, l'annuaire et la connexion aux

paiements. **Propriétaire :** le directeur des opérations bancaires. **Indicateur :** durée de bascule mesurée au dernier test.

Application Responsable de la continuité

Faire signer les objectifs par les métiers. M. EYENGA fait valider chaque MTPD, RTO et RPO par le responsable de l'activité et présente à la direction le coût de chaque niveau : c'est la direction qui choisit, en connaissance du prix.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **L'analyse d'impact** précède les stratégies et se conduit avec les métiers.
- **L'impact croît dans le temps**, par paliers liés aux échéances.
- **MTPD, RTO, RPO, niveau minimal** : le RTO laisse une marge sous la MTPD.
- **Les dépendances** imposent leur RTO aux ressources.
- **L'ordre de reprise** commence par les ressources des activités les plus urgentes.

● Note

Points de contrôle de l'élève. Je sais : définir l'analyse d'impact ; coter l'impact dans le temps ; distinguer MTPD, RTO, RPO et niveau minimal ; repérer un écart de RTO sur une ressource ; établir un ordre de reprise.

✍ Exercice 17.1. Définitions ★☆☆

Expliquez la différence entre MTPD et RTO avec l'exemple des virements.

✍ Exercice 17.2. Lire le tableau ★☆☆

D'après le Tableau 17.1, au bout de combien de temps les retraits deviennent-ils critiques ?

✍ Exercice 17.3. RPO nul ★☆☆

Que signifie un RPO nul pour les virements ? Quelle technique permet de l'atteindre ?

✍ Exercice 17.4. Écarts ★★☆

Calculez, pour chaque ressource du Tableau 17.3, l'écart entre RTO actuel et RTO exigé. Laquelle est la plus urgente ?

✍ Exercice 17.5. Le prestataire monétique ★★☆

Le prestataire monétique a un RTO de 2 h, meilleur que l'exigence. Cela suffit-il pour que les retraits reprennent en 4 h ? Justifiez par les dépendances.

✍ Exercice 17.6. L'ordre ★★☆

Établissez l'ordre de reprise des ressources et des activités de la BANQUE SANAGA.

✍ Exercice 17.7. Le niveau minimal ★★☆

Proposez un niveau minimal de continuité pour les guichets pendant trois jours sans système central.

✍ Exercice 17.8. LiZbiZ ★★☆

Construisez le tableau de l'impact dans le temps pour la facturation et le suivi des expéditions de LiZbiZ.

✍ Exercice 17.9. Le questionnaire ★★★

Rédigez le questionnaire d'entretien d'analyse d'impact que M. EYENGA soumet aux responsables d'activité.

✍ Exercice 17.10. Le coût des objectifs ★★★

Présentez à la direction de la BANQUE SANAGA trois options de RTO pour le système central (2 h, 8 h, 24 h), avec leurs conséquences sur les activités et un ordre de grandeur de coût.

Note

Pour aller plus loin.

➢ ISO 22301 [11] ; ISO/TS 22317 [22].

Note

Transition. Les objectifs fixés, il faut choisir les stratégies et écrire les plans. C'est l'objet du Chapitre 18.

18

STRATÉGIES ET PLANS DE CONTINUITÉ

« Le plan de continuité se juge le premier matin,
quand ceux qui doivent l'appliquer le trouvent sans le chercher. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 17.

✦ Objectifs du chapitre

- ➢ Situer le système de management de la continuité de l'ISO 22301.
- ➢ Choisir une stratégie de continuité pour chaque type de ressource.
- ➢ Concevoir un mode dégradé.
- ➢ Rédiger un plan de continuité d'activité : déclenchement, rôles, procédures, ressources.
- ➢ Articuler plan de gestion de crise, plan de continuité et plan de reprise informatique.

Question directrice : comment LiZbiZ a-t-elle livré pendant l'inondation de Bonabéri ?

Dans la nuit du 14 au 15 août 2026, l'entrepôt de Bonabéri, à Douala, est inondé par 40 cm d'eau. Cinq mois plus tôt, une telle nuit aurait arrêté les expéditions de Douala pour une semaine. Cette fois, LiZbiZ dispose d'un plan de continuité, écrit en juin après la crise de mars. Les expéditions reprennent en 36 heures depuis un entrepôt de repli. Ce chapitre montre comment un tel plan se construit.

Plan du chapitre.

1. Le système de management de la continuité (section 18.1).
2. Les stratégies par ressource (section 18.2).
3. Le mode dégradé (section 18.3).
4. Le plan de continuité (section 18.4).

© *MaletYon*

5. Les trois plans (section 18.5).

18.1 Le Système de Management de la Continuité

L'[ISO 22301:2019] fixe les exigences d'un système de management de la continuité d'activité, certifiable [11] ; l'ISO 22313 en donne les lignes directrices [13]. Le cœur opérationnel est la clause 8 : analyse d'impact et appréciation des risques (8.2), stratégies et solutions (8.3), plans et procédures (8.4), programme d'exercices (8.5), évaluation de la documentation et des capacités (8.6).

Définition

Continuité d'activité : capacité d'une organisation à continuer à fournir des produits et des services dans des délais et à une capacité acceptables, prédéfinis, pendant une perturbation.

18.2 Les Stratégies par Ressource

Ressource	Stratégies possibles	Choix de LiZbiZ
Personnes	Polyvalence, suppléants désignés, travail à distance	Deux suppléants formés par poste clé
Locaux	Site de repli, accord de réciprocité, location à la demande	Accord avec un entrepôt partenaire à Bassa (Douala)
Technologies	Site de secours, nuage, matériel en réserve	Reprise du système central à Yaoundé (Chapitre 19)
Information	Sauvegardes hors ligne, documents papier	Sauvegardes immuables, bordereaux papier numérotés
Fournisseurs	Second fournisseur, clauses de continuité, stocks	Second opérateur à Garoua, transporteurs de réserve

Tableau 18.1. Stratégies de continuité par ressource

Le choix se fait en comparant, pour chaque stratégie, son *coût* et le RTO qu'elle permet d'atteindre, au regard du RTO exigé par l'analyse d'impact. On ne finance pas une stratégie plus rapide que nécessaire.

18.3 Le Mode Dégradé

Définition

Mode dégradé : manière de poursuivre une activité, à un niveau réduit mais acceptable, sans une ou plusieurs de ses ressources habituelles.

Activité	Mode dégradé de LiZbiZ
Expéditions	Bordereaux papier numérotés en carnets ; liste des clients prioritaires ; tournées fixes
Suivi	Tableur partagé hors du système principal, mis à jour toutes les deux heures ; ligne téléphonique dédiée
Facturation	Factures reconstituées à partir des bordereaux, émises dès le retour du système, par ordre d'ancienneté
Paiements	Virements urgents seulement, double signature sur papier, plafond

Tableau 18.2. Modes dégradés de LiZbiZ

Attention

Violation typique. Un mode dégradé qui dépend de ce qui est en panne (un tableur stocké sur le serveur chiffré).

Règle : le mode dégradé utilise des ressources *indépendantes* de celles qu'il remplace : papier, autre site, autre fournisseur. Il est préparé à l'avance (carnets imprimés, listes à jour) et entraîné.

18.4 Le Plan de Continuité

Procédure de crise

Structure du plan de continuité d'une activité

1. **Objet et périmètre** : activité, sites, objectifs de reprise.
2. **Critères de déclenchement** : qui décide, à partir de quel seuil.
3. **Rôles** : responsable du plan, suppléants, équipes.
4. **Procédures** : premières heures, mode dégradé, retour à la normale.
5. **Ressources** : site de repli, matériel, documents, accès.
6. **Contacts** : internes, clients prioritaires, fournisseurs, autorités, assureur.
7. **Fin de crise** : critères de retour à la normale.

Scénario Opérationnel · Opération MOUNGO. La nuit du 14 août

Constatations.

- 15 août, 4 h 10 : le gardien signale 40 cm d'eau dans l'entrepôt de Bonabéri.
- 5 h 30 : M. NGUELE, responsable du plan, le déclenche par téléphone.
- 6 h 00 : les équipes appliquent la procédure : inventaire des 1 200 colis, transfert des colis secs, information des clients prioritaires.
- 15 août, 18 h 00 : l'entrepôt partenaire de Bassa reçoit les premiers colis ; 16 août, 16 h 00 : les expéditions de Douala reprennent depuis Bassa.
- Bilan : 310 colis endommagés, d'une valeur déclarée de 96 millions de FCFA ; expéditions interrompues 36 heures.

Analyse (confiance élevée). Le RTO des expéditions, fixé à 48 heures, est tenu. Les rayonnages surélevés, prévus pour septembre (Chapitre 11), n'étaient pas encore posés : les colis au sol sont ceux qui ont été endommagés.

18.5 Les Trois Plans

Plan	Question	Responsable chez LiZbiZ
Plan de gestion de crise	Qui décide, qui communique ?	M. ETEME (DG)
Plan de continuité	Comment continuer l'activité ?	Chaque directeur, pour son activité
Plan de reprise informatique	Comment rétablir les systèmes ?	M. KOUNOU

Tableau 18.3. Trois plans, trois questions

Fiche de risque · R-11 · Inondation de Bonabéri (après MOUNGO)

Scénario : inondation de l'entrepôt en saison des pluies. **Cotation :** V passe de 2 à 3 (événement survenu, saisons plus pluvieuses), I reste à 3. **Traitement :** plan de continuité (tenu), rayonnages surélevés (à accélérer), assurance des marchandises (à vérifier). **Propriétaire :** M. NGUELE. **Indicateur :** part des colis stockés au sol entre juin et octobre.

Application Responsable de la continuité

Imprimer le plan. Le responsable de la continuité garde une copie papier du plan et des contacts dans chaque site et chez chaque suppléant : un plan stocké sur le

serveur qui vient de tomber n'existe pas.

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- ➢ **L'ISO 22301** est certifiable ; sa clause 8 organise analyse, stratégies, plans et exercices.
- ➢ **Une stratégie par ressource** : personnes, locaux, technologies, information, fournisseurs.
- ➢ **Le mode dégradé** utilise des ressources indépendantes, préparées et entraînées.
- ➢ **Le plan** dit qui déclenche, qui fait quoi, avec quoi, jusqu'à quand.
- ➢ **Crise, continuité, reprise** : trois plans articulés.

● Note

Points de contrôle de l'élève. Je sais : situer l'ISO 22301 et sa clause 8 ; choisir une stratégie par ressource ; concevoir un mode dégradé ; structurer un plan de continuité ; distinguer les trois plans.

✍ Exercice 18.1. Ressources ★☆☆

Rangez dans les cinq types de ressources : le gardien de Bonabéri ; l'entrepôt de Bassa ; les carnets de bordereaux ; le second opérateur.

✍ Exercice 18.2. Le RTO tenu ★☆☆

Calculez la durée d'interruption des expéditions lors de MOUNGO, du signalement à la reprise. Le RTO de 48 heures est-il tenu ?

✍ Exercice 18.3. Quel plan ? ★☆☆

Quel plan répond à : « qui appelle les clients prioritaires ? » ; « comment restaurer la base de facturation ? » ; « faut-il informer la presse ? »

✍ Exercice 18.4. Indépendance ★★☆

Vérifiez que chaque mode dégradé du Tableau 18.2 est indépendant des ressources qu'il remplace.

✍ Exercice 18.5. Déclenchement ★★☆

Rédigez les critères de déclenchement du plan de continuité des expéditions de Douala.

✍ Exercice 18.6. L'accord de repli ★★☆

Quelles clauses l'accord avec l'entrepôt partenaire de Bassa doit-il contenir ?

✍ Exercice 18.7. Les colis au sol ★★☆

Les colis endommagés étaient ceux stockés au sol. Quelle leçon pour le plan de traitement et pour l'indicateur de R-11 ?

✍ Exercice 18.8. Fin de crise ★★☆

Proposez les critères de retour à la normale après MOUNGO.

✍ Exercice 18.9. Un plan complet ★★★

Rédigez le plan de continuité de la facturation de LiZbiZ, selon la structure en sept points.

✍ Exercice 18.10. Stratégie bancaire ★★★

À partir de l'analyse d'impact du Chapitre 17, proposez à la BANQUE SANAGA une stratégie pour chacune des cinq ressources.

Note

Pour aller plus loin.

➢ ISO 22301 [11] ; ISO 22313 [13].

Note

Transition. Le plan de reprise informatique est la partie la plus technique. Le Chapitre 19 la traite, avec la résilience opérationnelle.

19

REPRISE INFORMATIQUE ET RÉSILIENCE

« Après un rançongiciel, on ne restaure pas un système ;
on en reconstruit un sain. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 17 et 18 ; cours SEC3266, chapitre sur la continuité.

✦ Objectifs du chapitre

- ➢ Choisir une technique de protection des données selon le RTO et le RPO.
- ➢ Rédiger un plan de reprise informatique.
- ➢ Conduire une reprise après rançongiciel sans réinfecter.
- ➢ Appliquer les principes de résilience opérationnelle.
- ➢ Mesurer l'écart entre objectifs et capacité réelle.

Question directrice : comment passer de 250 heures à moins de 48 ?

En mars, la facturation de LiZbiZ est restée arrêtée 250 h 20, pour un objectif fixé après coup à 48 heures. En juin, M. KOUNOU doit présenter un plan de reprise qui tienne cet objectif, et le prouver par un test avant la fin de l'année.

Plan du chapitre.

1. Protéger les données selon les objectifs (section 19.1).
2. Le plan de reprise informatique (section 19.2).
3. Reprendre après un rançongiciel (section 19.3).
4. La résilience opérationnelle (section 19.4).
5. Mesurer la capacité réelle (section 19.5).

© *MaletYon*

19.1 Protéger les Données selon les Objectifs

Technique	RPO typique	RTO typique	Limite
Sauvegarde et restauration	Heures à 1 jour	Heures à jours	Lente à restaurer en volume
Réplication asynchrone	Minutes	Heures	Réplique aussi le chiffrement malveillant
Réplication synchrone	Nul	Minutes à heures	Distance limitée, coût
Actif-actif sur deux sites	Nul	Minutes	Coût élevé, complexité

Tableau 19.1. Techniques de protection des données

★ Attention

Violation typique. Compter sur la réplication contre le rançongiciel.

Règle : la réplication protège contre la perte d'un site, pas contre la corruption : elle recopie le chiffrement. Contre le rançongiciel, il faut des sauvegardes *versionnées*, dont une copie *hors ligne ou immuable*, administrée hors du domaine, et testée.

19.2 Le Plan de Reprise Informatique

L'[ISO/IEC 27031] traite de la préparation des technologies de l'information à la continuité [17] ; le NIST SP 800-34 décrit les plans de contingence des systèmes [37].

☑ Procédure de crise

Contenu du plan de reprise informatique de LiZbiZ

1. Inventaire des systèmes, avec leur RTO et leur RPO (issus de l'analyse d'impact).
2. Ordre de reprise selon les dépendances : réseau, annuaire, bases, applications.
3. Procédures de restauration, pas à pas, pour chaque système.
4. Site de reprise (centre de Yaoundé), capacités, accès.
5. Rôles : équipe informatique, prestataire, éditeurs.
6. Critères de réussite et vérifications (intégrité des données, tests fonctionnels avec les métiers).
7. Retour sur le site principal.

19.3 Reprendre après un Rançongiciel

Après un rançongiciel, l'attaquant peut avoir laissé des accès (comptes créés, services installés). Restaurer sur l'infrastructure compromise, ou restaurer une sauvegarde postérieure à son entrée, revient à le réinviter.

Procédure de crise

Reprise après rançongiciel

1. Préserver les preuves avant toute remise en état (cours SEC3266).
2. Établir la date d'entrée de l'attaquant ; choisir un point de restauration antérieur, ou vérifier la sauvegarde.
3. Reconstruire un environnement sain, isolé : annuaire neuf, comptes réinitialisés depuis des postes sains.
4. Restaurer les données, pas les systèmes infectés ; réinstaller les systèmes à partir de sources sûres.
5. Vérifier l'absence de persistance (comptes, services, tâches planifiées) avant de reconnecter.
6. Reconnecter progressivement, sous surveillance renforcée.

Scénario Opérationnel · Opération GAROUA. Pourquoi onze jours

Constatations. Sauvegardes en ligne supprimées le 5 mars à 21 h 15 ; restauration à partir d'une copie de fin janvier retrouvée sur un disque ; ressaisie de six semaines de factures ; annuaire reconstruit du 9 au 12 mars.

Analyse (confiance élevée). Trois causes expliquent l'essentiel de l'arrêt : l'absence de copie immuable (six semaines de données à ressaisir), l'absence de procédure de reconstruction de l'annuaire (quatre jours), et l'absence de site de reprise prêt. Le plan de juin traite les trois.

19.4 La Résilience Opérationnelle

Définition

Résilience opérationnelle : capacité d'une organisation à fournir ses opérations critiques à travers les perturbations, en anticipant, en absorbant, en s'adaptant et en se rétablissant.

Le Comité de Bâle sur le contrôle bancaire a publié en 2021 des principes de résilience opérationnelle [2]. Ils déplacent le regard des systèmes vers les *opérations critiques* : pour chacune, on fixe une *tolérance à la perturbation*, on cartographie ses interconnexions (personnes, technologies, tiers), et l'on teste la capacité à rester dans la tolérance face à des scénarios sévères mais plausibles.

Principe	Application à la BANQUE SANAGA
Gouvernance	Le conseil approuve les tolérances
Cartographie	Virements : système central, annuaire, connexion aux paiements, équipes de Douala et de Yaoundé
Gestion des tiers	Prestataire monétique, fournisseur du système central
Continuité testée	Bascule annuelle sur le site de secours
Gestion des incidents	Grille et escalade adaptées aux virements

Tableau 19.2. Principes de résilience opérationnelle (d'après le Comité de Bâle, 2021)

19.5 Mesurer la Capacité Réelle

Fiche de risque · R-01 · Test de reprise de novembre

Scénario testé : perte du centre de Douala ; reprise de la facturation à Yaoundé à partir de la sauvegarde immuable de la nuit. **Résultat :** facturation rétablie en 19 heures (RTO de 48 heures tenu) ; données perdues : 5 heures (RPO de 4 heures non tenu, la sauvegarde ayant eu lieu à 1 h et la panne simulée à 6 h). **Action :** journalisation des transactions entre deux sauvegardes. **Propriétaire :** M. KOUNOU. **Indicateur :** durée de la dernière reprise mesurée.

Application Responsable de la continuité

Comparer la capacité mesurée aux objectifs. Le responsable tient, pour chaque système critique, deux colonnes : l'objectif (RTO, RPO) et la dernière valeur mesurée en test. Un objectif jamais mesuré est noté « inconnu », non « atteint ».

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **La technique** se choisit selon le RTO et le RPO ; la réplication ne protège pas de la corruption.
- **Le plan de reprise** fixe l'ordre, les procédures, le site, les rôles et les critères de réussite.
- **Après un rançongiciel**, on reconstruit un environnement sain et l'on restaure les données, pas les systèmes infectés.
- **La résilience opérationnelle** raisonne en opérations critiques et en tolérances.
- **La capacité réelle** se mesure en test et se compare aux objectifs.

Note

Points de contrôle de l'élève. Je sais : associer une technique à des objectifs ; structurer un plan de reprise ; dérouler une reprise après rançongiciel ; énoncer les principes de résilience opérationnelle ; interpréter un résultat de test.

✍ Exercice 19.1. Quelle technique ? ★☆☆

Quelle technique du Tableau 19.1 choisir pour les virements de la BANQUE SANAGA (RPO nul, RTO 2 h) ? Et pour les rapports réglementaires ?

✍ Exercice 19.2. Le test ★☆☆

Dans le test de novembre, le RTO et le RPO sont-ils tenus ? Justifiez par les chiffres.

✍ Exercice 19.3. Réplication ★☆☆

Pourquoi la réplication n'aurait-elle pas sauvé LiZbiZ en mars ?

✍ Exercice 19.4. Le point de restauration ★★☆

L'attaquant est entré le 2 mars à 23 h 12. Quelle sauvegarde faut-il restaurer, et à quelles vérifications la soumettre si l'on en prend une plus récente ?

✍ Exercice 19.5. L'ordre ★★☆

Établissez l'ordre de reprise des systèmes de LiZbiZ : réseau, annuaire, base de facturation, application de facturation, messagerie, portail.

✍ Exercice 19.6. Persistance ★★☆

Citez quatre traces de persistance à rechercher avant de reconnecter un système restauré.

✍ Exercice 19.7. Tolérance ★★☆

Formulez la tolérance à la perturbation des virements de la BANQUE SANAGA, au sens du Comité de Bâle.

✍ Exercice 19.8. Inconnu ★★☆

Pourquoi noter « inconnu » un objectif jamais mesuré ? Reliez à l'instrument du Chapitre 26.

✍ Exercice 19.9. Un plan de reprise ★★★

Rédigez la procédure de reprise de la facturation de LiZbiZ sur le site de Yaoundé, pas à pas, avec les vérifications.

✍ Exercice 19.10. Scénario sévère ★★★

Proposez à la BANQUE SANAGA trois scénarios « sévères mais plausibles » pour tester sa résilience, et la mesure de réussite de chacun.

● Note

Pour aller plus loin.

- ISO/IEC 27031 [17] ; NIST SP 800-34 [37].
- Comité de Bâle, *Principles for Operational Resilience* [2].

● Note

Transition. Un plan non exercé est une hypothèse. Le Chapitre 20 apprend à exercer et à tester les plans.

20

EXERCER ET TESTER LES PLANS

« Un exercice qui réussit tout n'a rien appris à personne. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 18 et 19.

✦ Objectifs du chapitre

- ➢ Distinguer revue, exercice et test, et leurs niveaux de réalisme.
- ➢ Construire un programme d'exercices sur plusieurs années.
- ➢ Concevoir un exercice : objectifs mesurables, scénario, injections, observation.
- ➢ Évaluer un exercice et en tirer un plan d'actions.
- ➢ Limiter les risques d'un test sur des systèmes réels.

Question directrice : comment savoir que le plan de continuité fonctionne, avant la prochaine crise ?

En juin, LiZbiZ dispose d'un plan de continuité et d'un plan de reprise. Personne ne les a jamais utilisés. En août, l'inondation de Bonabéri a prouvé le premier pour les expéditions de Douala ; mais la facturation, les autres sites et la cellule de crise n'ont pas été éprouvés. Il faut un programme d'exercices, avant que les événements ne s'en chargent.

Plan du chapitre.

1. Revue, exercice, test (section 20.1).
2. Le programme d'exercices (section 20.2).
3. Concevoir un exercice (section 20.3).
4. Évaluer (section 20.4).
5. Tester sans nuire (section 20.5).

© *MaletYon*

20.1 Revue, Exercice, Test

L'ISO 22301 exige un programme d'exercices et de tests, fondé sur des scénarios, qui valide dans le temps l'efficacité des stratégies et des plans [11]. Le NIST SP 800-84 décrit les programmes de tests, de formation et d'exercices [7].

Forme	Principe	Réalisme	Coût
Revue documentaire	Relire le plan, vérifier contacts et procédures	Faible	Faible
Exercice sur table	Les acteurs discutent un scénario autour d'une table	Moyen	Faible
Exercice fonctionnel	Les acteurs agissent dans leurs rôles, sans toucher la production	Élevé	Moyen
Test technique	Restaurer, basculer, mesurer sur des systèmes réels ou copiés	Élevé	Moyen à élevé
Exercice grandeur réelle	Toute l'organisation, systèmes compris	Très élevé	Élevé

Tableau 20.1. Les formes d'exercice et de test

Définition

Exercice : activité qui entraîne des personnes et évalue des plans ou des capacités à partir d'un scénario. **Test** : exercice dont on attend un résultat mesurable, réussi ou échoué (une restauration en moins de 48 heures).

20.2 Le Programme d'Exercices

Un programme progresse du simple au complexe, couvre toutes les activités critiques sur un cycle, et varie les scénarios.

Période	Exercice	Plan éprouvé	Forme
Sept. 2026	Relecture et appel des contacts	Tous	Revue
Oct. 2026	Prise en main de la cellule de crise	Gestion de crise	Sur table
Nov. 2026	Reprise de la facturation à Yaoundé	Reprise informatique	Test technique
Fév. 2027	Rançongiciel, cellule de crise	Gestion de crise	Sur table
Mai 2027	Coupure de Garoua quatre jours	Continuité du Nord	Fonctionnel
Sept. 2027	Perte de Douala, bascule	Tous	Grandeur réelle partielle

Tableau 20.2. Programme d'exercices 2026-2027 de LiZbiZ

20.3 Concevoir un Exercice

Procédure de crise

Concevoir un exercice

1. **Objectifs mesurables** : « la facturation reprend en moins de 48 heures », « le DG est prévenu en moins d'une heure ».
2. **Périmètre et participants** : qui joue, qui observe, qui anime.
3. **Scénario** réaliste, tiré du registre des risques.
4. **Injections** : messages qui font évoluer la situation à heures fixes (un journaliste appelle, la sauvegarde est corrompue).
5. **Grille d'observation** : pour chaque objectif, ce que l'observateur note et quand.
6. **Règles de sécurité** : mot d'arrêt, communication « EXERCICE » sur chaque message.

★ Attention

Violation typique. Un scénario connu à l'avance des joueurs, sans surprise.

Règle : les joueurs connaissent la date et le cadre, pas le scénario. Au moins une injection doit mettre le plan en défaut (un suppléant absent, un fournisseur injoignable) : c'est là qu'on apprend.

20.4 Évaluer

Scénario Opérationnel · Opération LIZBIZ. Le test de reprise de novembre

Objectifs. Facturation reprise en moins de 48 heures ; données perdues inférieures à 4 heures ; contrôle de dix factures par la DAF.

Constatations. Reprise en 19 heures ; perte de 5 heures de données ; huit factures sur dix conformes, deux avec un taux de taxe erroné (paramètre non restauré).

Analyse (confiance élevée). Le RTO est tenu ; le RPO ne l'est pas (Chapitre 19) ; la restauration des paramètres n'était pas dans la procédure. Le test a fait apparaître deux écarts que rien d'autre n'aurait révélés.

Objectif	Résultat	Action
Reprise en moins de 48 h	Atteint (19 h)	Aucune
Perte inférieure à 4 h	Non atteint (5 h)	Journalisation des transactions
Dix factures conformes	Non atteint (8/10)	Ajouter les paramètres à la procédure

Tableau 20.3. Évaluation du test de novembre

20.5 Tester sans Nuire

Un test sur des systèmes réels peut lui-même provoquer un incident. On le prépare comme un changement : fenêtre en heures creuses, sauvegarde préalable, critère d'arrêt, retour arrière prévu et répété, information des utilisateurs et des clients concernés.

Fiche de risque · R-W1 · Bascule annuelle de la BANQUE SANAGA

Scénario testé : perte du site de Douala ; bascule du système central sur le site de secours. **Fenêtre :** un samedi de 22 h à 6 h. **Critère d'arrêt :** toute anomalie sur un virement réel. **Résultat attendu :** bascule en moins de 2 heures, aucun écart de solde. **Propriétaire :** M. EYENGA. **Indicateur :** durée mesurée de la bascule.

Application Responsable de la continuité

Mesurer, pas raconter. Le responsable fait chronométrer chaque étape par un observateur et consigne les heures. Le rapport compare les durées mesurées aux objectifs, étape par étape.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Revue, sur table, fonctionnel, technique, grandeur réelle** : un réalisme et un coût croissants.
- **Le programme** progresse, couvre les activités critiques et varie les scénarios.
- **Un exercice** a des objectifs mesurables, des injections et des observateurs.
- **L'évaluation** compare objectif et résultat et produit des actions.
- **Un test réel** se prépare comme un changement, avec un critère d'arrêt.

Note

Points de contrôle de l'élève. Je sais : distinguer les formes d'exercice ; construire un programme ; rédiger des objectifs mesurables et des injections ; évaluer un exercice ; préparer un test réel sans risque excessif.

✍ Exercice 20.1. Quelle forme ? ★☆☆

Classez : appeler tous les contacts du plan ; restaurer la base de facturation sur une machine de test ; réunir la direction autour d'un scénario d'inondation.

✍ Exercice 20.2. Mesurable ★☆☆

Réécrivez de manière mesurable : « vérifier que la cellule de crise sait se réunir ».

✍ Exercice 20.3. Le test de novembre ★☆☆

Quels objectifs du test de novembre sont atteints, lesquels ne le sont pas ?

✍ Exercice 20.4. Injections ★★☆

Proposez cinq injections pour l'exercice sur table « rançongiciel » de février 2027, avec leur heure.

✍ Exercice 20.5. Observation ★★☆

Construisez la grille d'observation de l'exercice « coupure de Garoua quatre jours ».

✍ Exercice 20.6. Les paramètres ★★☆

Deux factures sur dix avaient un taux erroné. Quelle cause, et quelle correction à la procédure ?

✍ Exercice 20.7. Critère d'arrêt ★★☆

Pourquoi un critère d'arrêt est-il indispensable à la bascule de la BANQUE SANAGA ? Que se passe-t-il s'il est atteint ?

✍ Exercice 20.8. Programme ★★☆

Le programme du Tableau 20.2 couvre-t-il toutes les activités critiques de LiZbiZ ? Que manque-t-il ?

✍ Exercice 20.9. Un dossier d'exercice ★★★

Rédigez le dossier complet de l'exercice fonctionnel de mai 2027 : objectifs, scénario, injections, participants, observation, sécurité.

✍ Exercice 20.10. Rapport d'exercice ★★★

Rédigez le rapport du test de novembre : cadre, objectifs, résultats chronométrés, écarts, actions.

Note

Pour aller plus loin.

- ISO 22301, programme d'exercices [11].
- NIST SP 800-84 [7].

Note

Transition. Quand l'incident déborde les plans, l'organisation entre en crise. La Partie V commence par définir la crise (Chapitre 21).

partie V

Gestion de Crise

© *MaletYon*

21

QU'EST-CE QU'UNE CRISE ?

« La crise, c'est quand les plans ne suffisent plus
et qu'il faut quand même décider. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 16 et 18.

✦ Objectifs du chapitre

- ➢ Définir la crise selon l'ISO 22361 et la distinguer de l'incident.
- ➢ Reconnaître les caractéristiques d'une crise et les signes de l'entrée en crise.
- ➢ Distinguer crises soudaines et crises rampantes.
- ➢ Décrire les phases d'une crise.
- ➢ Expliquer pourquoi une crise désorganise la compréhension de la situation.

Question directrice : pourquoi l'inondation de Bonabéri n'a-t-elle pas été une crise, et le rançongiciel si ?

En août, l'inondation a coûté des marchandises et 36 heures d'interruption ; elle a été gérée par un plan, sans réunir la direction. En mars, le rançongiciel a mobilisé le directeur général pendant trois semaines. La différence ne tient pas seulement au montant : elle tient à l'incertitude, à l'enjeu pour la réputation et à l'absence de réponse toute faite.

Plan du chapitre.

1. Définir la crise (section 21.1).
2. Les caractéristiques d'une crise (section 21.2).
3. Crises soudaines, crises rampantes (section 21.3).
4. Les phases d'une crise (section 21.4).
5. Perdre le sens de la situation (section 21.5).

© *MaletYon*

21.1 Définir la Crise

Définition

Crise (ISO 22361) : situation inhabituelle ou instable, marquée par un haut degré d'incertitude, qui perturbe les activités essentielles ou la crédibilité d'une organisation et exige une action urgente [15]. Le **management de crise** est la capacité de l'organisation à l'anticiper, à s'y préparer, à y répondre et à s'en rétablir.

Un incident se gère par des procédures ; une crise, par des *décisions* que les procédures n'ont pas prévues. Une organisation peut gérer comme un incident ce qui aurait été une crise sans préparation : MOUNGO l'illustre.

21.2 Les Caractéristiques d'une Crise

Caractère	Description	GAROUA (mars)
Incertitude	On ne sait ni l'étendue, ni la cause, ni la durée	Données volées ? Combien de sites ?
Urgence	Chaque heure aggrave les conséquences	Clients sans suivi, rumeur en ligne
Enjeu vital	Survie, réputation, responsabilité	Clients majeurs, actionnaires, justice
Débordement	Les moyens habituels ne suffisent pas	Prestataire lui-même en cause
Exposition	Le public et les médias s'en saisissent	Photographie du message de rançon

Tableau 21.1. Les caractères d'une crise

Scénario Opérationnel · Opérations GAROUA et MOUNGO. Deux situations comparées

Constatations. MOUNGO : cause connue (l'eau), étendue mesurable en quelques heures (1 200 colis), plan disponible, aucune exposition publique. GAROUA : cause et étendue inconnues pendant des jours, aucun plan, prestataire en cause, exposition publique dès le premier soir.

Analyse (confiance élevée). MOUNGO cumule peu des caractères du Tableau 21.1 ; GAROUA les cumule tous. Le critère n'est pas le coût, mais la combinaison d'incertitude, d'urgence, d'enjeu et d'exposition.

21.3 Crises Soudaines, Crises Rampantes

Type	Caractère	Exemple
Soudaine	Un événement brutal, visible	Rançongiciel, incendie, inondation
Rampante	Une dégradation lente, longtemps ignorée, qui éclate	Une fraude interne qui dure des années ; une dette technique

Tableau 21.2. Deux types de crise

Patrick Lagadec a montré que les crises naissent souvent de situations connues mais non traitées, et qu'elles frappent des organisations dont la culture refuse d'envisager l'impensable [28]. La crise de mars était soudaine dans son déclenchement, rampante dans ses causes : compte partagé sans second facteur depuis septembre, absence de plan, recommandation d'audit oubliée depuis 2023.

21.4 Les Phases d'une Crise

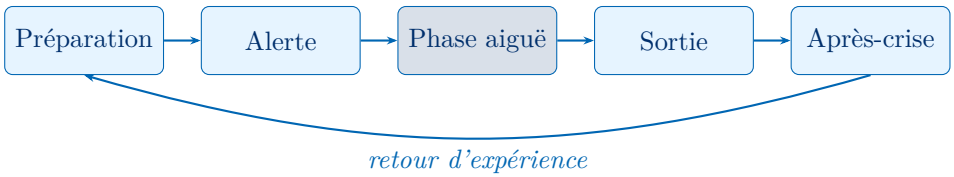


Figure 21.1. Les phases d'une crise

Phase	Enjeu
Préparation	Plans, cellule, annuaire, exercices : tout ce qui se fait à froid
Alerte	Reconnaître la crise et réunir la cellule vite ; c'est là que se perd le plus de temps
Phase aiguë	Décider, informer, protéger, sous incertitude
Sortie	Décider de la fin, alléger le dispositif, ne pas relâcher trop tôt
Après-crise	Retour d'expérience, réparation, suivi des engagements (Chapitre 26)

Tableau 21.3. Les enjeux de chaque phase

★ Attention

Violation typique. Attendre d'être sûr que c'est une crise pour réunir la cellule.

Règle : on réunit la cellule au premier doute sérieux, quitte à la dissoudre une heure plus tard. Le coût d'une fausse alerte est une heure de réunion ; le coût d'une alerte

tardive, en mars, fut 3 h 40 sans décision.

21.5 Perdre le Sens de la Situation

Karl Weick, à partir de l'incendie de Mann Gulch (1949), a décrit l'effondrement du sens : quand les repères habituels ne s'appliquent plus, un groupe peut cesser de comprendre ce qui lui arrive, et ses rôles se défont [42]. La gestion de crise vise d'abord à *reconstruire une compréhension partagée* : ce que l'on sait, ce que l'on ne sait pas, ce que l'on fait.

Procédure de crise

Le point de situation en trois colonnes

1. **Ce que l'on sait** : faits constatés, avec leur heure et leur source.
2. **Ce que l'on ne sait pas** : questions ouvertes, et qui les instruit.
3. **Ce que l'on fait** : décisions prises, responsables, prochaine échéance.

Application Directeur de crise

Ouvrir chaque réunion par le point de situation. Le directeur de crise ne commence pas par les solutions : il fait d'abord établir ce que l'on sait et ce que l'on ignore. C'est le premier remède à l'effondrement du sens.

À retenir

Ce qu'il faut retenir de ce chapitre :

- **Une crise** est une situation instable, très incertaine, qui menace l'essentiel et exige une action urgente (ISO 22361).
- **Ses caractères** : incertitude, urgence, enjeu, débordement, exposition.
- **Soudaine ou rampante** ; souvent soudaine dans son déclenchement, rampante dans ses causes.
- **Cinq phases** ; on perd le plus de temps à l'alerte.
- **Reconstruire le sens** : ce que l'on sait, ce que l'on ne sait pas, ce que l'on fait.

Note

Points de contrôle de l'élève. Je sais : définir la crise et la distinguer de l'incident ; reconnaître ses caractères ; distinguer crise soudaine et rampante ; nommer les phases ; conduire un point de situation.

✍ Exercice 21.1. Incident ou crise ★☆☆

Classez, en justifiant par le Tableau 21.1 : la panne de climatisation de Douala ; la publication des données clients le 19 mars ; l'inondation de Bonabéri.

✍ Exercice 21.2. Rampante ★☆☆

Donnez trois causes rampantes de la crise de mars.

✍ Exercice 21.3. Les phases ★☆☆

Datez, pour l'Opération GAROUA, le début et la fin de chaque phase de la Figure 21.1.

✍ Exercice 21.4. Le point de situation ★★☆

Rédigez le point de situation en trois colonnes de la réunion du 6 mars à 10 h 30.

✍ Exercice 21.5. L'alerte ★★☆

Proposez trois critères qui, chez LiZbiZ, déclenchent la réunion de la cellule de crise sans attendre de certitude.

✍ Exercice 21.6. MOUNGO en crise ★★☆

Quels événements auraient transformé l'inondation de Bonabéri en crise ?

✍ Exercice 21.7. La sortie ★★☆

Quand la crise de mars s'est-elle terminée ? Proposez des critères de sortie et appliquez-les.

✍ Exercice 21.8. Mann Gulch ★★☆

Expliquez, en dix lignes, l'idée d'effondrement du sens chez Weick, et un signe de cet effondrement le 6 mars.

✍ Exercice 21.9. Typologie bancaire ★★★

Dressez la liste des crises soudaines et rampantes possibles pour la BANQUE SANAGA, et un signe avant-coureur pour chaque crise rampante.

✍ Exercice 21.10. Le seuil ★★★

Rédigez la règle d'escalade qui fait passer LiZbiZ de la gestion d'incident (Chapitre 16) à la gestion de crise.

Note

Pour aller plus loin.

- ISO 22361 [15].
- P. Lagadec [28] ; K. Weick [42].

Note

Transition. Pour décider dans l'incertitude, il faut une organisation. Le Chapitre 22 présente la cellule de crise.

22

LA CELLULE DE CRISE

« En crise, ce qui n'est pas écrit n'a pas été décidé. »

Principe du cours

Niveau : *Intermédiaire à expert* • Chapitres 16 et 21.

✦ Objectifs du chapitre

- ➢ Organiser une cellule de crise à deux niveaux, stratégique et opérationnel.
- ➢ Attribuer les rôles : direction, coordination, main courante, communication, juridique, experts, logistique.
- ➢ Tenir une main courante exploitable.
- ➢ Rythmer la crise par des points de situation et des décisions consignées.
- ➢ Préparer la salle, l'annuaire, les relèves et la fin de crise.

Question directrice : pourquoi la réunion du 6 mars à 10 h 30 n'a-t-elle rien décidé ?

Huit personnes, un directeur général au téléphone, aucun ordre du jour, aucune personne chargée d'écrire. Chacun apporte ses informations, souvent contradictoires ; la discussion porte sur les causes plutôt que sur les décisions. À 11 h 10, on coupe enfin les liaisons. Le 7 mars, Mme NKENG ouvre une main courante, et la cellule commence à fonctionner. Ce chapitre, sur deux séances, montre comment organiser ce qui a manqué le premier jour.

Plan du chapitre.

1. Deux niveaux (section 22.1).
2. Les rôles (section 22.2).
3. La main courante (section 22.3).
4. Le rythme de la crise (section 22.4).
5. La première heure (section 22.5).

© MaletYon

6. Salle, annuaire, relèves, fin (section 22.6).

22.1 Deux Niveaux

Définition

Cellule de crise : équipe constituée à l'avance, réunie sur décision de la direction, qui centralise l'information, prend ou prépare les décisions, coordonne l'action et la communication pendant la crise.

Niveau	Rôle	Chez LiZbiZ
Stratégique (décisionnel)	Fixe les priorités, décide des arbitrages (rançon, communication publique, clients), parle au nom de l'entreprise	DG, DAF, directeur des opérations, juriste, communication
Opérationnel	Exécute, qualifie la situation, propose des options, remonte l'information	Responsable informatique, prestataire, chefs d'agence

Tableau 22.1. Les deux niveaux de la cellule de crise

L'ISO 22361 décrit cette articulation entre le niveau qui décide et celui qui agit [15] ; l'ISO 22320, pour les situations d'urgence, insiste sur une chaîne de commandement claire et une information partagée [14].

Attention

Violation typique. Faire travailler les mêmes personnes aux deux niveaux.

Règle : M. KOUNOU ne peut pas à la fois restaurer les serveurs et siéger trois heures en cellule stratégique. Il y délègue un représentant qui remonte la situation technique ; lui reste à la manœuvre.

22.2 Les Rôles

Rôle	Mission	Titulaire et suppléant
Directeur de crise	Décide, arbitre, fixe le rythme	M. ETEME ; Mme MBALLA
Coordinateur	Prépare les réunions, suit les actions, relance	Mme MOUAFO ; M. NGUELE
Main courante	Consigne heure, fait, source, décision	Mme NKENG ; une assistante formée
Communication	Messages internes et externes, médias	Mme ABOMO ; un prestataire désigné
Juridique	Preuves, plainte, rançon, données personnelles	Me TSALA ; un second cabinet
Experts	Situation technique, options, délais	Représentant de l'informatique, prestataire
Logistique	Salle, repas, transport, relèves	Services généraux

Tableau 22.2. Les rôles de la cellule de crise de LiZbiZ

Chaque rôle a un *suppléant* désigné et formé : une crise dure souvent plus longtemps que la résistance d'une personne, et le titulaire peut être absent (en mars, le DG était sur la route de Yaoundé).

22.3 La Main Courante

Définition

Main courante : registre chronologique, tenu en continu pendant la crise, de tous les faits, informations, décisions et actions, avec leur heure, leur source et leur auteur. Elle sert à piloter, à transmettre lors des relèves, à rendre compte, et à apprendre.

Heure	Type	Contenu	Source ou auteur	Échéance
08 h 05	Fait	Yaoundé et Bafoussam opérationnels, sans trace de chiffrement	M. KOUNOU	–
08 h 20	Décision	Ne pas payer la rançon tant que l'avis juridique n'est pas rendu	M. ETEME	8 mars
08 h 25	Action	Déposer plainte à la police judiciaire	Me TSALA	7 mars 12 h
08 h 40	Informatio	Un client majeur demande un point écrit avant midi	Mme ABOMO	11 h 30
09 h 00	Action	Diffuser le communiqué aux clients	Mme ABOMO	9 h 00

Tableau 22.3. Extrait de la main courante du 7 mars (Opération GAROUA)

Procédure de crise

Tenir la main courante

1. Une ligne par entrée : heure, type (fait, information, décision, action), contenu, source ou auteur, échéance.
2. Distinguer le fait constaté de l'information rapportée ; noter la source.
3. Relire chaque décision à voix haute avant de l'inscrire.
4. Numéroter les actions et les suivre jusqu'à leur clôture.
5. Ne rien effacer ; corriger par une nouvelle ligne datée.
6. Conserver la main courante comme pièce du dossier.

22.4 Le Rythme de la Crise

La cellule se réunit à heures fixes (par exemple toutes les trois heures en phase aiguë, deux fois par jour ensuite). Entre deux réunions, chacun agit. Chaque réunion suit le même ordre.

Procédure de crise

Ordre du jour d'un point de situation

1. Point de situation en trois colonnes : ce que l'on sait, ce que l'on ne sait pas, ce que l'on fait (Chapitre 21).
2. Revue des actions de la réunion précédente.
3. Décisions à prendre, avec les options et leurs conséquences.
4. Communication : messages à valider, destinataires.
5. Heure du prochain point.

22.5 La Première Heure

Procédure de crise

Fiche réflexe du directeur de crise : la première heure

1. Réunir la cellule (physiquement ou à distance) et désigner la personne qui tient la main courante.
2. Faire établir le premier point de situation.
3. Décider des mesures conservatoires : confiner (couper les liaisons), protéger les sauvegardes, préserver les preuves.

4. Activer les plans : continuité, reprise informatique.
5. Désigner le porte-parole ; valider un premier message d'attente interne et externe.
6. Prévenir le conseil juridique, l'assureur, le prestataire.
7. Fixer l'heure du prochain point.

Scénario Opérationnel · Opération GAROUA. Le 6 mars avec une fiche réflexe

Constatation. Le 6 mars, la cellule s'est réunie à 10 h 30, trois heures après la découverte, sans main courante ; la coupure des liaisons a été décidée à 11 h 10, le premier message externe le 7 mars à 9 h.

Analyse (confiance moyenne). Avec la fiche, l'appel de 7 h 45 au DG aurait suffi à déclencher la cellule à distance : les liaisons pouvaient être coupées vers 8 h, et un message d'attente publié dans la matinée, avant la rumeur du soir.

22.6 Salle, Annuaire, Relèves, Fin

Moyen	Exigence
Salle	Une salle principale et une de repli, accessibles sans le réseau de l'entreprise ; tableau, téléphones, alimentation de secours
Annuaire de crise	Imprimé, à jour : cellule, suppléants, prestataires, clients majeurs, assureur, autorités, médias
Moyens indépendants	Téléphones et messagerie hors du système compromis
Relèves	Passation écrite à partir de la main courante, toutes les 12 h au plus
Fin de crise	Décidée et annoncée par le directeur de crise, selon des critères fixés ; passage à une organisation allégée

Tableau 22.4. Les moyens de la cellule de crise

Fiche de risque · R-20 · Indisponibilité de la cellule de crise

Scénario : du fait de la messagerie hébergée sur le système compromis, la cellule ne peut ni se joindre ni joindre les tiers. **Cotation :** V=2, I=3. **Traitement :** annuaire imprimé, groupe de messagerie hors du système, salle de repli. **Propriétaire :** Mme MOUAFO. **Indicateur :** date de la dernière vérification de l'annuaire de crise.

Application Directeur de crise

Décider de la fin. Le directeur de crise ne laisse pas la crise s'éteindre d'elle-même : il annonce la fin, la passation à l'organisation normale, et la date du retour d'expérience.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Deux niveaux** : stratégique qui décide, opérationnel qui agit ; pas les mêmes personnes.
- **Des rôles nommés**, chacun avec un suppléant formé.
- **La main courante** : heure, type, contenu, source, échéance ; on n'efface rien.
- **Un rythme fixe**, un ordre du jour constant.
- **La première heure** se joue avec une fiche réflexe ; salle, annuaire et relèves se préparent à froid.

Note

Points de contrôle de l'élève. Je sais : distinguer les deux niveaux ; attribuer les rôles ; tenir une main courante ; conduire un point de situation ; dérouler la fiche réflexe de la première heure.

Exercice 22.1. Quel niveau ? ★☆☆

Rangez au niveau stratégique ou opérationnel : décider de ne pas payer la rançon ; restaurer la base de facturation ; valider le communiqué.

Exercice 22.2. Le type ★☆☆

Donnez le type (fait, information, décision, action) de chaque ligne du Tableau 22.3.

Exercice 22.3. Les suppléants ★☆☆

Pourquoi chaque rôle a-t-il un suppléant ? Donnez l'exemple du 6 mars.

Exercice 22.4. Une main courante ★★☆

Rédigez la main courante de la matinée du 6 mars, de 7 h 30 à 11 h 10, à partir du Tableau 0.2.

✍ Exercice 22.5. Corriger ★★☆

À 10 h, on apprend que l'information de 8 h 05 était fausse : Bafoussam est touché. Comment le consigner dans la main courante ?

✍ Exercice 22.6. Le rythme ★★☆

Proposez le calendrier des points de situation du 6 au 9 mars.

✍ Exercice 22.7. La relève ★★☆

Rédigez la fiche de relève remise par Mme NKENG à sa suppléante le 7 mars à 20 h.

✍ Exercice 22.8. L'annuaire ★★☆

Dressez la liste des entrées de l'annuaire de crise de LiZbiZ, par catégorie.

✍ Exercice 22.9. Le plan de gestion de crise ★★★

Rédigez le plan de gestion de crise de LiZbiZ : déclenchement, cellule, rôles, salle, moyens, rythme, fin.

✍ Exercice 22.10. La cellule bancaire ★★★

Composez la cellule de crise de la BANQUE SANAGA pour une indisponibilité du système central, en tenant compte des autorités de supervision et des systèmes de paiement.

● Note

Pour aller plus loin.

➢ ISO 22361 [15] ; ISO 22320 [14].

● Note

Transition. La cellule organisée, il reste à bien décider. Le Chapitre 23 traite de la décision en situation de crise.

23

DÉCIDER EN SITUATION DE CRISE

> « En crise, ne pas décider est aussi une décision,
> et souvent la pire. »
>
> Principe du cours

Niveau : *Expert* • Chapitres 1, 2 et 22.

✦ Objectifs du chapitre

- ➢ Expliquer comment les experts décident sous pression (modèle de Klein).
- ➢ Reconnaître les biais propres à la crise : effet tunnel, pensée de groupe, biais de normalité.
- ➢ Distinguer décisions réversibles et irréversibles, et les traiter différemment.
- ➢ Structurer une décision difficile : options, critères, conséquences.
- ➢ Préparer à froid les décisions que l'on devra prendre à chaud.

Question directrice : comment décider de payer ou non une rançon en quarante-huit heures ?

Le 7 mars, la cellule de crise doit trancher : payer 85 000 dollars pour une clé de déchiffrement et la promesse de ne pas publier les données, ou refuser. L'information est incomplète, le temps compte, l'enjeu est grand, et la décision ne pourra pas être défaite. Ce chapitre donne une méthode pour ce type de décision.

Plan du chapitre.

1. Comment décident les experts (section 23.1).
2. Les biais de la crise (section 23.2).
3. Réversible ou irréversible (section 23.3).
4. Structurer une décision (section 23.4).
5. Décider à froid ce qui se décidera à chaud (section 23.5).

© *MaletYon*

23.1 Comment Décident les Experts

Gary Klein a observé des pompiers, des militaires, des médecins urgentistes : sous pression, ils ne comparent pas des options ; ils *reconnaissent* une situation à partir de leur expérience, imaginent la première action plausible, la simulent mentalement et l'appliquent si elle tient [26]. C'est la **décision fondée sur la reconnaissance**.

Note

Conséquence pour la gestion de crise. Ce mode de décision est rapide et souvent bon, *à condition* d'avoir déjà vu des situations semblables. D'où l'importance des exercices (Chapitre 25) : ils donnent aux décideurs l'expérience que les crises réelles, rares, ne leur donnent pas. Face à une situation vraiment nouvelle, il faut revenir à une décision délibérée.

23.2 Les Biais de la Crise

Biais	Effet	Parade
Effet tunnel	Toute l'attention sur un seul problème (restaurer)	Revue systématique des parties prenantes à chaque point
Biais de normalité	Croire au retour rapide à la normale	Hypothèse de travail pessimiste, révisée à chaque point
Pensée de groupe	Unanimité de façade, objections tues	Tour de table inversé, contradicteur désigné
Excès de confiance	Annoncer un délai de reprise trop court	Annoncer des fourchettes, avec leur hypothèse
Fatigue	Décisions dégradées après de longues heures	Relèves, sommeil imposé au directeur de crise

Tableau 23.1. Biais de la crise et parades

Scénario Opérationnel · Opération GAROUA. « Lundi, tout sera rétabli »

Constatation. Le 6 mars à 16 h, M. KOUNOU annonce aux clients, par la voix de M. NGUELE, un retour à la normale « lundi 9 mars ». La facturation reprend le 16 mars.

Analyse (confiance élevée). L'annonce cumule biais de normalité et excès de confiance : on ignorait encore l'état des sauvegardes. Elle a coûté de la crédibilité à chaque report. Une fourchette (« au plus tôt lundi, au plus tard dans deux semaines, nous préciserons chaque jour ») aurait été plus juste.

23.3 Réversible ou Irréversible

Décision	Exemples	Traitement
Réversible	Couper les liaisons, isoler un serveur, basculer en mode dégradé	Décider vite, sur l'information disponible ; corriger ensuite
Irréversible	Payer la rançon, publier un communiqué, licencier un salarié, effacer un serveur	Prendre le temps strictement nécessaire ; avis juridique ; options écrites

Tableau 23.2. Deux catégories de décisions

★ Attention

Violation typique. Traiter avec la même lenteur la coupure des liaisons (réversible) et le paiement de la rançon (irréversible).

Règle : les décisions réversibles et conservatoires se prennent tout de suite, au besoin par délégation ; les irréversibles se préparent. Le 6 mars, la coupure a attendu 3 h 40 alors qu'elle se défaisait en une minute.

23.4 Structurer une Décision

☑ Procédure de crise

Structurer une décision irréversible

1. **Formuler la question** et l'échéance réelle.
2. **Lister les options**, y compris des options intermédiaires.
3. **Fixer les critères** : continuité, coût, droit, éthique, réputation, précédent.
4. **Évaluer** chaque option sur chaque critère, avec ce que l'on sait et ce que l'on ignore.
5. **Décider**, consigner la décision, ses motifs et l'information disponible (Chapitre 1).

Critère	Payer	Ne pas payer
Continuité	Clé peut-être fournie ; aucune garantie qu'elle fonctionne	Reprise par sauvegardes : copie de fin janvier, ressaisie
Données	Promesse de non-publication sans garantie	Publication probable d'un échantillon
Droit et éthique	Financement d'une activité criminelle ; sanctions possibles selon le destinataire	Conforme à l'avis juridique
Précédent	Signal donné aux attaquants	Signal de fermeté
Coût	85 000 dollars et risque de seconde demande	Coût de la reprise (Tableau 0.4)

Tableau 23.3. La décision du 8 mars, structurée

Scénario Opérationnel · Opération GAROUA. La décision consignée

Main courante, 8 mars, 18 h 10. « Décision : LiZbiZ ne paie pas la rançon. Motifs : aucune garantie de déchiffrement ni de non-publication ; avis de Me TSALA ; sauvegarde de fin janvier exploitable selon M. KOUNOU. Information manquante : étendue des données copiées. Décidé par M. ETEME. »

Analyse (confiance élevée). La décision est documentée avec ses motifs et ses inconnues : elle pourra être jugée sur son dossier, et non sur la publication du 19 mars.

23.5 Décider à Froid ce qui se Décidera à Chaud

Les décisions les plus difficiles se préparent avant la crise : on fixe à froid une *position de principe* et les *délégations*.

Décision préparée	Position adoptée par la direction de LiZbiZ (juin)
Couper les liaisons entre sites	Délégation au responsable informatique ou à l'astreinte, sans attendre le DG
Basculer en mode dégradé	Délégation au directeur des opérations
Payer une rançon	Principe : non ; dérogation par le DG seul, après avis juridique écrit
Premier message public	Message d'attente préapprouvé, publiable par la communication

Tableau 23.4. Décisions préparées à froid

Application Directeur de crise

Déléguer les gestes conservatoires. Le directeur de crise donne à l'avance, par écrit, le pouvoir de prendre les décisions réversibles et urgentes. Il se garde les irréversibles.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Sous pression**, les experts reconnaissent la situation ; les exercices donnent cette expérience.
- **Les biais de crise** : tunnel, normalité, groupe, confiance, fatigue ; chacun a sa parade.
- **Réversible** : vite ; **irréversible** : préparé, documenté.
- **Une décision structurée** : question, options, critères, évaluation, décision consignée.
- **À froid**, on fixe les positions de principe et les délégations.

Note

Points de contrôle de l'élève. Je sais : décrire la décision fondée sur la reconnaissance ; reconnaître un biais de crise et sa parade ; classer une décision en réversible ou irréversible ; structurer une décision ; préparer des délégations.

Exercice 23.1. Réversible ★☆☆

Classez en réversible ou irréversible : isoler un poste ; envoyer un communiqué de presse ; effacer un serveur pour le réinstaller ; basculer sur Yaoundé.

Exercice 23.2. Les biais ★☆☆

Quel biais illustre l'annonce « lundi, tout sera rétabli » ? Quelle parade ?

Exercice 23.3. Klein ★☆☆

Pourquoi le modèle de Klein justifie-t-il les exercices de crise ?

Exercice 23.4. Une fourchette ★★☆

Rédigez l'annonce de délai de reprise que LiZbiZ aurait dû faire le 6 mars à 16 h.

✍ Exercice 23.5. Options intermédiaires ★★☆

Entre « payer » et « ne pas payer », quelles options intermédiaires la cellule pouvait-elle examiner ? Avec quelles limites ?

✍ Exercice 23.6. Consigner ★★☆

Pourquoi consigner l'information manquante au moment de la décision ?

✍ Exercice 23.7. Délégations ★★☆

Proposez deux autres décisions à déléguer à froid, avec leur délégataire.

✍ Exercice 23.8. La fatigue ★★☆

La cellule a siégé dix-huit heures le 7 mars. Proposez une organisation des relèves pour le directeur de crise.

✍ Exercice 23.9. Une décision bancaire ★★★

Le système central de la BANQUE SANAGA est indisponible depuis trois heures. Structurez la décision « fermer ou non les agences demain » : options, critères, évaluation.

✍ Exercice 23.10. La politique ★★★

Rédigez la politique de LiZbiZ sur les rançons : principe, exceptions, procédure de décision, documentation.

● Note

Pour aller plus loin.

- G. Klein, *Sources of Power* [26].
- D. Kahneman [25] ; I. Janis [23].

● Note

Transition. Une décision doit être expliquée. Le Chapitre 24 traite de la communication de crise.

24

COMMUNIQUER EN CRISE

> « Dites vite ce que vous savez, dites ce que vous ne savez pas, et dites quand vous en direz plus. »
>
> Principe du cours

Niveau : *Intermédiaire à expert* • Chapitres 2, 22 et 23.

✦ Objectifs du chapitre

- ➢ Appliquer les principes de la communication de crise.
- ➢ Identifier les parties prenantes et l'ordre dans lequel les informer.
- ➢ Choisir une stratégie de réponse selon la théorie de Coombs.
- ➢ Rédiger un message d'attente, un communiqué et une fiche de questions et réponses.
- ➢ Gérer les réseaux sociaux, le porte-parole et les personnes dont les données sont touchées.

Question directrice : pourquoi la photographie du 6 mars a-t-elle parlé avant LiZbiZ ?

À 18 h 30 le 6 mars, un salarié publie la photographie du message de rançon. LiZbiZ ne dit rien avant le lendemain 9 h. Entre-temps, les clients apprennent l'attaque par les réseaux sociaux, et les journalistes appellent un standard sans consigne. Ce chapitre montre comment parler tôt, juste et d'une seule voix.

Plan du chapitre.

1. Les principes (section 24.1).
2. Les parties prenantes (section 24.2).
3. La théorie de Coombs (section 24.3).
4. Les messages (section 24.4).
5. Porte-parole et réseaux sociaux (section 24.5).

© MaletYon

24.1 Les Principes

Principe	Application
Tôt	Un premier message dans l'heure qui suit la décision de crise, même bref
Exact	Ne dire que ce qui est établi ; dire ce que l'on ne sait pas
Régulier	Annoncer quand viendra la prochaine information, et tenir l'heure
Cohérent	Une seule voix, un seul contenu pour tous les canaux
Empathique	Parler d'abord des personnes touchées, ensuite de l'entreprise
Interne d'abord	Les salariés apprennent la crise par l'entreprise, pas par la presse

Tableau 24.1. Les principes de la communication de crise

★ **Attention**

Violation typique. Se taire « tant qu'on ne sait pas tout ».

Règle : le silence est rempli par d'autres. On publie un *message d'attente* : ce qui s'est passé, ce que l'on fait, quand on en dira plus. On n'attend pas la cause pour parler de la situation.

24.2 Les Parties Prenantes

Partie prenante	Ce qu'elle attend	Canal
Salariés	Que faire, que dire, leur emploi est-il menacé	Réunion, message interne
Clients majeurs	Leurs expéditions, leurs données, les délais	Appel du directeur commercial
Clients touchés par une fuite	Quelles données, quels risques, quoi faire	Lettre individuelle
Autorités	Faits, mesures, respect des obligations	Courrier, selon le conseil juridique
Partenaires et prestataire	Coordination, obligations du contrat	Cellule de crise
Médias	Faits, responsabilité, mesures	Communiqué, porte-parole

Tableau 24.2. Les parties prenantes d'une crise chez LiZbiZ

24.3 La Théorie de Coombs

Timothy Coombs propose une théorie situationnelle de la communication de crise : la réponse doit être adaptée à la *responsabilité* que les parties prenantes attribuent à l'organisation [4].

Groupe de crise	Exemples	Responsabilité attribuée
Victime	Catastrophe naturelle, rumeur, malveillance extérieure	Faible
Accident	Défaillance technique, accident industriel	Moyenne
Évitable	Erreur humaine, négligence, faute de la direction	Forte

Tableau 24.3. Les groupes de crise (d'après Coombs, 2007)

Les stratégies de réponse vont de *nier* (contester la crise ou la responsabilité) à *diminuer* (justifier, minimiser), *reconstruire* (s'excuser, réparer, compenser), complétées par le *renforcement* (rappeler les mérites passés). Plus la responsabilité attribuée est forte, plus il faut reconstruire. Un passé de crises semblables et une mauvaise réputation antérieure aggravent l'attribution.

Scénario Opérationnel · Opération GAROUA. Victime ou négligente ?

Constatation. LiZbiZ est victime d'une attaque criminelle, mais la presse apprend le 21 mars que l'accès du prestataire n'avait pas de second facteur, et qu'un audit l'avait recommandé en 2023.

Analyse (confiance moyenne). La crise passe du groupe « victime » au groupe « évitable ». La stratégie « nous sommes victimes » ne suffit plus : il faut reconnaître le manquement, dire ce qui a changé et proposer une réparation aux clients touchés. Insister sur la seule qualité de victime aurait été perçu comme une dénégation.

24.4 Les Messages

Procédure de crise

Le message d'attente

1. Ce qui s'est passé, en une phrase, sans spéculer.
2. Ce que l'entreprise fait pour les personnes touchées.
3. Ce que l'on ne sait pas encore.

4. Ce que l'on demande (ne pas répondre à des messages suspects, appeler un numéro dédié).
5. Quand viendra la prochaine information.

Exemple. « LiZbiZ subit depuis hier soir une attaque informatique qui perturbe le suivi des expéditions à Douala et à Garoua. Les livraisons continuent ; nos équipes informent chaque client concerné. Nous ne savons pas encore si des données ont été dérobées. Pour toute question, appelez le numéro dédié. Nous ferons un nouveau point demain à 12 h. »

La **fiche de questions et réponses** prépare, pour le porte-parole et le standard, les réponses aux questions prévisibles (« avez-vous payé ? des données ont-elles été volées ? quand la situation sera-t-elle rétablie ? »), et la réponse à donner quand on ne sait pas.

Scénario Opérationnel · Opération MOUNGO. Les clients des colis endommagés

Constatation. 15 août, 11 h : lettre aux clients dont des colis ont été endommagés (41 sur 47 ; les six autres le 17 août, faute d'adresse à jour) ; elle indique les colis concernés, la procédure d'indemnisation et un interlocuteur nommé. Aucune publication de presse.

Analyse (confiance élevée). Crise du groupe « victime » (pluies exceptionnelles), traitée par une communication ciblée, rapide, orientée réparation : aucune escalade médiatique n'a suivi.

24.5 Porte-Parole et Réseaux Sociaux

Sujet	Règle
Porte-parole	Un seul, désigné, formé ; le DG pour les annonces majeures, la communication pour le quotidien
Salariés	Consigne écrite : ne pas publier, renvoyer les questions vers la communication ; expliquer pourquoi
Réseaux sociaux	Surveiller ; répondre aux questions sur le même contenu que le communiqué ; corriger les erreurs factuelles sans polémique
Données personnelles	Message individuel aux personnes concernées, selon l'avis juridique (Chapitre 5)
Ce qu'on ne dit pas	Les détails techniques utiles à l'attaquant, les noms de salariés, les spéculations

Tableau 24.4. Porte-parole et canaux

Application Chargé de communication de crise

Préparer les modèles à froid. Mme ABOMO tient prêts des modèles de message d'attente, de communiqué, de lettre aux clients et de fiche de questions et réponses pour les cinq scénarios majeurs du registre ; en crise, il ne reste qu'à les compléter et à les faire valider.

Fiche de risque · R-21 · Atteinte à la réputation après une crise

Scénario : du fait d'une communication tardive ou défensive, les clients et le public attribuent à LiZbiZ une forte responsabilité, ce qui entraîne des pertes de clients. **Cotation :** V=3, I=3. **Traitement :** modèles préparés, porte-parole formé, message d'attente préapproué. **Propriétaire :** Mme ABOMO. **Indicateur :** délai entre la décision de crise et le premier message lors des exercices.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Tôt, exact, régulier, cohérent, empathique, interne d'abord.**
- **Chaque partie prenante** a ses attentes et son canal.
- **Coombs** : adapter la réponse à la responsabilité attribuée ; reconstruire quand elle est forte.
- **Le message d'attente** dit ce qui s'est passé, ce que l'on fait, ce que l'on ignore, quand on en dira plus.
- **Un porte-parole**, des consignes aux salariés, des modèles prêts.

Note

Points de contrôle de l'élève. Je sais : énoncer les principes ; ordonner les parties prenantes ; situer une crise dans les groupes de Coombs ; rédiger un message d'attente et une fiche de questions et réponses ; fixer les règles du porte-parole.

Exercice 24.1. Quel groupe ? ★☆☆

Situez dans les groupes de Coombs : l'inondation de Bonabéri ; le rançongiciel avant le 21 mars ; le rançongiciel après le 21 mars.

Exercice 24.2. Les principes ★☆☆

Quels principes du Tableau 24.1 LiZbiZ a-t-elle méconnus le 6 mars ?

✍ Exercice 24.3. L'ordre ★☆☆

Dans quel ordre informer, le 6 mars : les salariés, les clients majeurs, la presse, le conseil d'administration ? Justifiez.

✍ Exercice 24.4. Un message d'attente ★★☆

Rédigez le message d'attente aux salariés de LiZbiZ, le 6 mars à 9 h.

✍ Exercice 24.5. Questions et réponses ★★☆

Rédigez la fiche de questions et réponses du standard pour le 7 mars : huit questions et leurs réponses.

✍ Exercice 24.6. Le 21 mars ★★☆

Rédigez le communiqué du 21 mars, après les révélations de la presse, selon une stratégie de reconstruction.

✍ Exercice 24.7. La lettre ★★☆

Rédigez la lettre aux clients dont les données ont été publiées le 19 mars, en tenant compte des questions à soumettre au conseil juridique.

✍ Exercice 24.8. Ce qu'on ne dit pas ★★☆

Un journaliste demande « par quel serveur l'attaquant est-il entré ? ». Que répond le porte-parole, et pourquoi ?

✍ Exercice 24.9. Un plan de communication ★★★

Rédigez le plan de communication de crise de LiZbiZ : rôles, validation, parties prenantes, canaux, modèles, consignes aux salariés.

✍ Exercice 24.10. Une banque ★★★

Le système central de la BANQUE SANAGA est arrêté depuis quatre heures et les distributeurs ne fonctionnent plus. Rédigez le message d'attente aux clients et précisez par quels canaux le diffuser.

● Note

Pour aller plus loin.

- W. T. Coombs, « Protecting Organization Reputations During a Crisis » [4].
- ISO 22361 [15].

Note

Transition. Cellule, décision et communication s'entraînent. Le Chapitre 25 présente les exercices de crise.

25

LES EXERCICES DE CRISE

« On ne s'élève pas au niveau de ses attentes en crise ;
on retombe au niveau de son entraînement. »

Formule d'usage chez les instructeurs

Niveau : *Intermédiaire à expert* • Chapitres 20, 22 à 24.

✦ Objectifs du chapitre

- ➢ Concevoir un exercice de crise pour une cellule de direction.
- ➢ Écrire un scénario et un chronogramme d'injections réalistes.
- ➢ Animer, observer et préserver la sécurité de l'exercice.
- ➢ Conduire un débriefing à chaud et un débriefing à froid.
- ➢ Mesurer la progression d'une cellule d'un exercice à l'autre.

Question directrice : la cellule de crise de LiZbiZ ferait-elle mieux aujourd'hui qu'en mars ?

Le 22 octobre 2026, Mme MOUAFO réunit la direction de LiZbiZ pour un premier exercice sur table de deux heures. Le scénario n'est pas annoncé. La question n'est pas de « réussir », mais de mesurer, par rapport au 6 mars, ce qui a progressé et ce qui manque encore.

Plan du chapitre.

1. Ce qu'entraîne un exercice de crise (section 25.1).
2. Le scénario et les injections (section 25.2).
3. Animer et observer (section 25.3).
4. Débriefer (section 25.4).
5. Mesurer la progression (section 25.5).

© MaletYon

25.1 Ce qu'Entraîne un Exercice de Crise

Un exercice de continuité éprouve des procédures ; un exercice de crise éprouve une *organisation qui décide* : se réunir vite, partager la situation, décider sous incertitude, communiquer, tenir la main courante. Il donne aux dirigeants l'expérience que les crises réelles, rares, ne leur donnent pas (Chapitre 23).

Capacité	Objectif mesurable de l'exercice d'octobre
Se réunir	Cellule réunie en moins de 30 minutes après l'alerte
Tenir la main courante	Main courante ouverte dans les 5 minutes
Communiquer	Premier message validé en moins de 60 minutes
Décider	Décisions conservatoires prises avant le premier point
Joindre	Tous les contacts utiles joints par l'annuaire de crise

Tableau 25.1. Capacités entraînées et objectifs

25.2 Le Scénario et les Injections

Le scénario part du registre des risques. En octobre, Mme MOUAFO choisit un risque de la zone de contrôle de l'écosystème (Chapitre 8) : une fuite de données chez un transporteur sous-traitant.

Temps	Injection	Capacité visée
T+0	Un transporteur signale qu'un fichier de 3 000 adresses de destinataires de LiZbiZ est en vente sur un forum	Se réunir
T+15	Un journaliste appelle pour confirmation	Communiquer
T+35	Le transporteur ignore depuis quand le fichier a fuité	Décider sous incertitude
T+50	Un client majeur menace de suspendre son contrat	Parties prenantes
T+70	Le directeur général doit quitter la salle (suppléant)	Suppléance
T+90	Le vendeur propose de « retirer » le fichier contre paiement	Politique sur les rançons

Tableau 25.2. Chronogramme de l'exercice du 22 octobre

★ Attention

Violation typique. Un scénario si dur que la cellule est submergée et n'apprend rien, ou si doux qu'elle ne rencontre aucune difficulté.

Règle : doser : chaque injection met une capacité à l'épreuve, une seule à la fois au début, puis plusieurs. L'animateur peut accélérer ou ralentir selon la réaction de la cellule.

25.3 Animer et Observer

Rôle	Mission
Directeur d'exercice	Garant du cadre et de la sécurité ; peut suspendre
Animateurs	Jouent les tiers (journaliste, client, transporteur), envoient les injections
Observateurs	Notent, sur une grille, les heures et les faits liés à chaque objectif
Joueurs	La cellule de crise, dans ses rôles réels

Tableau 25.3. Les rôles d'un exercice de crise

Chaque message porte la mention « EXERCICE » ; un mot d'arrêt est convenu pour le cas où un incident réel surviendrait pendant l'exercice. Aucun appel n'est passé à un vrai journaliste ni à un vrai client.

25.4 Débriefer

Procédure de crise

Deux débriefings

1. **À chaud**, juste après l'exercice, trente minutes : chaque joueur dit ce qui l'a aidé, ce qui l'a gêné, ce qu'il ferait autrement. On ne juge personne.
2. **À froid**, une à deux semaines plus tard : rapport fondé sur les grilles d'observation ; objectifs atteints ou non ; actions, responsables, échéances.

Scénario Opérationnel · Opération LIZBIZ. L'exercice du 22 octobre

Constatations (grilles d'observation).

- Cellule réunie en 25 minutes ; main courante ouverte à 4 minutes.
- Premier message validé à 52 minutes.
- Décision de refuser le paiement conforme à la politique, prise en 8 minutes.
- Suppléance : Mme MBALLA prend la direction, mais un numéro sur vingt-trois

de l'annuaire de crise est faux.

➢ Personne n'est chargé d'appeler l'assureur ; l'appel n'est pas passé.

Analyse (confiance élevée). Quatre objectifs sur cinq sont atteints (contre aucun le 6 mars). Les deux écarts sont simples à corriger : mise à jour trimestrielle de l'annuaire, ajout de l'assureur à la fiche réflexe (Chapitre 22).

25.5 Mesurer la Progression

Indicateur	6 mars (réel)	22 octobre (exercice)
Délai de réunion de la cellule	3 h	25 min
Délai d'ouverture de la main courante	Plus d'un jour	4 min
Délai du premier message externe	25 h 30	52 min
Contacts joints par l'annuaire	Pas d'annuaire	22 sur 23

Tableau 25.4. Progression de la cellule de crise de LiZbiZ

★ Attention

Violation typique. Comparer un exercice préparé et une crise réelle comme s'ils étaient équivalents.

Règle : l'exercice se déroule un jour ouvré, à heure connue, avec une cellule présente ; la crise de mars a éclaté un vendredi à l'aube, le DG sur la route. La progression est réelle, mais elle doit être confirmée par un exercice inopiné, hors des heures ouvrées.

Application Directeur de crise

Jouer son propre rôle. M. ETEME participe aux exercices dans son rôle réel et accepte d'être mis en défaut : un directeur général qui se fait remplacer à l'exercice ne sera pas prêt le jour venu.

★ À retenir

Ce qu'il faut retenir de ce chapitre :

➢ **Un exercice de crise** éprouve une organisation qui décide, avec des objectifs mesurables.

➢ **Le scénario** vient du registre ; les injections sont dosées et datées.

- **Animateurs, observateurs, directeur d'exercice** ; mention « EXERCICE » et mot d'arrêt.
- **Débriefing à chaud** sans jugement, **à froid** fondé sur les observations.
- **La progression** se mesure d'un exercice à l'autre, et se confirme par un exercice inopiné.

Note

Points de contrôle de l'élève. Je sais : fixer les objectifs d'un exercice de crise ; écrire un chronogramme d'injections ; répartir les rôles ; conduire les deux débriefings ; mesurer une progression.

Exercice 25.1. Les objectifs ★☆☆

Combien d'objectifs du Tableau 25.1 l'exercice d'octobre a-t-il atteints ? Lesquels ne l'ont pas été ?

Exercice 25.2. Les rôles ★☆☆

Qui, dans l'exercice, joue le journaliste ? Qui peut suspendre l'exercice ?

Exercice 25.3. La progression ★☆☆

Calculez, pour chaque indicateur du Tableau 25.4, le gain entre mars et octobre.

Exercice 25.4. Une injection ★★☆

Ajoutez deux injections au chronogramme d'octobre pour éprouver la communication interne.

Exercice 25.5. La grille ★★☆

Construisez la grille d'observation de l'objectif « premier message validé en moins de 60 minutes ».

Exercice 25.6. À chaud ★★☆

Préparez les trois questions du débriefing à chaud et la règle qui empêche d'en faire un procès.

Exercice 25.7. L'assureur ★★☆

L'appel à l'assureur a été oublié. Corrigez la fiche réflexe de la première heure (Chapitre 22).

✍ Exercice 25.8. Inopiné ★★☆

Concevez un exercice inopiné d'une heure, un samedi matin, et dites ce qu'il mesure que l'exercice d'octobre ne mesurait pas.

✍ Exercice 25.9. L'exercice de février ★★★

Concevez l'exercice sur table « rançongiciel » de février 2027 : objectifs, scénario, chronogramme de huit injections, rôles, sécurité.

✍ Exercice 25.10. Le rapport à froid ★★★

Rédigez le rapport à froid de l'exercice du 22 octobre.

Note

Pour aller plus loin.

➢ ISO 22361 [15] ; NIST SP 800-84 [7].

Note

Transition. Exercices et crises réelles ne servent que si l'on en tire les leçons. Le Chapitre 26 traite du retour d'expérience et de la mesure de la résilience.

partie VI

Apprendre et Mesurer

© MaletYon

26

RETOUR D'EXPÉRIENCE, RÉSILIENCE ET MESURE

« Une organisation apprend quand ses erreurs
changent ses pratiques, pas quand elle les raconte. »

Principe du cours

Niveau : *Expert* • Ensemble du cours.

✦ Objectifs du chapitre

- ➢ Conduire un retour d'expérience : faits, écarts, causes, actions.
- ➢ Remonter aux causes profondes sans désigner de coupable.
- ➢ Suivre les actions jusqu'à leur effet.
- ➢ Mesurer la résilience avec l'instrument OUI / NON / NEK et les mesures μ, U, H.
- ➢ Dire la précision d'une mesure et ce qu'elle ne permet pas de conclure.

Question directrice : LiZbiZ est-elle plus résiliente en octobre qu'en mars, et le sait-elle ?

Le 2 avril, la réunion de retour d'expérience de l'Opération GAROUA a produit quarante idées et aucune décision. En mai, Mme MOUAFO a repris la méthode. En octobre, le conseil demande : « sommes-nous plus résilients ? De combien ? Avec quelle certitude ? » Ce dernier chapitre répond, et résume le cours.

Plan du chapitre.

1. Le retour d'expérience (section 26.1).
2. Remonter aux causes (section 26.2).
3. Suivre jusqu'à l'effet (section 26.3).
4. Mesurer la résilience (section 26.4).

© *MaletYon*

5. La précision de la mesure (section 26.5).
6. Synthèse du cours (section 26.6).

26.1 Le Retour d'Expérience

Définition

Retour d'expérience (RETEX) : démarche structurée qui, après un incident, une crise ou un exercice, établit les faits, les compare à ce qui était prévu, en recherche les causes et décide des actions qui changent durablement les pratiques.

Procédure de crise

Conduire un retour d'expérience

1. **Établir la chronologie** à partir de la main courante et des journaux, avant toute interprétation.
2. **Comparer** à ce qui était prévu (plans, objectifs, procédures) : les écarts.
3. **Rechercher les causes** de chaque écart, jusqu'aux causes d'organisation.
4. **Décider** d'un petit nombre d'actions, chacune avec un responsable, une échéance et un indicateur d'effet.
5. **Diffuser** les enseignements à ceux qui doivent changer leurs pratiques.
6. **Vérifier**, à l'exercice suivant, que les actions ont produit leur effet.

Attention

Violation typique. Faire du retour d'expérience la recherche d'un coupable.

Règle : dans une culture juste (Chapitre 2), on cherche pourquoi le système a permis l'erreur, et non qui l'a commise. Le technicien qui a redémarré les serveurs le 5 mars n'avait ni consigne, ni grille, ni formation : c'est l'organisation qu'il faut corriger.

26.2 Remonter aux Causes

James Reason distingue les *défaillances actives*, commises au contact du système (un clic, un redémarrage), et les *conditions latentes*, créées par des décisions d'organisation, parfois anciennes, qui laissent passer les défaillances [35]. Le retour d'expérience remonte des unes aux autres.

Écart de mars	Chaîne des causes
Serveurs redémarrés à 22 h 05	Pas de consigne → pas de grille d'escalade → pas de procédure d'incident → aucun dispositif de gestion des risques
Cellule réunie à 10 h 30	Pas de plan de crise → personne ne savait qui décidait → crise jamais envisagée
Onze jours pour facturer	Pas de copie immuable → pas d'objectif de reprise → pas d'analyse d'impact
Compte du prestataire sans second facteur	Exception jamais revue → recommandation de 2023 non suivie → pas de suivi des audits

Tableau 26.1. Des défaillances actives aux conditions latentes

26.3 Suivre jusqu'à l'Effet

Scénario Opérationnel · Opération GAROUA. Le retour d'expérience repris en mai

Décisions (cinq actions au lieu de quarante idées) : dispositif de gestion des risques (Partie II) ; programme d'audit et suivi des recommandations (Partie III) ; analyse d'impact et plans (Partie IV) ; cellule de crise et fiche réflexe (Partie V) ; exercices réguliers.

Effets vérifiés en octobre. Registre et comité en place ; audit d'octobre réalisé et suivi ; test de reprise de la facturation en 19 heures ; cellule réunie en 25 minutes à l'exercice. **Analyse** (confiance moyenne). Les cinq actions ont produit un effet mesurable ; leur solidité face à une crise inopinée reste à démontrer.

26.4 Mesurer la Résilience

Mme MOUAFO pose les mêmes vingt questions en mars (après coup, sur l'état antérieur) et en octobre : « Existe-t-il un plan de crise approuvé ? », « Le RTO de la facturation a-t-il été mesuré en test ? », « L'annuaire de crise a-t-il été vérifié ce trimestre ? » … Chaque question reçoit OUI, NON ou NEK (connaissance insuffisante pour conclure), selon l'instrument proposé par l'auteur [31].

Définition

Trois mesures. Sur n questions, avec n_O réponses OUI, n_N NON et n_K NEK : $\mu = n_O/n$, la **conformité** ; $U = n_K/n$, l'**incertitude** ; $H = -\sum p \log_2 p$ sur les trois proportions, l'**entropie**, au plus $\log_2 3 \approx 1{,}585$ bit.

Lecture auditologique · La résilience de LiZbiZ, mars et octobre

Vingt questions sur la préparation (plans, cellule, exercices, annuaire, objectifs mesurés, assurance, contrats).

Date	O / N / K	μ	U	H (bit)
Mars	3 / 9 / 8	0,15	0,40	1,458
Octobre	13 / 3 / 4	0,65	0,20	1,279

Constatation. La conformité passe de 0,15 à 0,65, l'incertitude de 0,40 à 0,20. **Analyse** (confiance moyenne). La préparation a progressé, et l'on sait mieux où l'on en est : quatre questions restent sans réponse établie. Compter les NEK comme des OUI afficherait 85 % en octobre, une image flatteuse que rien ne justifie.

$\mu = 0{,}65$ · $U = 0{,}20$ · $H = 1{,}28$ **bit**

26.5 La Précision de la Mesure

Vingt questions, c'est peu. L'intervalle de Wilson à 95 % donne, pour μ, de 0,05 à 0,36 en mars et de 0,43 à 0,82 en octobre : les deux intervalles ne se recouvrent pas, la progression de la conformité est établie. Pour U, il va de 0,22 à 0,61 en mars et de 0,08 à 0,42 en octobre : les intervalles se recouvrent, la baisse de l'incertitude est probable mais pas établie avec vingt questions.

★ Attention

Violation typique. Annoncer au conseil « 65 % de résilience ».

Règle : on donne la mesure, son effectif, sa marge et ce qu'elle mesure (la préparation déclarée et vérifiée, pas la résilience face à une crise réelle). « Résilience » se démontre par des exercices inopinés et par les crises elles-mêmes.

Application Gestionnaire de risques

Faire baisser U d'abord. Mme MOUAFO consacre le trimestre suivant aux quatre questions NEK : chacune deviendra OUI ou NON. Un NON établi vaut mieux qu'un NEK : il se traite.

26.6 Synthèse du Cours

Partie	Ce qu'elle apprend
I. Fondements	Le risque est une incertitude sur des pertes ; nos jugements sont biaisés ; il faut des rôles, un cadre, et la loi l'exige
II. Analyser	Formuler, coter avec prudence, conduire EBIOS RM, chiffrer avec FAIR, simuler, traiter et rendre compte
III. Auditer	Vérifier par la preuve que ce que l'on croit en place l'est, et suivre jusqu'à l'effet
IV. Continuer	Savoir ce qui ne peut pas attendre, préparer les plans, reconstruire sain, exercer
V. Décider en crise	Une cellule organisée, une main courante, des décisions structurées, une parole tôt et juste
VI. Apprendre	Remonter aux conditions latentes, mesurer, et dire ce que l'on ne sait pas

Tableau 26.2. Les six parties du cours

❍

★ À retenir

Ce qu'il faut retenir de ce chapitre :

- **Le retour d'expérience** : chronologie, écarts, causes, quelques actions, diffusion, vérification.
- **On remonte** des défaillances actives aux conditions latentes, sans chercher de coupable.
- **Une action** n'est finie que lorsque son effet est vérifié.
- μ, U, H mesurent la préparation et ce que l'on en ignore ; on fait d'abord baisser U.
- **Une mesure** se donne avec son effectif et sa marge.

● Note

Points de contrôle de l'élève. Je sais : conduire un retour d'expérience ; distinguer défaillance active et condition latente ; calculer μ, U et H ; lire un intervalle de Wilson ; présenter une mesure avec sa marge.

✍ **Exercice 26.1. Actif ou latent** ★☆☆

Classez en défaillance active ou condition latente : le clic de l'assistante hameçonnée ; l'absence de politique de dérogation ; le redémarrage des serveurs.

✍ Exercice 26.2. Calculer ★☆☆

Calculez μ, U et H pour 10 OUI, 6 NON et 4 NEK.

✍ Exercice 26.3. Quarante idées ★☆☆

Pourquoi la réunion du 2 avril, avec quarante idées, n'a-t-elle rien changé ? Que fallait-il faire ?

✍ Exercice 26.4. La chaîne ★★☆

Construisez la chaîne des causes de l'écart « premier message externe 25 h 30 après la découverte ».

✍ Exercice 26.5. NEK compté ★★☆

Calculez la conformité d'octobre si l'on compte les NEK comme des OUI, puis comme des NON. Pourquoi les deux sont-elles trompeuses ?

✍ Exercice 26.6. Les intervalles ★★☆

Expliquez à M. ETEME, sans formule, pourquoi la progression de la conformité est établie et celle de l'incertitude seulement probable.

✍ Exercice 26.7. Un indicateur d'effet ★★☆

Pour chacune des cinq actions décidées en mai, proposez un indicateur qui mesure son effet, et non sa seule réalisation.

✍ Exercice 26.8. Faire baisser U ★★☆

Pour les quatre questions NEK d'octobre (à imaginer), indiquez la preuve qui permettrait de répondre OUI ou NON.

✍ Exercice 26.9. Le rapport au conseil ★★★

Rédigez la page de Mme MOUAFO au conseil sur la résilience de LiZbiZ : mesures, marges, limites, décisions demandées.

✍ Exercice 26.10. Synthèse ★★★

En deux pages, racontez la crise de mars telle qu'elle se serait déroulée si LiZbiZ avait appliqué ce cours un an plus tôt : risques, audit, continuité, crise, retour d'expérience.

● Note

Pour aller plus loin.

➢ J. Reason [35].

- L'instrument OUI / NON / NEK [31] ; l'auditologie [32].
- Les UE INF3226 (audit des systèmes d'information), SEC3266 (sécurité informatique), SEC4031 et SEC4052 (investigation numérique), SEC4062 (hacking éthique).

Note

Conclusion. Gérer les risques, c'est décider avant de savoir ; gérer une crise, c'est décider sans avoir le temps de savoir ; apprendre, c'est savoir enfin, et le dire avec sa marge.

A

GLOSSAIRE

Ce glossaire reprend, sous une forme abrégée, les notions définies dans les chapitres. Le renvoi indique le chapitre où la notion est présentée.

Action corrective Action qui supprime la cause d'un écart pour éviter qu'il ne se reproduise ; la correction ne supprime que l'écart (Ch. 15).

Ampleur des pertes (LM) Dans FAIR, pertes primaires et secondaires d'un événement (Ch. 9).

Analyse d'impact sur l'activité (BIA) Analyse de l'impact d'une interruption au fil du temps, qui fixe priorités et objectifs de reprise (Ch. 17).

Analyse de sensibilité Étude de la variation d'un résultat quand on fait varier une hypothèse entre ses bornes (Ch. 10).

Appétence au risque Types et niveau de risque qu'une organisation accepte pour atteindre sa mission (Ch. 3).

Appréciation du risque Identification, analyse et évaluation du risque (ISO 31000) (Ch. 4).

Audit Processus méthodique, indépendant et documenté d'obtention et d'évaluation de preuves au regard de critères (ISO 19011) (Ch. 12).

Biais Erreur systématique de jugement produite par une heuristique (Ch. 2).

Cellule de crise Équipe constituée à l'avance qui centralise l'information, décide et coordonne pendant la crise (Ch. 22).

Condition latente Faiblesse créée par une décision d'organisation, qui laisse passer les défaillances actives (Reason) (Ch. 26).

Constat d'audit Résultat de la comparaison des preuves aux critères : critère, fait, preuve, cause, conséquence, classement (Ch. 13).

Continuité d'activité Capacité à fournir produits et services à un niveau acceptable pendant une perturbation (Ch. 18).

Courbe de dépassement Probabilité que la perte annuelle dépasse chaque montant (Ch. 10).

Crise Situation instable, très incertaine, qui perturbe l'essentiel ou la crédibilité et exige une action urgente (ISO 22361) (Ch. 21).

Critères d'audit Référentiel auquel on compare les preuves : norme, politique, contrat, loi (Ch. 12).

Critères de risque Termes de référence fixés à l'avance pour évaluer l'importance d'un risque (Ch. 4).

Culture juste Culture où l'on signale erreurs et quasi-accidents sans crainte de sanction injuste (Ch. 2).

Décision fondée sur la reconnaissance Mode de décision des experts sous pression : reconnaître, imaginer une action, la simuler (Klein) (Ch. 23).

Déclaration d'applicabilité Document d'un système de management de la sécurité qui justifie chaque mesure retenue ou exclue (Ch. 8).

Délai de reprise visé (RTO) Durée au terme de laquelle l'activité doit avoir repris à un niveau minimal (Ch. 17).

EBIOS Risk Manager Méthode de l'ANSSI d'appréciation des risques par scénarios, en cinq ateliers (Ch. 8).

Échantillonnage par attributs Comptage des anomalies dans un échantillon aléatoire, avec un taux tolérable et une confiance (Ch. 13).

Échelle de cotation Suite de niveaux définis par une description et une plage de valeurs (Ch. 7).

Énoncé de risque Phrase qui relie une cause, un événement et ses conséquences sur un objectif (Ch. 6).

Entropie (H) Dispersion des réponses OUI, NON, NEK, en bits, au plus $\log_2 3$ (Ch. 26).

Exercice, test Activité qui entraîne et évalue à partir d'un scénario ; un test attend un résultat mesurable (Ch. 20).

FAIR Méthode d'analyse quantitative : risque = fréquence des pertes × ampleur des pertes (Ch. 9).

Fréquence des pertes (LEF) Nombre d'événements de perte par an : fréquence des menaces × vulnérabilité (Ch. 9).

Gouvernance des risques Rôles, règles et instances qui fixent l'appétence, attribuent et vérifient le traitement des risques (Ch. 3).

Heuristique Règle de jugement simple, rapide, source de biais (Ch. 2).

Incertitude (Knight) Situation dont on ne connaît pas la distribution des issues (Ch. 1).

Incertitude (U) Part des réponses NEK dans une grille (Ch. 26).

Incident de sécurité Événements indésirables qui ont une probabilité significative de compromettre l'activité (ISO/IEC 27035) (Ch. 16).

Indicateur clé de risque (KRI) Mesure avancée de l'évolution d'un risque, avec des seuils d'alerte (Ch. 11).

Instrument OUI / NON / NEK Grille dont chaque question admet une troisième réponse : connaissance insuffisante pour conclure (Ch. 26).

Limite supérieure Taux d'anomalies que la population ne dépasse pas, à un niveau de confiance donné (Ch. 13).

Main courante Registre chronologique des faits, informations, décisions et actions de la crise (Ch. 22).

Management de crise Capacité à anticiper une crise, à s'y préparer, à y répondre et à s'en rétablir (Ch. 21).

Matrice de risques Tableau vraisemblance × impact qui classe les risques ; elle ne les mesure pas (Cox) (Ch. 7).

Menace d'une partie prenante Dans EBIOS RM, (dépendance × pénétration) / (maturité cyber × confiance) (Ch. 8).

Message d'attente Premier message bref : ce qui s'est passé, ce que l'on fait, ce que l'on ignore, quand on en dira plus (Ch. 24).

Mode dégradé Manière de poursuivre une activité à un niveau réduit sans certaines ressources (Ch. 18).

Modèle des trois lignes Opérations qui gèrent les risques, fonctions qui aident et surveillent, audit qui donne une assurance (IIA) (Ch. 3).

Monte-Carlo (simulation) Tirages aléatoires répétés des facteurs incertains pour étudier la distribution des résultats (Ch. 10).

Niveau minimal de continuité (MBCO) Niveau d'activité acceptable pendant la perturbation (Ch. 17).

Obligation de moyens Obligation de mettre en œuvre les moyens raisonnables, sans garantir le résultat (Ch. 5).

Période d'interruption maximale tolérable (MTPD) Durée au-delà de laquelle l'impact d'une interruption devient inacceptable (Ch. 17).

PERT (moyenne) (minimum + 4 × plus probable + maximum) / 6 (Ch. 9).

Perte annuelle attendue Fréquence moyenne × ampleur moyenne ; compare des options, ne décrit pas la pire année (Ch. 1).

Perte de données maximale admissible (RPO) Quantité de données, exprimée en durée, que l'on accepte de perdre (Ch. 17).

Plan de traitement Actions, justification, responsable, ressources, échéance, indicateur et résiduel visé de chaque risque traité (Ch. 11).

Point de situation Ce que l'on sait, ce que l'on ne sait pas, ce que l'on fait (Ch. 21).

Preuve d'audit Enregistrements, énoncés de faits ou informations, pertinents et vérifiables (Ch. 13).

Programme d'audit Ensemble d'audits planifiés pour une durée donnée et dirigés vers un but (Ch. 12).

Résilience opérationnelle Capacité à fournir les opérations critiques à travers les perturbations (Ch. 19).

Retour d'expérience Démarche qui établit les faits, les écarts, les causes et décide des actions qui changent les pratiques (Ch. 26).

Risque (ISO 31000) Effet de l'incertitude sur les objectifs (Ch. 1).

Risque résiduel Risque qui subsiste après les seules mesures en place et vérifiées (Ch. 11).

Seuil de rentabilité Valeur d'une hypothèse à partir de laquelle une décision bascule (Ch. 1).

Signal faible Information partielle ou ambiguë qui peut annoncer un risque nouveau ou aggravé (Ch. 6).

Taxonomie des risques Répartition des risques en familles stables, pour la couverture et la consolidation (Ch. 6).

Théorie de Coombs Adapter la réponse de communication à la responsabilité attribuée : victime, accident, évitable (Ch. 24).

B

RÉFÉRENTIEL DES OUTILS

Les outils cités sont des exemples. Le cours privilégie les outils simples (tableur, langage de programmation) qui obligent à comprendre le calcul.

Outil	Usage	Chapitre, lab
Tableur	Registre, matrice, cotation, tableau de bord	Ch. 7, ARGC-LAB-01
Cartographie de l'écosystème	Menace des parties prenantes (EBIOS RM)	Ch. 8, ARGC-LAB-02
Estimation à trois points	Facteurs FAIR, moyenne PERT	Ch. 9, ARGC-LAB-03
Python ou tableur	Simulation de Monte-Carlo, centiles	Ch. 10, ARGC-LAB-04
Tableau de bord	Indicateurs clés de risque et seuils	Ch. 11, ARGC-LAB-05
Plan d'échantillonnage	Taille d'échantillon, limite supérieure	Ch. 13, ARGC-LAB-06
Registre des incidents	Classement, délais, escalade	Ch. 16, ARGC-LAB-07
Grille d'analyse d'impact	MTPD, RTO, RPO, dépendances	Ch. 17, ARGC-LAB-08
Main courante	Chronologie, décisions, actions	Ch. 22, ARGC-LAB-09
Modèles de messages	Message d'attente, questions et réponses	Ch. 24, ARGC-LAB-10

C

MODÈLES ET PROCÉDURES

Les modèles ci-dessous reprennent ceux des chapitres, sous une forme prête à l'emploi.

Fiche de risque

Rubrique	Contenu
Référence et scénario	R-xx ; cause, événement, conséquence sur un objectif
Cotation	Vraisemblance, impact, score, zone ; estimation chiffrée pour les risques majeurs
Traitement	Option et mesures, avec leur échéance
Propriétaire	Responsable de l'activité exposée
Indicateur	Indicateur clé de risque et ses seuils
Résiduel	Cotation après mesures vérifiées, acceptation écrite

Constat d'audit

Rubrique	Contenu
Critère	Exigence de référence
Constat	Fait observé, chiffré
Preuve	Pièce, référence, empreinte
Cause	Pourquoi l'écart existe
Conséquence	Risque qui en résulte
Classement et recommandation	Majeure, mineure, opportunité ; recommandation vérifiable

Ligne de main courante

Colonne	Contenu
Heure	Heure exacte
Type	Fait, information, décision, action
Contenu	Une phrase
Source ou auteur	Qui l'a dit ou décidé
Échéance	Pour les actions

© MaletYon

Message d'attente

Élément	Contenu
Ce qui s'est passé	Une phrase, sans spéculer
Ce que l'on fait	Pour les personnes touchées
Ce que l'on ignore	Dit franchement
Ce que l'on demande	Consignes, numéro dédié
Prochaine information	Heure annoncée, et tenue

Retour d'expérience

Étape	Livrable
Chronologie	À partir de la main courante et des journaux
Écarts	Prévu contre réalisé
Causes	Des défaillances actives aux conditions latentes
Actions	Peu nombreuses ; responsable, échéance, indicateur d'effet
Vérification	À l'exercice suivant

D

TEXTES JURIDIQUES ET NORMATIFS

Seuls les articles lus dans le texte officiel sont cités entre guillemets dans les chapitres ; ce tableau indique où les trouver.

Loi n° 2010/012 relative à la cybersécurité et la cybercriminalité

Article	Objet	Chapitre
4, point 9	Définition de l'audit de sécurité, au regard des risques encourus	5, 12
13	Audit de sécurité obligatoire ; modalités fixées par voie réglementaire	5
26	Systèmes normalisés de gestion continue des risques	5, 4
29	Conservation des données de connexion pendant dix ans ; surveillance des accès	5, 16
30	Évaluation et révision des systèmes de sécurité	5
32	Audit périodique par l'Agence, chaque année ou lorsque les circonstances l'exigent	5, 12

Les articles de la loi n° 2010/012 utilisés dans le cours [29]

Autres textes et normes

© MaletYon

Texte	Statut dans le cours
Loi n° 2024/017 (données personnelles)	Présentée ; articles à lire au Journal officiel [30]
ISO 31000, Guide ISO 73, IEC 31010	Management du risque [8], [10], [16]
ISO/IEC 27001, 27005, 27007, 27035	Sécurité de l'information [18], [19], [20], [21]
ISO 19011	Audit des systèmes de management [12]
ISO 22301, 22313, ISO/TS 22317, ISO/IEC 27031	Continuité [11], [13], [17], [22]
ISO 22361, ISO 22320	Crise et urgence [14], [15]
COSO ERM ; modèle des trois lignes	Référentiels professionnels [3], [39]
NIST SP 800-30, 800-34, 800-61, 800-84	Publications publiques [7], [24], [33], [37]

E

BIBLIOGRAPHIE COMMENTÉE

Pour chaque partie, quelques lectures, avec ce qu'elles apportent. Les références complètes figurent dans la bibliographie du livre.

Partie I · Fondements du risque

- F. Knight [27] : la distinction entre risque et incertitude.
- A. Tversky et D. Kahneman [40] ; P. Slovic [36] : comment nous jugeons les risques.
- C. Perrow [34] ; J. Reason [35] : les accidents des systèmes complexes.

Partie II · Analyser

- ISO 31000 [16] ; ANSSI, EBIOS RM [1].
- L. A. Cox [5] : les limites des matrices.
- J. Freund et J. Jones [6] ; D. Hubbard et R. Seiersen [9] : mesurer le risque.

Partie III · Auditer

- ISO 19011 [12] ; ISO/IEC 27007 [18].

Partie IV · Continuer

- ISO 22301 [11] ; ISO/TS 22317 [22] ; NIST SP 800-34 [37].
- Comité de Bâle [2] : la résilience opérationnelle.

Partie V · Crise

- P. Lagadec [28] ; K. Weick [42] : la crise et la perte du sens.
- G. Klein [26] : décider sous pression ; W. T. Coombs [4] : communiquer.

Partie VI · Apprendre et mesurer

- L'instrument OUI / NON / NEK [31].

© *MaletYon*

F

CONTACTS ET RESSOURCES

Les adresses sont celles des sites institutionnels à la date de rédaction ; à vérifier.

Organisation	Rôle	Site
ANTIC	Régulation de la sécurité électronique au Cameroun	`www.antic.cm`
MINPOSTEL	Tutelle des communications électroniques	`www.minpostel.gov.cm`
ISO	Normes ISO et ISO/IEC	`www.iso.org`
NIST	Publications SP 800	`www.nist.gov`
ANSSI	EBIOS Risk Manager	`cyber.gouv.fr`
COSO	Référentiel ERM	`www.coso.org`
IIA	Modèle des trois lignes, normes d'audit interne	`www.theiia.org`
The Open Group, FAIR Institute	Normes FAIR	`www.opengroup.org`

NDAP SUKULU

Les fiches d'auto-évaluation et les labs du cours sont disponibles sur NDAP SUKULU, sous le code GES4062. NDAP SUKULU est une propriété de MaletYon : `maletyon@proton.me`.

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] Agence nationale de la sécurité des systèmes d'information, *EBIOS Risk Manager. Le guide*, version 1.0, ANSSI, Paris, 2018.

[2] Basel Committee on Banking Supervision, « Principles for Operational Resilience, » Bank for International Settlements, Bâle, rapp. tech., 2021.

[3] Committee of Sponsoring Organizations of the Treadway Commission, *Enterprise Risk Management: Integrating with Strategy and Performance*, COSO, 2017.

[4] W. T. Coombs, « Protecting Organization Reputations During a Crisis : The Development and Application of Situational Crisis Communication Theory, » *Corporate Reputation Review*, t. 10, n° 3, p. 163-176, 2007.

[5] J. Cox Louis Anthony, « What's Wrong with Risk Matrices? » *Risk Analysis*, t. 28, n° 2, p. 497-512, 2008.

[6] J. Freund et J. Jones, *Measuring and Managing Information Risk: A FAIR Approach*. Oxford : Butterworth-Heinemann, 2014.

[7] T. Grance, T. Nolan, K. Burke, R. Dudley, G. White et T. Good, « Guide to Test, Training, and Exercise Programs for IT Plans and Capabilities, » National Institute of Standards et Technology, NIST Special Publication 800-84, 2006.

[8] *Guide ISO 73:2009 – Management du risque – Vocabulaire*, Organisation internationale de normalisation, 2009.

[9] D. W. Hubbard et R. Seiersen, *How to Measure Anything in Cybersecurity Risk*. Hoboken, NJ : Wiley, 2016.

[10] *IEC 31010:2019 – Management du risque – Techniques d'appréciation du risque*, Commission électrotechnique internationale, 2019.

[11] ISO, *ISO 22301:2019 – Security and resilience – Business continuity management systems – Requirements*, Genève : ISO, 2019.

[12] *ISO 19011:2018 – Lignes directrices pour l'audit des systèmes de management*, Troisième édition ; l'édition de 2011 comptait six principes, celle de 2018 en compte sept, Organisation internationale de normalisation, 2018.

[13] *ISO 22313:2020 – Sécurité et résilience – Systèmes de management de la continuité d'activité – Lignes directrices sur l'utilisation de l'ISO 22301*, Organisation internationale de normalisation, 2020.

[14] *ISO 22320:2018 – Sécurité et résilience – Gestion des urgences – Lignes directrices pour la gestion des incidents*, Organisation internationale de normalisation, 2018.

[15] *ISO 22361:2022 – Sécurité et résilience – Management de crise – Lignes directrices*, Organisation internationale de normalisation, 2022.

[16] *ISO 31000:2018 – Management du risque – Lignes directrices*, Organisation internationale de normalisation, 2018.

[17] ISO/IEC, *Information technology. Security techniques. Guidelines for information and communication technology readiness for business continuity*, ISO/IEC 27031:2011, 2011.

[18] ISO/IEC, *ISO/IEC 27007:2020 – Information security, cybersecurity and privacy protection – Guidelines for information security management systems auditing*, Genève : ISO, 2020.

[19] ISO/IEC, *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements*, Genève : ISO, 2022.

[20] ISO/IEC, *ISO/IEC 27005:2022. Sécurité de l'information, cybersécurité et protection de la vie privée. Préconisations pour la gestion des risques liés à la sécurité de l'information*, Organisation internationale de normalisation, Genève, 2022.

[21] ISO/IEC, *Information technology. Information security incident management. Part 1: Principles and process*, ISO/IEC 27035-1:2023, 2023.

[22] *ISO/TS 22317:2021 – Sécurité et résilience – Systèmes de management de la continuité d'activité – Lignes directrices pour l'analyse d'impact sur l'activité*, Organisation internationale de normalisation, 2021.

[23] I. L. Janis, *Victims of Groupthink*. Boston : Houghton Mifflin, 1972.

[24] Joint Task Force Transformation Initiative, « Guide for Conducting Risk Assessments, » National Institute of Standards et Technology, NIST Special Publication 800-30 Rev. 1, 2012.

[25] D. Kahneman, *Thinking, Fast and Slow*. Farrar, Straus et Giroux, 2011.

[26] G. Klein, *Sources of Power : How People Make Decisions*. Cambridge (Massachusetts) : MIT Press, 1998.

[27] F. H. Knight, *Risk, Uncertainty and Profit*. Boston : Houghton Mifflin, 1921.

[28] P. Lagadec, *La gestion des crises : outils de réflexion à l'usage des décideurs*. Paris : McGraw-Hill (Ediscience), 1991.

[29] *Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité au Cameroun*, Version anglaise officielle : Law No. 2010/012 of 21 December 2010 relating to cybersecurity and cybercriminality in Cameroon, 21 déc. 2010.

[30] *Loi n° 2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel au Cameroun*, 23 déc. 2024.

[31] T. E. Minka Mi Nguidjoï. « Modelling epistemic uncertainty in information systems audit: A trichotomous response instrument and its information-theoretic properties. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701270. adresse : https://hal.science/hal-05701270

[32] T. E. Minka Mi Nguidjoï. « Vers l'auditologie : un agenda de recherche en science du design pour une science appliquée de la réduction de l'incertitude dans l'audit des systèmes d'information. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701007. adresse : https://hal.science/hal-05701007

[33] A. Nelson, S. Rekhi, M. Souppaya et K. Scarfone, « Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile, » NIST, NIST Special Publication 800-61 Rev. 3, 2025.

[34] C. Perrow, *Normal Accidents : Living with High-Risk Technologies*. New York : Basic Books, 1984.

[35] J. Reason, *Managing the Risks of Organizational Accidents*. Aldershot : Ashgate, 1997.

[36] P. Slovic, « Perception of Risk, » *Science*, t. 236, n° 4799, p. 280-285, 1987.

[37] M. Swanson et al., « Contingency Planning Guide for Federal Information Systems, » NIST, NIST Special Publication 800-34 Rev. 1, 2010.

[38] N. N. Taleb, *The Black Swan : The Impact of the Highly Improbable*. New York : Random House, 2007.

[39] The Institute of Internal Auditors, *The IIA's Three Lines Model: An Update of the Three Lines of Defense*, IIA, 2020.

[40] A. Tversky et D. Kahneman, « Judgment under Uncertainty : Heuristics and Biases, » *Science*, t. 185, n° 4157, p. 1124-1131, 1974.

[41] D. Vaughan, *The Challenger Launch Decision : Risky Technology, Culture, and Deviance at NASA*. Chicago : University of Chicago Press, 1996.

[42] K. E. Weick, « The Collapse of Sensemaking in Organizations : The Mann Gulch Disaster, » *Administrative Science Quarterly*, t. 38, n° 4, p. 628-652, 1993.

INDEX

action corrective, 120
ampleur des pertes, 76
Analyse d'impact sur l'activité, 132
Appréciation du risque, 35
Appétence au risque, 29
Audit, 100

biais, 22
biais de normalité, 23
biais rétrospectif, 23

calibrées, 24
Cellule de crise, 164
conformité, 195
Continuité d'activité, 138
Correction, 120
Courbe de dépassement des pertes, 85
Crise, 158
crise, 126
critères d'audit, 100
critères de risque, 35
culture juste, 24
cycle opérationnel, 69
cycle stratégique, 69

distribution des conséquences, 14
décision fondée sur la reconnaissance, 172
déclaration d'applicabilité, 68
Délai de reprise visé, 133

entropie, 195
excès d'optimisme, 23
Exercice, 150

fiche de questions et réponses, 180
fréquence des pertes, 76

Gouvernance des risques, 28

Heuristique, 22

incertitude, 14, 195
Incident de sécurité, 126
Indicateur clé de risque, 92

limite supérieure, 107

Main courante, 165
management de crise, 158
Mode dégradé, 139

Niveau de menace d'une partie prenante, 69
niveau minimal de continuité, 133

Obligation de moyens, 42
Obligation de résultat, 42

PERT, 77
Perte annuelle attendue, 15, 78
Perte de données maximale admissible, 133
plan d'amélioration continue de la sécurité, 71
Plan de traitement, 90
Preuve d'audit, 106
Programme d'audit, 101
Période d'interruption maximale tolérable, 133

Retour d'expérience, 194
Risque, 14
risque, 14
risque brut, 60
risque résiduel, 91
Résilience opérationnelle, 145

seuil de rentabilité, 15
Signal faible, 54
Simulation de Monte-Carlo, 84

taxonomie des risques, 54
termes clés, vii

Test, 150
tolérance, 29

valeur de l'information, 16

Échantillonnage par attributs, 107
Échelle de cotation, 60
Énoncé de risque, 52
Événement de sécurité, 126
échantillon, 107

À propos de ce cours

Gérer un risque, c'est décider avant de savoir ; gérer une crise, c'est décider sans avoir le temps de savoir. Ce cours apprend à faire l'un et l'autre avec méthode, et à rendre compte de ce que l'on ignore.

Il progresse en six parties, précédées d'un prologue : les fondements du risque, l'analyse des risques (qualitative, EBIOS Risk Manager, FAIR, Monte-Carlo), l'audit du dispositif (ISO 19011), les incidents et la continuité (ISO/IEC 27035, ISO 22301), la gestion de crise (ISO 22361) et le retour d'expérience.

Chaque notion est ancrée dans les standards internationaux et dans le droit camerounais. Le cours s'adresse aux élèves ingénieurs en génie informatique de l'ENSP Yaoundé et aux professionnels qui exercent comme gestionnaires de risques, auditeurs des systèmes d'information, responsables de la continuité, directeurs de crise ou chargés de communication de crise.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information